Geely Automotive Research Institute (Ningbo)Co.Ltd	Document Release Status **RELEASED**	
	Release Date	Version **(3)**
	Document No	Revision
	Volume No **01**	Page No 1 (1 4 9)

Document Type **CSRS**	Reference No

Document Name

IGM-GEEA4.0-GEELYCSRS260723-EU7 SecOC

GEEA4.0_26R3

R155&GB44495&EU7

xxx

Issued by **changyu.xiang**	Approved by **Guan Chao**

Cyber Security Requirement Specification

Contents

0 REQUIREMENT LOG 5
0.1 List of requirements 5
0.2 Requirements change log 8
0.2.1 New requirements in this issue 8
0.2.2 Updated requirements in this issue 8
0.2.3 Modifications in the updated requirements in this issue 8
0.2.4 Deleted requirements in this issue 8
1 LIST OF REQUIREMENTS WITH DEVIATIONS 9
2 INTRODUCTION 9
2.1 What is the purpose of this document? 9
2.2 Who should read this document? 9
2.3 How is this document organized? 9
2.4 How do you receive more information? 9
3 REVISION HISTORY 9
4 ECU SOFTWARE REQUIREMENTS 9
4.1 Cybersecurity Requirement Specification 10
4.1.1 Euro 7_Hardware Tamper Proof Requirements 10
4.1.2 01_Key Management 15
4.1.2.1 Key Protection 17
4.1.2.2 Key Updating 19
4.1.2.3 Number of Key Slots Supported 20
4.1.3 02_Password Management 21
4.1.4 03_Secure Crypto 23
4.1.4.1 Cryptographic HW Acceleration: AES 23
4.1.4.1.1 Application Layer Encryption - In Transit 23
4.1.4.1.2 Secure Crypto 29
4.1.5 07_CAN Firewall 31
4.1.6 09_SecOC 31
4.1.6.1 SecOC Cluster 33

4.1.6.2 SecOC Configuration 37
4.1.6.3 SecOC Freshness Value Management 41
4.1.6.4 SecOC Key Management 42
4.1.6.4.1 Symmetric Device Key 47
4.1.6.5 SecOC Verification and Failure Handling 51
4.1.7 18_Security Audit Log 55
4.1.7.1 Security Audit Log Introduction 57
4.1.7.2 Terminology 58
4.1.7.3 Security Event Record 58
4.1.7.4 Protection Of Log Data 66
4.1.7.5 Optional Requirements - Protection of log data 68
4.1.7.6 Security Audit Log Events 71
4.1.8 20_Process Separation 89
4.1.9 21_Random Number Generator 92
4.1.9.1 DRBG - Deterministic Random Bit Generator 93
4.1.9.2 TRNG - True Random Number Generator 95
4.1.10 22_Secure Debug 96
4.1.11 25_Secure Boot 101
4.1.11.1 Root of Trust 101
4.1.11.2 On-Chip Root-of-Trust Code 101
4.1.11.3 Chain-of-Trust 102
4.1.11.4 Secure Boot process 104
4.1.11.5 Asymmetric key based solution 104
4.1.11.6 Symmetric-key-based solution 107
4.1.11.7 Secure Boot Flow – Asymmetric keys 109
4.1.11.8 Secure Boot Flow – Symmetric keys using HSM 110

4.1.11.9 Initialization and activation requirements 112
4.1.12 26_HSM 113
4.1.13 29_Enhanced System Hardening for MCU 118
4.1.14 29_System Hardening for MCU 120
4.1.15 39_Rate Limitation 123
4.1.16 40_Input Validation 123
4.1.17 46_[DP]Personal Data Handling in ECUs 123
4.2 CSRS 149
5 DETAILED CHANGE INFO 149

0 REQUIREMENT LOG

0.1 List of requirements

520525	DRBG - Deterministic Random Bit Generator	1
520526	TRNG-Random number generator validation	1
520527	DRBG-Seed Entropy for Deterministic Random Bit Generator	1
520528	DRBG-Seed for Deterministic Random Bit Generator	1
524487	Key Storage Location	1
524490	Protect Access to Key Material	1
524491	Security Key Installation	1
524497	Cryptographic Operations in Secure Environment	1
524499	Follow industry accepted processes	1
524501	General process separation	1
524502	Protected Memory Space	1
524511	Security Event Types	1
524512	Analyze and agree on the security events	1
524513	SecurityEvent structure	1
524514	Read out Security Event records	1
524521	Overwrite strategy	1
524522	Authenticity Verification Of Components	1
524616	Event log flooding	1
524628	Secure storage of log data	1
524629	Security Audit Log - Access Control	1
525137	Mandatory Confidential Key HW Protection	1
525151	Password Storage	1
525153	Authenticated Encryption of Personal Data in Transit	1
525154	Identify and agree on Personal Data protection	1
525155	Personal Data Access Control	1
525156	Secure Erase of Personal Data	1
525158	Ensure code quality - compiler warnings handling	1
525159	Ensure code quality - static code analysis	1
525161	No execute memory	1
525163	Read-only executable memory	1
525165	Stack protection	1
525168	Secure Boot Coverage	1
525169	On-Chip Root-of-Trust code	1
525170	Root-of-Trust Code	1
525171	Root-of-Trust code integrity protection	1
525172	Enforce Chain-of-Trust	1
525173	Chain-of-Trust sequence (sequential)	1
525174	Action on failure	1
525184	Minimum cryptographic support	1
525185	Asymmetric-Key Sign server	1
525186	PKI Secure cryptographic operations	1
525187	The private keys used for signing SW	1
525188	Secure cryptographic operations	1
525190	Root-of-Trust key provisioning	1
525191	Asymmetric key	1
525192	Hash of the asymmetric key	1
525193	Secure Boot [Asymmetric] key protection	1
525194	Secure Boot key revocation	1
525195	Symmetric key	1
525196	Access to symmetric key	1
525197	[Symmetric] Root-of-Trust key provisioning	1
525198	Symmetric keys	1

525199	Secure Boot [Symmetric] key protection	1
525200	Secure Boot Flow – Asymmetric keys	1
525201	Secure Boot Flow – Symmetric keys in Secure Environment	1
525202	Secure Boot activation	1
525203	Secure Boot design validation	1
525204	Secure Boot initialization	1
525205	Secure Boot from optional media	1
527401	PKI Secure cryptographic operations	1
693227	Product vulnerability handling policy(GB)	1
693230	Network ports management（GB)	1
838997	Basic Principles of Personal Information Processing	1
848372	ECU Log Printing Principle	1
851730	General requirements for cryptographic modules(GB)	1
851903	Log recording of vehicle remote control（GB)	1
851907	Key Communication Information Security Event Logging Requirements(GB)	1
973512	Cryptographic HW Engine: AES	1
973513	Cryptographic HW Engine: ECC	1
973514	Cryptographic HW Engine: SHA	1
973515	Minimum Cryptographic Support	1
973516	Cryptographic Algorithm: AES	1
973517	Cryptographic Algorithm: ECC	1
973518	Cryptographic Keys	1
973523	Cryptographic Algorithm: RSA	1
973538	Configuration Integrity	1
973539	Configuration Updates	1
973543	Traffic Inspection	1
985897	Throttling	1
985898	Input Sanitization	1
986037	Disable Hardware Debug Interfaces	1
986039	PCB-BGA or LQFP Packaging	1
986040	PCB-Serial Interfaces	1
986041	PCB-Test Points	1
986330	Disable Software Interfaces for Non-Specified Software Services	1
986362	Disable Hardware Debug Interfaces to HSM	1
986364	Full EVITA Compliant	1
986366	HSM Support	1
986367	Resistant to Side Channel Analysis	1
986377	Interface to Secure Environment cryptographic operations	1
986378	Mandatory Root-of-Trust Public Key Protection	1
986379	Secure Environment	1
986382	Light EVITA Compliance	1
986383	SW Based Solution	1
986836	Password Brute-Forcing	1
986837	Password Conformity	1
986839	Uniqueness of Password	1
987070	AUTOSAR SecOC Support	1
987071	SecOC Implementation and SDB Handling	1
987072	Cluster Key Sync Test	1
987073	SecOC Cluster Key Identifier	1
987074	SecOCClusterKeyID Configuration	1
987075	Configurations in ECU Extract	1
987076	Crypto Algorithm	1
987077	Default Configurations	1
987081	Immediate Return of Authentic Data	1
987082	Optimization for CPU Load	1
987083	Optimization for Latency	1
987084	Profiles and Configuration Overview	1
987085	Signals Protected by SecOC	1

987086	FVM Solution	1
987087	RID for FV Reset	1
987088	Default Development Key	1
987089	Encryption Method for Key Format	1
987091	Key Decryption	1
987092	Key Encryption	1
987093	Key Programmed Status	1
987094	Key Storage	1
987095	Key Type Structure	1
987096	Key Update Handling	1
987097	Device Key	1
987100	Encryption Method for Key Format	1
987101	Key Decryption	1
987102	Key Encryption	1
987104	Key Storage	1
987106	Key Type Structure	1
987108	Key Update Handing	1
987109	Action on Message Failures	1
987110	DID for SecOC Verification Failure Counters	1
987116	DID for SecOC Verification Failures	1
987117	Detection of Corrupt Data Received	1
987118	Verification Modes	1
987167	Authentication Data - Algorithm	1
987168	Authentication Data - Inputs	1
987169	Key storage	1
987170	Authentication Data calculation	1
987185	Event Type - C00B_Diagnostic Events	1
987196	Event Type - C00D_Firewall Events	1
987197	Event Type - C00E_Key Management	1
987198	Event Type - C012_OTA Events	1
987199	Event Type - C00C_Secure Boot	1
987200	Event Type - C00A_Security Access	1
987201	Event Type - C00F_System Access	1
987208	Counter overflow strategy	1
987209	Minimum number of events to be stored	1
987210	Security Event Header	1
987211	Total number of events	1
987213	Logging of Failures	1
987359	Superseding Previous Requirements	1
987360	DRBG-System Performance	1
987361	TRNG - True Random Number Generator	1
987521	Hardware protection for vehicle terminal(GB/T 32960)	1
987837	Key Reuse	1
987839	Key Revocation	1
987842	Key Usage	1
987847	Component Replacement	1
987848	Key Replacement	1
987850	Minimum Key Slots Supported	1
988159	Cryptographic HW Engine: RSA	1
988308	Data secure storage	1
1029012	DID for SecOC TripCounter	1
1029206	Physical Tampering Attacks Recognition	1
1041045	ECU Level	1
1041046	Shell Level	1
1054714	General Requirements	1
1054724	REQ1:Critical Signals of the Core Controller Must Be Routed on Inner PCB Layers	1
1054754	REQ2:Critical Chips and Associated Circuits to Utilize Potting Encapsulation Process	1

1054755	REQ3:Critical Sensor Signal Interface Range Diagnostics	1
1054756	REQ4:Critical Sensor Signal Plausibility Diagnostics	1
1054757	REQ5:Critical Actuator Plausibility Diagnostics	1
1073238	Event Type - [Euro7]C09F_ SecOC Authenticated Freshness Value Verification Failure	1
1073243	Event Type - [Euro7]C0A0_SecOC PDU MAC Verification Failure Counter Exceeds Threshold Limit - Small	1
1073259	Event Type - [Euro7]C0A1_SecOC PDU MAC Verification Failure Counter Exceeds Threshold Limit - Medium	1
1073389	Event Type - [Euro7]C0A2_SecOC PDU MAC Verification Failure Counter Exceeds Threshold Limit - Large	1

0.2 Requirements change log

0.2.1 New requirements in this issue

0.2.2 Updated requirements in this issue

0.2.3 Modifications in the updated requirements in this issue

For details, please look in the DETAILED CHANGE INFO

0.2.4 Deleted requirements in this issue

1 LIST OF REQUIREMENTS WITH DEVIATIONS

2 INTRODUCTION

2.1 What is the purpose of this document?

This document is a Cyber security SWRS. It contains the software requirements for implementation of the Cyber security concepts needed for an ECU to be integrated into the vehicle electrical system. This specification may contain generic requirements that are not applicable to specific ECUs.

2.2 Who should read this document?

This document is intended for:

- Developers of ECU software and hardware at the car OEM, ECU suppliers (Tier 1:s) or sub suppliers/contractors (Tier 2:s).
- Test engineers of electrical systems, ECUs or ECU software and hardware.

2.3 How is this document organized?

This document contains one or several Cyber security concept specifications. Each concept is located in a separate section under "ECU Software Requirements" and can be seen as a stand alone document. Each concept typically has its own introduction chapters containing reference lists, definition and abbreviation lists and similar information.

2.4 How do you receive more information?

More information can be found in the reference document lists. Questions and support issues may also be sent to the team within Geely responsible for the central Cyber security team responsible for the specific project.

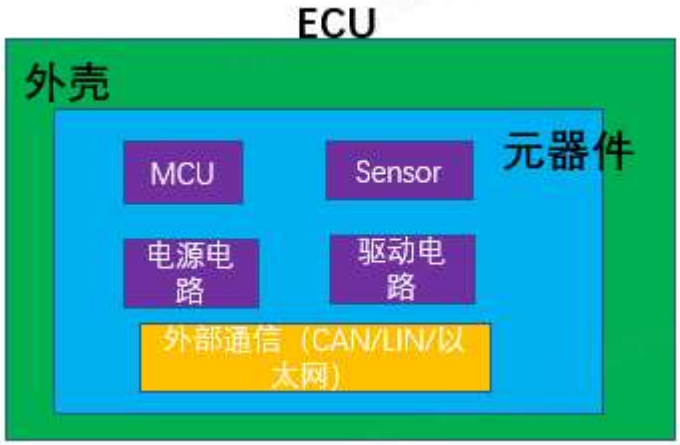
3 REVISION HISTORY

Revision	Date	Description	Author
001	2021-12	first release of the Cyber security SWRS for the GEEA2.0	Yinyang

4 ECU SOFTWARE REQUIREMENTS

4.1 Cybersecurity Requirement Specification

4.1.1 Euro 7_Hardware Tamper Proof Requirements



The hardware anti tampering requirements from the outside to the inside are mainly divided into three levels: ECU level, shell level, and internal electronic component level;

从外到内硬件防篡改需求主要分为3个层级：ECU级别，外壳级别和内部电子元气件级别；

ECU Level

1041045 v1 **ECU Level**

Version history:
(1):

Purpose:
Verification Method: Test
Legacy ID:

ECU level:
Security mechanism: Replacement identification

- By using the S-679-01 function, which identifies physical replacement parts and reminds users, the DHU master node periodically reads the serial numbers of each ECU, Send to the cloud for comparison, and if any abnormalities are found, remind the user via SMS;

ECU级别：

安全机制：换件识别

- 通过S-679-01功能，即物理换件识别提醒用户，DHU主节点周期读取各ECU的序列号，发送到云端进行对比，如发现异常，通过短信提醒用户；

Shell Level

1041046 v1 **Shell Level**

Version history:
(1):

Purpose:
Verification Method: Test
Legacy ID:

Shell level:
Security mechanism: Access control mechanism;

- Shell protection: Strengthen the shell by selecting external objects with rivets to increase the difficulty of disassembly prevention;
- Anti disassembly sticker: If some ECU housings do not support rivet operation, anti disassembly stickers can be added to identify whether the ECU has violent damage behavior through anti disassembly stickers;
- Installation location: If the ECU is installed or fixed on other structural components inside the vehicle and it is difficult to disassemble, there is no need to consider access control mechanisms;

外壳级别:
安全机制：访问控制机制;

- 外壳防护：外壳进行加固，如选择带有铆钉的外部客体，增加防拆解的难度;
- 防拆贴：如一些ECU外壳不支持铆钉操作，可增加防拆贴，通过防拆贴识别该ECU是否有暴力破坏的行为;
- 安装部位：如果ECU安装或者固定在车内其他结构件上，且很难进行拆卸，则不需要考虑访问控制机制;

General Requirements

1054714 v2 **General Requirements**

Version history:
(2):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

REQ1:Critical Signals of the Core Controller Must Be Routed on Inner PCB Layers
REQ2:Critical Chips and Associated Circuits to Utilize Potting Encapsulation Process
REQ3:Critical Sensor Signal Interface Range Diagnostics
REQ4:Critical Sensor Signal Plausibility Diagnostics
REQ5:Critical Actuator Plausibility Diagnostics
REQ1:核心控制器的关键信号布线于PCB内层
REQ2:关键芯片及其关联电路，采用灌胶封装工艺
REQ3:关键传感器信号接口范围诊断
REQ4:关键传感器信号可信性（合理性）诊断
REQ5:关键执行器可信性（合理性）诊断

	A	B	C	D	E
1	细分组件	OBM 监控排放指标（NOx/PM）影响	其他排放指标（CO/HC 等）影响	数据完整性影响	保护需求
2	主控芯片及关联电路	只要是对欧七法规有影响的细分组件，就采用E列需求。			Mandatory: 参考已部署需求 - 软件安全需求 参考已部署需求 - 信号防篡改 Better to have: REQ1 / REQ2
3	通信芯片及处理电路	只要是对欧七法规有影响的细分组件，就采用E列需求。			Mandatory: 参考已部署需求 - 软件安全需求 参考已部署需求 - 信号防篡改 Better to have: REQ1 / REQ2
4	传感器及其信号处理电路	高	"或者"高	"或者"高	Mandatory: REQ4 或者 REQ1 / REQ2
5	传感器及其信号处理电路	低	"并且"低	"并且"低	Better to have: REQ3 REQ1或REQ2;
6	执行器及其驱动电路	高	"或者"高	"或者"高	Mandatory: REQ5 或者 REQ1 / REQ2;
7	执行器及其驱动电路	低	"并且"低	"并且"低	Better to have: REQ1或REQ2;

Note:

-The impact level (high, medium, low) shall be determined with reference to regulatory interpretation documents.
-Each controller/sensor system is responsible for conducting a regulatory impact analysis for its own system and adopting the corresponding protection requirements based on the above protection matrix.
-Due to the absence of an NOx sensor node in the topology, the requirements for the NOx sensor shall be communicated by the ECM.

备注：
- 影响高、中、低参考法规解读文件；
- 各控制器/传感器系统负责本系统的法规影响分析，根据上述保护矩阵确定各自系统应该采纳的保护需求。
- 由于拓扑中无NOx传感器节点，因此NOx传感器的需求由ECM进行传递；

REQ1:Critical Signals of the Core Controller Must Be Routed on Inner PCB Layers

1054724 v2 **REQ1:Critical Signals of the Core Controller Must Be Routed on Inner PCB Layers**

Version history:
(2):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

REQ1. Critical Signals of the Core Controller Must Be Routed on Inner PCB Layers

REQ1. 核心控制器的关键信号布线于PCB内层

Requirement Description: The core controller PCBA shall utilize a multilayer board design. Critical signals, including the encryption chip communication link, data buses (e.g., CAN FD/Ethernet), and core signal processing circuits (e.g., emission data-related circuits), must be routed exclusively on the inner layers of the PCB (not on the top/bottom layers). Pads and vias associated with these critical signals shall maintain inner-layer connections only, with no exposed contacts on the outer layers. This ensures that unauthorized physical tampering (e.g., probing attempts or circuit modifications) requires destruction of the PCB structure to access target signals, thereby establishing a hardware foundation for physical tamper resistance.
需求描述：核心控制器 PCBA 需采用多层板设计，将加密芯片通信链路、数据总线（如 CAN FD/Ethernet）、核心信号处理电路（如排放数据相关电路）的关键信号布线于 PCB 内层（非顶层 / 底层）；关键信号的焊盘、过孔需仅保留内层连接，外层无裸露触点，确保非授权物理篡改（如探针接入、线路改接）需破坏 PCB 结构才能接触目标信号，形成防物理篡改的硬件基础。

Acceptance Criteria: ①Critical signal routing must exhibit no exposed traces on outer layers.

②Simulated unauthorized physical tampering (e.g., probing attempts to access critical signals) must necessitate damaging the PCB substrate to reach target circuits.
验收标准：①关键信号的布线，无外层裸露；②模拟非授权物理篡改（探针尝试接入关键信号），需破坏 PCB 基材才能接触目标线路。

REQ2:Critical Chips and Associated Circuits to Utilize Potting Encapsulation Process

1054754 v2 **REQ2:Critical Chips and Associated Circuits to Utilize Potting Encapsulation Process**

Version history:
(2):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

REQ2. Critical Chips and Associated Circuits to Utilize Potting Encapsulation Process
REQ2. 关键芯片及其关联电路，采用灌胶封装工艺

Requirement Description: Critical chips and their associated circuits in core electronic control products shall employ a potting encapsulation process for tamper resistance. The potting area must fully cover the key chips, their pins, and the copper foil regions of associated circuits. The potting material shall be a high-adhesion, high-hardness epoxy resin. This encapsulation design aims to provide tamper protection through three dimensions: increasing the difficulty of disassembly and tampering, ensuring circuit failure is irreversible, and leaving visible evidence of tampering.
需求描述：核心电控产品的关键芯片及其关联电路需采用灌胶封装工艺实施防篡改保护；灌胶范围需完整覆盖关键芯片本体、引脚及关联电路的铜箔区域，灌胶材料选用高附着力、高硬度环氧树脂胶；通过该封装设计，实现从拆解篡改难度、电路失效不可复原、篡改留痕三个维度的防篡改防护。

Acceptance Criteria: The potting encapsulation must effectively prevent or significantly increase the difficulty of tampering with the chips and associated circuits.
验收标准：灌胶封装可有效阻止芯片及关联电路的篡改或增加篡改难度。

REQ3:Critical Sensor Signal Interface Range Diagnostics

1054755 v2 **REQ3:Critical Sensor Signal Interface Range Diagnostics**

Version history:
(2):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

REQ3. Critical Sensor Signal Interface Range Diagnostics
REQ3. 关键传感器信号接口范围诊断

Requirement Description: Critical sensor signal interfaces shall implement range diagnostic logic to monitor the output signal values in real time. If a signal value exceeds the predefined operating range of the sensor, a fault flag shall be triggered and a Diagnostic Trouble Code (DTC) shall be reported.
需求描述：关键传感器信号部署接口范围诊断逻辑，对传感器输出的信号值进行实时监测。当信号值超出传感器预设工作范围时，触发故障标记并上报故障码（DTC）。

Acceptance Criteria:
①A fault flag is triggered when the signal exceeds the predefined range.
②A DTC is reported.
验收标准：
①超出范围触发故障标记；
②上报DTC

REQ4:Critical Sensor Signal Plausibility Diagnostics

1054756 v2 **REQ4:Critical Sensor Signal Plausibility Diagnostics**

Version history:
(2):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

REQ4. Critical Sensor Signal Plausibility Diagnostics
REQ4. 关键传感器信号可信性（合理性）诊断

Requirement Description: Critical sensor signals shall implement plausibility diagnostic logic to monitor the output signal values in real time. Based on system operating conditions (e.g., speed, output torque/power), if the signal value or its rate of change exceeds the predefined deviation from the theoretical value under current conditions, a fault flag shall be triggered and a Diagnostic Trouble Code (DTC) shall be reported. Note: Any form of plausibility diagnostics may be defined according to specific system characteristics.
需求描述：关键传感器信号部署可信性（合理性）诊断逻辑，对传感器输出的信号值进行实时监测。结合系统工况（比如转速，输出扭矩/功率），当信号值或者信号值变化与当前工况理论值超过预设偏差时，触发故障标记并上报故障码（DTC）。注：可以根据各自系统特性定义任何形式的合理性诊断。

Acceptance Criteria:
①A fault flag is triggered when the predefined deviation is exceeded.
②A DTC is reported.
验收标准：
①超出范围触发故障标记；
②上报DTC

REQ5:Critical Actuator Plausibility Diagnostics

1054757 v2 **REQ5:Critical Actuator Plausibility Diagnostics**

Version history:
(2):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

REQ5. Critical Actuator Plausibility Diagnostics
REQ5. 关键执行器可信性（合理性）诊断

Requirement Description: Critical actuators shall implement plausibility diagnostic logic, where system characteristic signals are selected to determine whether the actuator is functioning normally. If the characteristic signal value or its rate of change exceeds the predefined deviation from the theoretical value, a fault flag shall be triggered and a Diagnostic Trouble Code (DTC) shall be reported. Note: Any form of plausibility diagnostics may be defined according to specific system characteristics.
需求描述：关键执行器部署可信性（合理性）诊断逻辑，选取系统特征信号表征执行器是否正常工作，当特征信号值或者信号值变化与理论值超过预设偏差时，触发故障标记并上报故障码（DTC）。注：可以根据各自系统特性定义任何形式的合理性诊断。

Acceptance Criteria:
①A fault flag is triggered when the predefined deviation is exceeded.
②A DTC is reported.
验收标准：
①超出范围触发故障标记；
②上报DTC

4.1.2 01_Key Management

The purpose of Base Key Protection is to provide a base protection against disclosure and modifications of sensitive and confidential keys through diagnostic services or runtime external ECU interfaces.

To make it harder for an attacker from retrieving or modifying key material data, the software must be designed so that sensitive information is not accessible through ECU external interfaces.

The key material should only be accessible internally by the software during normal application operations.
Examples on key areas where keys need to be protected are:
• Secure Software Download
• Secure Communication
• Security Access

In all use case scenarios after end-of-line production, the software needs to be designed with no external interfaces that can modify the asymmetric public key that act as a root of trust to assure that the correct public key is used, while for secret keys, no external interfaces for both disclosure and modifications are allowed. If the public key is not used as a root of trust, it must always be verified against the root public key before it is used to verify a signature.

It is important to note that this does not protect against human errors in the application program interface that can be used by an adversary to exploit vulnerabilities such as buffer or stack overflows to leak or modify sensitive and confidential keys. To have a better protection against this, a dedicated Hardware Security Module should be used, if it's supported by the ECU platform. This provides an isolated secure execution environment for sensitive cryptographic operations and data.

General requirements for cryptographic modules(GB)

851730 v2 **General requirements for cryptographic modules(GB)**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

base key protection--
密码模块通用要求
1、密码模块应采用符合国际、国家或行业标准要求的；
2、若未采用国际、国家或行业标准要求的密码模块，应说明使用的合理性。
Note（参考但不限于的标准如下）：
1.可信密码模块：
GM/T 0012《可信计算可信密码模块接口规范》
GM/T 0028《密码模块安全技术要求》
2.硬件随机数发生器：
GM/T 0078《密码随机数生成模块设计指南》
GM/T 0103《随机数发生器总体框架》
GM/T 0028《密码模块安全技术要求》
3.软件随机数发生器：
GM/T 0103《随机数发生器总体框架》
GM/T 0105《软件随机数发生器设计指南》
GM/T 0028《密码模块安全技术要求》

General Requirements for Cryptographic Modules:

1、Cryptographic modules shall be based on standards that are in compliance with international, national, or industry
requirements.

2、Should a cryptographic module not be based on standards that meet international, national, or industry requirements,
the rationale for its use must be provided.

Note (References are not limited to the following standards):
Trusted Cryptography Modules:

GM/T 0012 "Trusted Computing Trusted Cryptography Module Interface Specification"
GM/T 0028 "Cryptographic Module Security Technical Requirements"
Hardware Random Number Generators:

GM/T 0078 "Design Guidelines for Cryptographic Random Number Generation Module"
GM/T 0103 "General Framework of Random Number Generator"
GM/T 0028 "Cryptographic Module Security Technical Requirements"
Software Random Number Generators:

GM/T 0103 "General Framework of Random Number Generator"

GM/T 0105 "Design Guidelines for Software Random Number Generator"
GM/T 0028 "Cryptographic Module Security Technical Requirements"

4.1.2.1 Key Protection

Key Reuse

987837 v1 **Key Reuse**

Version history:
(1):

Purpose:
Verification Method: Analysis
Legacy ID:

Symmetric and private asymmetric keys shall be unique and only be used in a single set of production components or a single production component (respectively).

Note: This implies that the keys are not to be re-used in e.g., multiple vehicles.
Note: Development units are exempt from this requirement unless otherwise specified.

Key Revocation

987839 v1 **Key Revocation**

Version history:
(1):

Purpose:
Verification Method: Analysis
Legacy ID:

The chosen Secure Environment shall have the capabilities to detect and revoke compromised keys.

If the ECU has the Security Audit Log concept allocated the detection and revokation of compromised keys shall be logged as specified in the Security Audit Log concept, see Security Audit Log Events. Otherwise, if the component has other concepts for logging allocated, such as but not limited to AUTOSAR Intrusion Detection System, then the detection and revokation shall be logged through this concept.

Synchronization with the OEM to determine the method of logging shall be performed.

Key Storage Location

524487 v4 **Key Storage Location**

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

Any encryption key, trust file or data of similar value shall be stored in the Secure Environment available to the component, **plaintext storage of keys is not allowed.**

The cryptographic keys utilized for the Application Layer Encryption concept shall be stored in and utilized from a Secure Environment.

In case asymmetric keys are utilized for the purposes of this concept, both the private and the public key shall be stored in and utilized from a Secure Environment as to protect them from e.g., tampering.

Additionally, in case a temporary session key is generated (many asymmetric cryptography algorithms generate a temporary symmetric "session" key, regarding "session" key, permanent session keys are not allowed to exist and must be updated regularly;

Note:
Secure Environment is a general term used to realize hardware security and is usually a dedicated hardware or a logically isolated secure environment, providing crypto functions and handling cryptographic keys along with sensitive security operations. Commonly implemented and referred as
· Trusted Execution Environment (TEE)
· Hardware Security Module (HSM)
· Secure Hardware Extension (SHE)
· Secure Element (SE)
· Trusted Platform Module (TPM)
or any other vendor specific secure environments.

Key Usage

987842 v1 **Key Usage**

Version history:
(1):

Purpose:
Verification Method: Analysis
Legacy ID:

Any cryptographic operations related to the confidential keys shall take place within a Secure Environment, isolated and protected from the normal applications outside of the Secure Environment.

During runtime, confidential keys shall only be exposed to secure memory belonging to the Secure Environment and shall thereby never leave the Secure Environment.

Note: The Secure Environment could be realized through the use of Trusted Execution Environment (TEE) or Hardware Security Module (HSM) and it is up to the OEM to specify the realization.

Protect Access to Key Material

524490 v6 **Protect Access to Key Material**

Version history:
(6):

Purpose:
Verification Method: Analysis
Legacy ID:

It shall not be possible to read out key material from the component and **not be allowed to print as a log for output**.

Examples of Key Material includes but is not limited to key material used for SecurityAccess or in immobilizer.

Security Key Installation

524491 v3 **Security Key Installation**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

Initial confidential key provisioning must only take place within a factory production environment with a controlled restricted access, through a trusted channel to avoid disclosure or modification of confidential and sensitive information.
Note:
Example on confidential keys are Security Access keys and TLS private keys.

4.1.2.2 Key Updating

Component Replacement

987847 v1 **Component Replacement**

Version history:
(1):

Purpose:
Verification Method: Test
Legacy ID:

In the event the OEM has decided to replace keys, but the component does not support key replacement, the involved component(s) shall be replaced with a new component(s) which use a new key(s).

Key Replacement

987848 v1 **Key Replacement**

Version history:
(1):

Purpose:
Verification Method: Test
Legacy ID:

In case of leakage of cryptographic keys the keys shall be replaced. Depending on how it/they is/are stored the following applies:
Secure Environment:
Any key replacement in the secure environment must be coordinated and agreed with the OEM.
In case there is no support for key revocation, a new key / new keys shall instead be used when producing new

components.
Others:
The secret key shall be revoked and replacement keys shall be rolled-out with regular SW updates.

4.1.2.3 Number of Key Slots Supported

Minimum Key Slots Supported

987850 v1 **Minimum Key Slots Supported**

Version history:
(1):

Purpose:
Verification Method: Analysis
Legacy ID:

The component shall be able to, at minimum, store all relevant keys and key related material (e.g., certificates) needed for the functionality of the component in the Secure Environment Storage.

The component shall, unless the expected need is zero (0), allow for storage of at least two more entities of each cryptographic material type than what is currently needed. This is to allow for future functionality growth.

For an estimation of how many keys are needed for each concepts see the table below:

Concept	Asymmetric - Private	Asymmetric - Public	Symmetric	Certificates
UDS - Service #29 - Uni-directional				2 ECC Root/Intermediate Certificates****
UDS - Service #29 - Bi-directional	1 ECC-P256			1 ECC Public Key Certificate (Server) 2+ ECC Root/Intermediate Certificates*****
Security Audit Log			1 AES-128	
SecOC			x AES-128***	
SecOC (SHE based)			1+x AES-128** (MASTER_KEY + x SLOT_KEY)	
Secure Boot		1 RSA*	1 AES*	

MACsec			2 AES-128	
Device Identity Key (ZEEA3 - Variant)	1 ECC-P256	1 ECC-P256		
Digital Key			1 AES-128	
Digital Key (SHE based)			2 AES-128 (MASTER_KEY + SLOT_x)	
TLS	1 ECC-P256	1 ECC-P256		1 ECC Public Key Certificate 2 ECC Root/Intermediate Certificates****
UWB/BLE	1 ECC-P256	1 ECC-P256		

Table - Concept to Cryptographic Material Mapping

* Key length and key type (AES/RSA) is variable, depending on component
** The number of SLOT_KEY keys needed depends on the SecOC cluster allocation to the ECU and may differ from 1-10
*** The number of SecOC AES-128 keys depends on the number of SecOC clusters allocated to the ECU and may differ from 1-10
**** OEM root/intermediate certificates can be reused
***** Multiple OEM root/intermediate certificates are used, one pair can be re-used but the other is unique for this concept
Notes:

- The estimation is provided only for guidance, the supplier shall calculate how many keys need to be supported based on all requirements allocated to the component (not exclusive to cybersecurity).
- This requirement is allocated in both the Cybersecurity DPR and the Cybersecurity SWRS

4.1.3 02_Password Management

Password Storage

525151 v3 **Password Storage**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

If the hardware and OS supports it, Passwords shall be stored in the secure environment, e.g. in an HSM or a TEE.

If the hardware and OS does not support storing passwords in a secure environment (or due to cost considerations), then **passwords (include but not limited PIN CODE and Secure Constant etc.)** should not be stored in plain text in an insecure environment either.

Specifically, parameterized and deterministic cryptographic hashing mechanism(e.g. Salted Password Hashing) shall be used and only the result of this computation has to be stored on the system.

Notes:

- The login password of the Linux system is hashed and saved in the /etc/shadow file of the system. When a user creates an account or changes a password, the system will automatically generate a random “salt”, and then process this salt and the user’s plaintext password through a specific hash function to form a hash value. Finally, it only saves this hash value and salt, but does not save the user’s original password.
- Newer versions of Android store the screen lock password and PIN code in TEE (Trusted Execution Environment), while older versions (like Android 5.0) save the password in /data/system/password.key (Salted Password Hash value).

Password Brute-Forcing

986836 v3 Password Brute-Forcing

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

Mechanisms to prevent brute-force password guessing shall be implemented. This prevention mechanism shall not be possible to reset except by a full re-flash of the software.

If there is a conflict with BT SWRS, Implement according to BT requirements;

Example: After 5 failed login attempts in a row the logging in mechanism is locked for 5 minutes. If the user continues to fail logins within another 5 minutes of the mechanisim being unlocked, the mechanism shall be locked again for an exponentially increasing duration.

Password Conformity

986837 v2 Password Conformity

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

Passwords shall be at least twelve (12) characters in length. Highly sensitive passwords shall have a minimum length of twenty (20) characters.

A password should include both lower-case and capital letters as well as one digit and special characters such as ! "" # $ % & ‘ ( ) * + , - . / : ; < = > ? @ [\ ] ^ { | } ~

All default passwords for services, users or software shall immediately be changed.

Notes:

- For OCDS passwords, their lengths are typically set by the specific device or chip manufacturer. For instance, the JTAG password length for a certain chip is fixed at 128 bits (16 Bytes). In such cases, the password length should correspond to the maximum length supported by the device or chip.
- OCDS passwords are usually preset in devices or chips in hexadecimal format, and the corresponding password entry interface also typically accepts hexadecimal inputs, with passwords similar to 0x0123456789ABCDEF0123456789ABCDEF. This situation is not subject to this requirement, but the password still needs a certain level of complexity. The specific password generation scheme needs to be provided by the supplier and approved by the OEM.
- For Android's PIN or pattern locks, these types of passwords are fixed by the Android OS, and this situation is not subject to this requirement.

Uniqueness of Password

986839 v2 **Uniqueness of Password**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Must use unique passwords for each ECU.
Must use unique passwords for each service, application, OS.

4.1.4 03_Secure Crypto

4.1.4.1 Cryptographic HW Acceleration: AES

4.1.4.1.1 Application Layer Encryption - In Transit

Terminology:

Term	Description
ECC	Elliptic-curve cryptography (ECC) is an approach to asymmetric key cryptography based on the algebraic structure of elliptic curves over finite fields.
RSA	RSA (Rivest–Shamir–Adleman) is an asymmetric key cryptosystem that is widely used for secure data transmission.
AES	Advanced Encryption Standard is a specification for the encryption of electronic data. The algorithm described by AES is a symmetric-key algorithm.
MAC	A message authentication code (MAC), sometimes known as a tag, is a short piece of information used for authenticating a message. In other words, to confirm that the message came from the stated sender (its authenticity) and has not been changed.
Symmetric	A security scheme in which only a single shared secret key is utilized between the parties.

Asymmetric	A security scheme in which each party has their own matching private (secret) key and a public key pair, which are generated together. The public key allows a second party to validate any signature made by the owner of the private key. Additionally, the public key can be used to encrypt data, which can then only be decrypted by the matching private key.
Sender	The sender of some data, usually this party encrypts the data using either the recipients public key or their shared secret key.
Receiver / Recipient	The receiver or recipient of some data sent by the sender, which is then to be decrypted using the secret keys.
KDF	A key derivation function (KDF) is a cryptographic algorithm that derives one or more secret keys from a secret value such as a main key, a password, or a passphrase using a pseudorandom function (which typically uses a cryptographic hash function or block cipher).

Cryptographic Algorithm: AES

973516 v3 **Cryptographic Algorithm: AES**

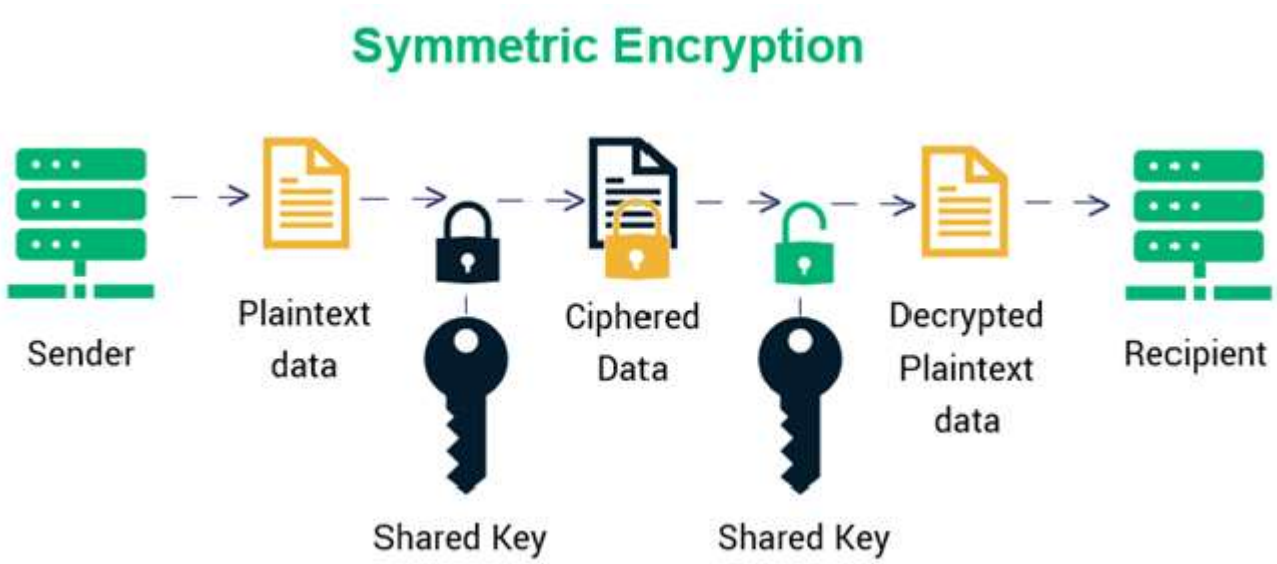
Version history:
(3):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

This requirement is only applicable if ECU without HSM hardware security module, functions are implemented through software algorithms

The method for encrypting and decrypting the data as per the Application Layer Encryption concept shall be as follows, depending on the type of keys utilized:

AES:



The sender shall encrypt the data with the symmetric shared secret key, using the AES algorithm as specified in FIPS 197 (NIST).

Only once encrypted can the data be transmitted to the recipient, over any medium (CAN, Ethernet, LIN etc).

Using equivalent AES decryption algorithm, and the very same shared secret key, the recipient shall decrypt the message.

Cryptographic Algorithm: ECC

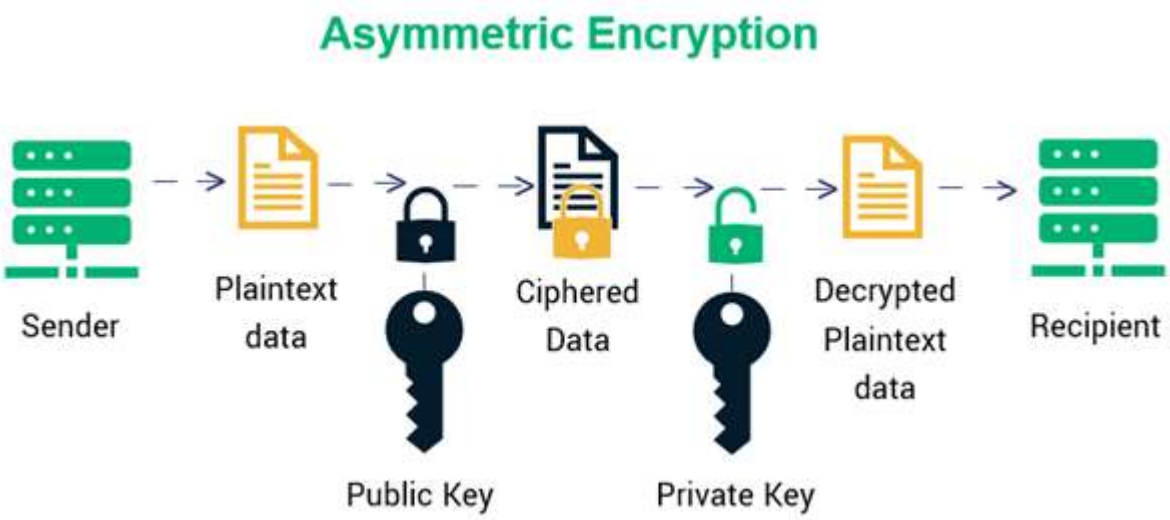
973517 v3 **Cryptographic Algorithm: ECC**

Version history:
(3):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

This requirement is only applicable if ECU without HSM hardware security module, functions are implemented through software algorithms

The method for encrypting and decrypting the data as per the Application Layer Encryption concept shall be as follows, depending on the type of keys utilized:



ECC:

The data shall be encrypted using the ECIES algorithm. See below for information:

Required information [edit]

To send an encrypted message to Bob using ECIES, Alice needs the following information:

- The cryptography suite to be used, including a key derivation function (e.g., *ANSI-X9.63-KDF with SHA-1 option*), a message authentication code (e.g., *HMAC-SHA-1-160 with 160-bit keys* or *HMAC-SHA-1-80 with 80-bit keys*) and a symmetric encryption scheme (e.g., *TDEA in CBC mode* or *XOR encryption scheme*) — noted E.
- The elliptic curve domain parameters: (p, a, b, G, n, h) for a curve over a prime field or $(m, f(x), a, b, G, n, h)$ for a curve over a binary field.
- Bob's public key K_B, which Bob generates it as follows: $K_B = k_B G$, where $k_B \in [1, n-1]$ is the private key he chooses at random.
- Some optional shared information: S_1 and S_2
- O which denotes the point at infinity.

The KDF shall be: Counter Mode as defined in NIST SP 800-108.

The MAC shall be: CMAC-AES

The Symmetric Encryption Scheme shall be: AES

The key length of the derived session key shall be at least 128 bits, but preferably 256 bits.

Encryption [edit]

To encrypt a message m Alice does the following:

1. generates a random number $r \in [1, n-1]$ and calculates $R = rG$
2. derives a shared secret: $S = P_x$, where $P = (P_x, P_y) = rK_B$ (and $P \neq O$)
3. uses a KDF to derive symmetric encryption keys and MAC keys: $k_E \| k_M = \mathrm{KDF}(S \| S_1)$
4. encrypts the message: $c = E(k_E; m)$
5. computes the tag of encrypted message and S_2: $d = \mathrm{MAC}(k_M; c \| S_2)$
6. outputs $R \| c \| d$

Only once encrypted can the data be transmitted to the recipient, over any medium (CAN, Ethernet, LIN etc).

Using the same ECIES algorithm, the recipient shall decrypt the message using their own ECC private key. See below:

Decryption [edit]

To decrypt the ciphertext $R \| c \| d$ Bob does the following:

1. derives the shared secret: $S = P_x$, where $P = (P_x, P_y) = k_B R$ (it is the same as the one Alice derived because $P = k_B R = k_B rG = rk_B G = rK_B$), or outputs *failed* if $P = O$
2. derives keys the same way as Alice did: $k_E \| k_M = \mathrm{KDF}(S \| S_1)$
3. uses MAC to check the tag and outputs *failed* if $d \neq \mathrm{MAC}(k_M; c \| S_2)$
4. uses symmetric encryption scheme to decrypt the message $m = E^{-1}(k_E; c)$

Note: This mandates that the component supports proper random number generation. See 21. Random Number Generation for reference.

Note: This involves generating/deriving a temporary symmetric (session) key, for faster encryption.

Cryptographic Keys

973518 v2 **Cryptographic Keys**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The data shall be encrypted using a predefined set of cryptographic encryption keys.

Such keys may be:
- Asymmetric keys defined by the Device Identification Key concept (see Cryptographic Key Algorithm, REQ ID: 653435)
- Symmetric keys already used in the Secure On-Board Communication concepts
- otherwise defined symmetric or asymmetric keys

In case an asymmetric key solution is selected:
- The public key of the parties (components, ECU etc) participating in the concept shall be shared with the other party. The sharing of such keys is not described by this concept, and must instead be defined elsewhere in the Application SWRS by the components utilizing the concept.
- The keys of both parties shall be of the same type (e.g., RSA, ECC etc)
- The keys of both parties shall be of the same length (e.g., 2048 bits, 4096 bits, 128 bits, 256 bits).

The OEM shall determine which keys are to be utilized for the encryption.

Cryptographic Algorithm: RSA

973523 v3 **Cryptographic Algorithm: RSA**

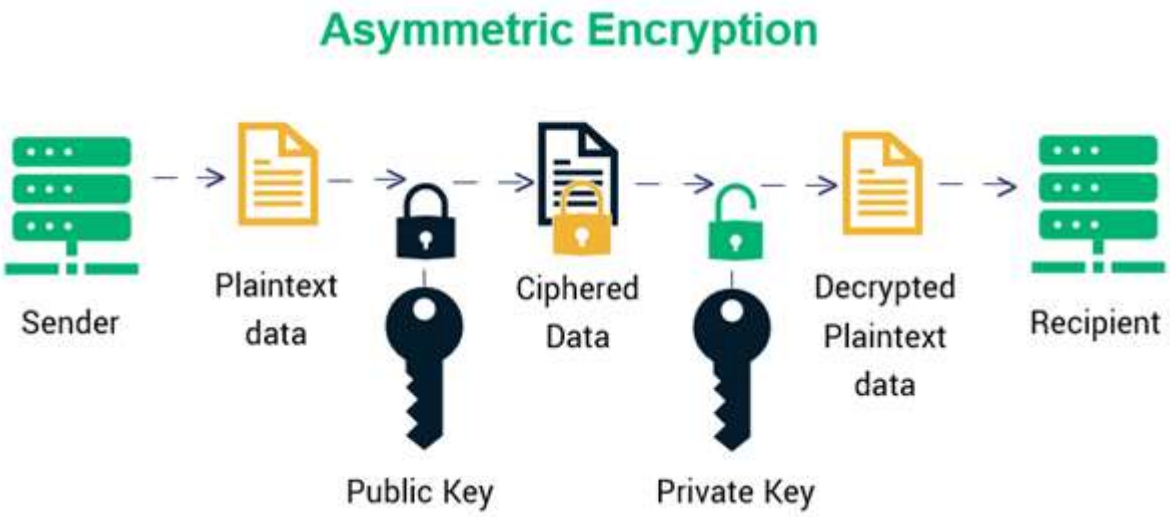
Version history:
(3):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

This requirement is only applicable if ECU without HSM hardware security module, functions are implemented through software algorithms

The method for encrypting and decrypting the data as per the Application Layer Encryption concept shall be as follows, depending on the type of keys utilized:

RSA:



The data shall be encrypted by the sender using the RSA algorithm, which requires the sender to utilize the public key of the recipient. See below for information (note, Bob is the sender and Alice is the recipient):

Encryption [edit]

After Bob obtains Alice's public key, he can send a message M to Alice.

To do it, he first turns M (strictly speaking, the un-padded plaintext) into an integer m (strictly speaking, the padded plaintext), such that $0 \leq m < n$ by using an agreed-upon reversible protocol known as a padding scheme. He then computes the ciphertext c, using Alice's public key e, corresponding to

$$c \equiv m^e \pmod{n}.$$

This can be done reasonably quickly, even for very large numbers, using modular exponentiation. Bob then transmits c to Alice. Note that at least nine values of m will yield a ciphertext c equal to m,[22] but this is very unlikely to occur in practice.

The Padding Scheme shall be: Optimal Asymmetric Encryption Padding as specified in PKCS#1 v2 and RFC 2437.

Only once encrypted can the data be transmitted to the recipient, over any medium (CAN, Ethernet, LIN etc).

Using the same RSA algorithm, and the recipients own private key, the recipient shall decrypt the message. See below:

Decryption [edit]

Alice can recover m from c by using her private key exponent d by computing

$$c^d \equiv (m^e)^d \equiv m \pmod{n}.$$

Given m, she can recover the original message M by reversing the padding scheme.

4.1.4.1.2 Secure Crypto

Cryptographic HW Engine: AES

973512 v3 **Cryptographic HW Engine: AES**

Version history:
(3):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

Cryptographic Hardware Engine for AES shall be supported.

Cryptographic HW Engine: ECC

973513 v3 **Cryptographic HW Engine: ECC**

Version history:

(3):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

Cryptographic Hardware Engine for ECC (Elliptic Curve Cryptography) shall be supported. This includes at minimum both key generation, ECIES and ECDSA.

Cryptographic HW Engine: SHA

973514 v3 **Cryptographic HW Engine: SHA**

Version history:
(3):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

Cryptographic Hardware Engine for SHA1/2/3 shall be supported.

Minimum Cryptographic Support

973515 v2 **Minimum Cryptographic Support**

Version history:
(2):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

The minimum required cryptographic support shall be SHA-256 / RSA-2048 for asymmetric keys and AES-128 for symmetric keys. Cipher-based Message Authentication Code (CMAC), according to the appropriate and most recent revision of the National Institute of Standards and Technology (NIST) special publication 800-38B.

Note: If individual security mechanisms (concepts) allocated to the ECU require cryptographic support for other algorithms or longer keys, the requirements in those security mechanisms (concepts) supersede this requirement.

Cryptographic HW Engine: RSA

988159 v3 **Cryptographic HW Engine: RSA**

Version history:
(3):

Purpose:
Verification Method: Analysis AND Test
Legacy ID:

Cryptographic Hardware Engine for RSA shall be supported.

4.1.5 07_CAN Firewall

Traffic Inspection

973543 v1 **Traffic Inspection**

Version history:
(1):

Purpose:
Verification Method: Test
Legacy ID:

A firewall with stateful inspection shall be used to control external interface(s) to the ECU. The vehicle networks shall be protected from external networks using diagnostics through the use of firewalls.

The firewall should be configured to:
- Deny all traffic by default
- Accept only expected traffic, at the expected rates (at most), according to a predefined specification from the OEM including both payload and ID expectations.

Configuration Integrity

973538 v1 **Configuration Integrity**

Version history:
(1):

Purpose:
Verification Method: Test
Legacy ID:

The firewall configuration shall be protected from unauthorized altering.

Configuration Updates

973539 v1 **Configuration Updates**

Version history:
(1):

Purpose:
Verification Method: Test
Legacy ID:

It shall be possible to securely update the firewall configuration (rule set etc.) remotely from within a trusted private cloud ONLY.

4.1.6 09_SecOC

This specification specifies the requirements for the implementation of Secure Onboard Communication (SecOC).

Abbreviations:

DID	Data Identifier
DTC	Diagnostic Trouble Code
E2E	End-to-End
FTB	Failure Type Byte
FV	Freshness Value
FVM	Freshness Value Management
MAC	Message Authentication Code
NRC	Negative Response Code
PDU	Protocol Data Unit
RID	Routine Identifier
SID	UDS Service Identifier
SDB	Signal Database

AUTOSAR SecOC Support

987070 v2 AUTOSAR SecOC Support

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The ECU shall support the AUTOSAR Secure Onboard Communication (SecOC) concept. The version of AUTOSAR SecOC in the ECU shall be compliant with version 4.3.1 of the AUTOSAR Specification of Secure Onboard Communication (document ID 654).

In case another AUTOSAR SecOC version is used, the supplier shall discuss with the OEM to avoid any incompatibility issues.

SecOC Implementation and SDB Handling

987071 v2 SecOC Implementation and SDB Handling

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

After requirement alignment with the supplier, should the ECU receive an SDB (ECU Extract, DBC file etc) which contains PDUs protected with SecOC (Secured I-PDUs) intended for a release prior to when the supplier is actually able to implement SecOC support in the ECU, then the ECU shall still be capable of handling such an SDB in the manner specified below:

Sent PDUs (Tx):The Authentic I-PDU shall be sent, but the FV + MAC (Authentication Info) data can be arbitrary / empty data. The bit position of the Authentic I-PDU shall not be changed.

Received PDUs (Rx): Ignore the FV+MAC (Authentication Info) data, just accept the Authentic I-PDU without inspecting the FV + MAC.

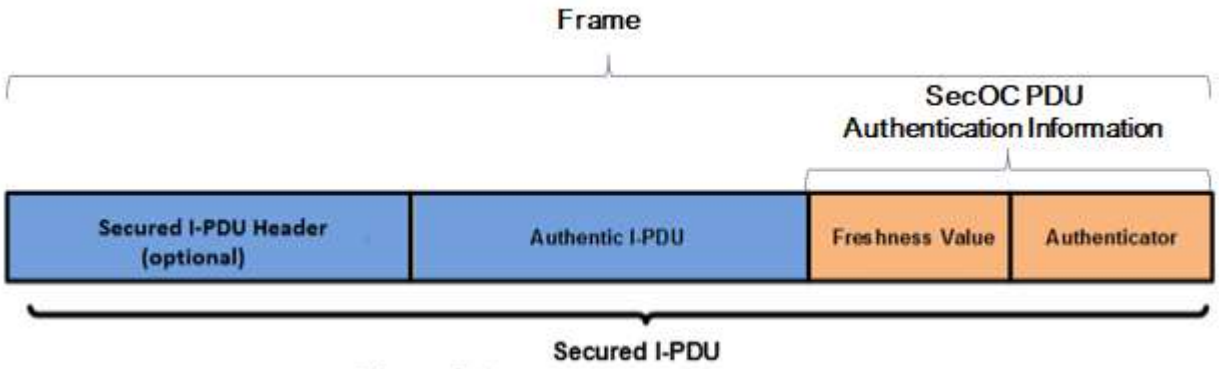


Figure 5.1: Secured I-PDU contents

Note: Secured I-PDU Header will most likely not be used (0 byte length), see the SDB content for confirmation.

If this situation occurs, the OEM representative should be informed by the supplier of how the supplier will resolve the issue.

Recommendations from OEM:

Depending on BSW supplier there are different ways of approaching this. The three main approaches for the supplier include:

- Re-routing the Authentic I-PDU in the PduR such that it does not get routed to the SecOC module
- Create a stub implementation of SecOC which just accepts all Rx (e.g., via SecOcIgnoreVerificationResult = true), and creates arbitrary data for the Authentication Information for Tx frames.
- Manipulate the SDB data such that the Authentication Information (FV+MAC) is either not referenced at all or is viewed by the SW as an I-PDU.

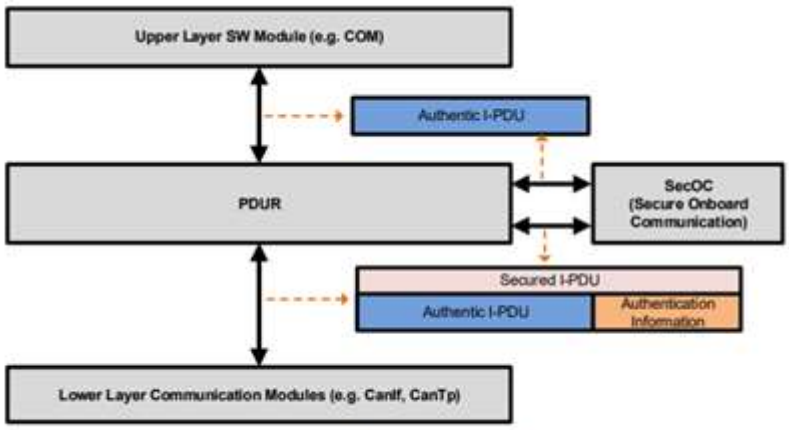


Figure 7:Transformation of an Authentic I-PDU in a Secured I-PDU by SecOC

4.1.6.1 SecOC Cluster

A SecOC cluster is a virtual group of ECUs, typically sender ECU(s) transmitting authentic message(s) and receiver ECU(s) verifying the authentic message(s), grouped together to enable data exchange between all ECUs in the SecOC Cluster securely.

All ECUs part of a SecOC cluster shall maintain consistent configurations per message required for secure communication such as authentication method, freshness management, key etc. in order to enable ECUs in the cluster to successfully authenticate and verify secure messages.

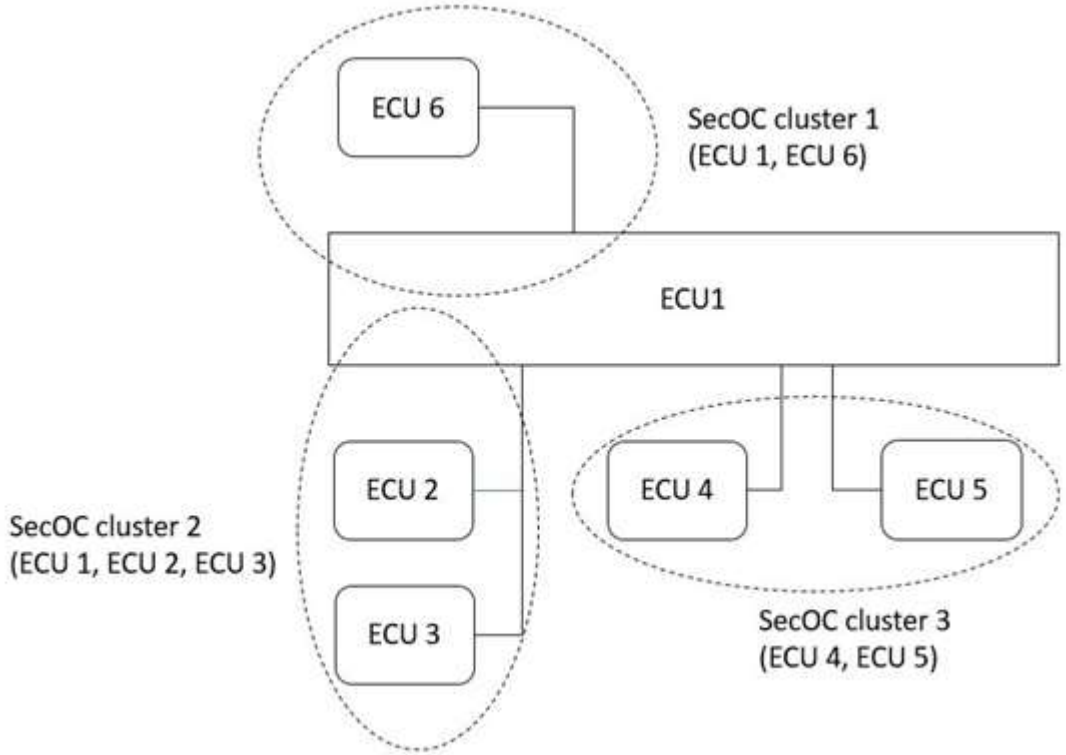


Figure: Example of SecOC clusters.

Cluster Key Sync Test

987072 v2 **Cluster Key Sync Test**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

Successful secure communication is only possible if the same key is provisioned in all ECUs of a SecOC cluster. To ensure that the same key is stored in all the ECUs of a SecOC cluster, diagnostics clients can perform key sync test for each SecOC cluster.

The ECU shall support control routine identifier 0xB050. The control routine shall be supported in extendedDiagnosticSession and Authentication service 0x29 shall be used as authentication using the diagnostics role "Workshop elevated" to be able to perform SecOC key sync test operation. If the ECU does not support Authentication service 0x29, SecurityAccess service 0x27 with level 0x19 shall be used instead.

Message Direction	Client → Server	
Message Type	Request	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	RoutineControl Request SID	31_{16}

Message Direction	Client → Server	
Message Type	Request	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#2	SubFunction = startRoutine	01_{16}
#3	routineIdentifier – SecOC Key Sync Test Byte#1 (MSB)	$B0_{16}$
#4	routineIdentifier – SecOC Key Sync Test Byte#2 (LSB)	50_{16}
#5	routineControlOption –SecOCClusterKeyID	$00\text{-}FF_{16}$

Table: RID startRoutine request for SecOC Key Sync Test.

Upon RID request, the ECU shall check if the requested SecOCClusterKeyID is supported by the ECU. For a valid SecOCClusterKeyID, the ECU shall respond back with the requested SecOCClusterKeyID concatenated with a 16 byte MAC value computed using AES-CMAC-128 algorithm on a preconfigured 16 byte static constant value "0xFFFF 5A5A 5A5A 5A5A 5A5A 5A5A 5A5A FFFF" as input with the corresponding key of the SecOCClusterKeyID requested in the routineControlOption.

Message Direction	Server → Client	
Message Type	Response	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	RoutineControl Response SID	71_{16}
#2	routineControlType = startRoutine	01_{16}
#3	routineIdentifier – SecOC Key Sync Test Byte#1 (MSB)	$B0_{16}$
#4	routineIdentifier – SecOC Key Sync Test Byte#2 (LSB)	50_{16}
#5	routineInfo	Routine Type (4 bits) || Routine Status (4 bits)

Table: RID startRoutine response for SecOC Key Sync Test from the ECU.

Message Direction	Client → Server	
Message Type	Request	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	RoutineControl Request SID	31_{16}
#2	SubFunction = requestRoutineResult	03_{16}
#3	routineIdentifier – SecOC Key Sync Test Byte#1 (MSB)	$B0_{16}$
#4	routineIdentifier – SecOC Key Sync Test Byte#2 (LSB)	50_{16}

Table: RID requestRoutineResult request for SecOC Key Sync Test.

Message Direction	Server → Client	
Message Type	Response	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	RoutineControl Response SID	71_{16}
#2	routineControlType = requestRoutineResult	03_{16}
#3	routineIdentifier – SecOC Key Sync Test Byte#1 (MSB)	$B0_{16}$
#4	routineIdentifier – SecOC Key Sync Test Byte#2 (LSB)	50_{16}
#5	routineInfo	Routine Type (4 bits) || Routine Status (4 bits)
#6	Routine Error Information	00-FF_{16}
#7	routineStatus – SecOCClusterKeyID	00-FF_{16}
#8	routineStatus – MAC Byte#1 (MSB)	00-FF_{16}
#9	routineStatus – MAC Byte#2	00-FF_{16}
...	...	...
#23	routineStatus – MAC Byte#16 (LSB)	00-FF_{16}

Table: RID requestRoutineResult response for SecOC Key Sync Test from the ECU.

The diagnostic client shall verify that the same key is stored in all ECUs of the SecOC cluster if the MAC value from all ECUs belonging to the same SecOC cluster is the same.

There shall be different negative response codes to separate errors:

1. Length or format check failed (NRC 0x13: incorrectMessageLengthOrInvalidFormat).
2. The client is not authenticated with Authentication service 0x29 using the diagnostics role "Workshop elevated" before requesting the RID (NRC 0x34: authenticationRequired).
3. The ECU is not unlocked with SecurityAccess service 0x27 before requesting the RID (NRC 0x33: securityAccessDenied).
4. None of the supported SecOC cluster key identifier value(s) stored in the ECU match the SecOC cluster key identifier value in the RID request (NRC 0x31: requestOutOfRange).
5. Error in computing MAC in the ECU (NRC 0x72: generalProgrammingFailure).

SecOC Cluster Key Identifier

987073 v2 **SecOC Cluster Key Identifier**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

All ECUs in a SecOC cluster shall use the same key to generate or verify authentic message(s) between them. The key for each SecOC cluster shall be identified by a unique identifier (SecOCClusterKeyID), represented in one byte

length hexadecimal value. The ECU shall use the SecOC cluster key identifiers to differentiate different keys for identifying the respective SecOC cluster if the ECU supports multiple SecOC clusters.

The ECU shall preconfigure and store the SecOC cluster key identifier(s) supported in the ECU. The SecOC cluster key identifier(s) to be configured and stored for each ECU shall be defined by the OEM.

SecOCClusterKeyID Configuration

987074 v2 **SecOCClusterKeyID Configuration**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

It shall be possible to configure which SecOC Cluster Key Identifier shall be used for each PDU by configuring the parameter SecOCClusterKeyID.

Note:
SecOCClusterKeyID here is the OEM configuration to uniquely identify the key for each SecOC cluster.

4.1.6.2 SecOC Configuration

Configurations in ECU Extract

987075 v2 **Configurations in ECU Extract**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

If SecOC configurations defined by the OEM is carried in the ECU Extract from the OEM, the supplier shall implement SecOC according to both the requirements and the ECU Extract from the OEM.

Crypto Algorithm

987076 v2 **Crypto Algorithm**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The cryptographic algorithm used for SecOC shall be CMAC mode based on AES-128 according to NIST SP 800-38B, i.e., AES-CMAC-128.

Default Configurations

987077 v4 **Default Configurations**

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

The list of SecOC configuration parameters as defined by the OEM are provided below.

The default value (if defined in the list below) shall be used if it is not overridden by the OEM SecOC configuration in the ECU extract.

CAN_FD/Flexray : Profile A

SecOC Parameters	Default Value
SecOCAuthInfoTxLength	88 bits
SecOCFreshnessValueLength	56 bits
SecOCFreshnessValueTxLength	16 bits
TripCntLength	24 bits
ResetCntLength	16 bits
MsgCntLength	14 bits
MsgCntUpper	0 bits
MsgCntLower	14 bits
ResetFlagLength	2 bits
ResetCycle	20s
ClearAcceptanceWindow	3
SecOCUseAuthDataFreshness	false
SecOCSecuredRxPduOffset	0
SecOCSecuredRxPduVerification	true
SecOCVerificationStatusPropagationMode	BOTH
SecOCAuthenticationVerifyAttempts	3
SecOCIgnoreVerificationResult	false
SecOCEnableForcedPassOverride	false
SecOCSecuredTxPduOffset	0
SecOCAuthenticationBuildAttempts	3
SecOCClusterKeyID*	-

CAN : Profile B

SecOC Parameters	Default Value
SecOCAuthInfoTxLength	24 bits
SecOCFreshnessValueLength	56 bits
SecOCFreshnessValueTxLength	8 bits
TripCntLength	24 bits
ResetCntLength	16 bits
MsgCntLength	14 bits
MsgCntUpper	8 bits
MsgCntLower	6 bits
ResetFlagLength	2 bits
ResetCycle	20s
ClearAcceptanceWindow	3
SecOCUseAuthDataFreshness	false

SecOCSecuredRxPduOffset	0
SecOCSecuredRxPduVerification	true
SecOCVerificationStatusPropagationMode	BOTH
SecOCAuthenticationVerifyAttempts	3
SecOCIgnoreVerificationResult	false
SecOCEnableForcedPassOverride	false
SecOCSecuredTxPduOffset	0
SecOCAuthenticationBuildAttempts	3
SecOCClusterKeyID*	-

Note:
* SecOCClusterKeyID: The OEM-defined SecOC Cluster key identifier associated for the PDU.

Immediate Return of Authentic Data

987081 v2 **Immediate Return of Authentic Data**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The supplier shall be prepared to implement this requirement if there is a need due to various performance related reasons.

It shall be possible to configure SecOC to immediately pass the authentic data to the receiving application without waiting for the verification completion. The MAC verification may be delayed but shall not be skipped. The receiving application shall be able to subscribe to a status notification when the SecOC verification is done.

An OEM specific configuration shall be introduced to enable such implementation.

Optimization for CPU Load

987082 v2 **Optimization for CPU Load**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The supplier shall be prepared to implement this requirement if there is a need due to various performance related reasons.

Pushing the CPU to a very high load could make the system become very unstable and unreliable. If an ECU has already very high CPU load, adding SecOC MAC computation may not be acceptable during the high load period. This is especially true in case there is no HSM support to offload the ECU for the MAC computation. In such case, optimization shall be done to balance the CPU load to stay at a reasonable level. Optimization could be to optimize the execution flow, offload the CPU when possible, improve scheduling for the SecOC MAC verification, etc.

An OEM specific configuration shall be introduced to enable such optimization.

Optimization for Latency

987083 v2 Optimization for Latency

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The supplier shall be prepared to implement this requirement if there is a need due to various performance related reasons.

SecOC introduces extra E2E latency to the messages due to the extra time for MAC computation, freshness management, extra payload data transmission, etc. In case the SecOC messages are very time critical and require low latency, optimization shall be done to reduce the possible latency introduced by SecOC processing. Optimization could be to optimize the execution flow, improve the cryptographic performance, improve the scheduling for the SecOC MAC verification, etc.

An OEM specific configuration shall be introduced to enable such optimization.

Profiles and Configuration Overview

987084 v5 Profiles and Configuration Overview

Version history:
(5):

Purpose:
Verification Method: Analysis
Legacy ID:

The SecOC implementation shall support the configuration profiles defined below by the OEM. A SecOC profile configuration includes parameters for MAC truncation and FV.

SecOC Profile	Truncated MAC length - SecOCAuthInfoTxLength	FV length - SecOCFreshnessValueLength	FV TX length - SecOCFreshnessValueTxLength	Payload Size Used for SecOC Data	Applicable Bus Types
Profile A	88	56	16	104	FlexRay/CAN-FD Default
Profile B	24	56	8	32	CAN Default

Table: Predefined OEM SecOC profiles.

Signals Protected by SecOC

987085 v2 Signals Protected by SecOC

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The OEM shall identify which signals to be protected by SecOC. All configurations regarding which signals to be protected shall be part of the ECU Extract provided by the OEM.

4.1.6.3 SecOC Freshness Value Management

FVM Solution

987086 v2 **FVM Solution**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

FV based on multiple freshness counters using the single FV management master method shall be used for SecOC as specified in section 11.4 in AUTOSAR Specification of Secure Onboard Communication version 4.3.1 or newer.

The masters and slaves shall be identified by the OEM, as part of the Application Requirement Specification. Additionally, the sync messages which the FV management masters have to send shall be defined and distributed as part of the ECU Extract.

RID for FV Reset

987087 v2 **RID for FV Reset**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall support control routine identifier 0xB051. The control routine shall be supported in extendedDiagnosticSession and shall be protected by Authentication service 0x29 using the diagnostics role "Workshop elevated". If the ECU does not support Authentication service 0x29, the DID shall be protected by SecurityAccess service 0x27 with level 0x19 instead.

Message Direction	Client → Server	
Message Type	Request	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	RoutineControl Request SID	31_{16}
#2	SubFunction = startRoutine	01_{16}
#3	routineIdentifier – SecOC FV Counter Reset Byte#1 (MSB)	$B0_{16}$

Message Direction	Client → Server	
Message Type	Request	
Data Byte	Description (all values are in hexadecimal)	Byte Value
#4	routineIdentifier – SecOC FV Counter Reset Byte#2 (LSB)	51_{16}
#5	routineControlOption – SecOCClusterKeyID	$00\text{-}FF_{16}$

Table: RID request for SecOC FV Counter Reset.

Upon RID request, the ECU shall check if the requested SecOCClusterKeyID is supported by the ECU. For a valid SecOCClusterKeyID, the ECU shall reset the FV counter of all PDUs associated with the corresponding key of the SecOCClusterKeyID.

Message Direction	Server → Client	
Message Type	Response	
Data Byte	Description (all values are in hexadecimal)	Byte Value
#1	RoutineControl Response SID	71_{16}
#2	routineControlType = startRoutine	01_{16}
#3	routineIdentifier – SecOC FV Counter Reset Byte#1 (MSB)	$B0_{16}$
#4	routineIdentifier – SecOC FV Counter Reset Byte#2 (LSB)	51_{16}
#5	routineInfo	Routine Type (4 bits) || Routine Status (4 bits)
#6	routineStatus – Successful FV Counter Reset	00_{16} – No 01_{16} – Yes

Table: RID response for SecOC FV Counter Reset from the ECU.

There shall be different negative response codes to separate errors:

1. Length or format check failed (NRC 0x13: incorrectMessageLengthOrInvalidFormat).
2. The client is not authenticated with Authentication service 0x29 using the diagnostics role "Workshop elevated" before requesting the RID (NRC 0x34: authenticationRequired).
3. ECU is not unlocked with SecurityAccess service 0x27 before requesting the RID (NRC 0x33: securityAccessDenied).
4. None of the supported SecOCClusterKeyID stored in the ECU match the SecOCClusterKeyID in the RID request (NRC 0x31: requestOutOfRange).

Note: Before restarting, the FV Counter reset does not take effect.

4.1.6.4 SecOC Key Management

Default Development Key

987088 v2 **Default Development Key**

Version history:
(2):

Purpose:

Verification Method: Test
Legacy ID:

When programming the default development key in the ECU for the first time, the initial key provisioned by the supplier shall have all bytes set to 0xFF as the old plaintext SecOC key in the DID request to write the new default development key.

Encryption Method for Key Format

987089 v2 **Encryption Method for Key Format**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The encryption algorithm for the key format shall be the Galois/Counter Mode of Operation with AES-128 symmetric block cipher (GCM-AES-128) according to NIST SP 800-38D. The GCM-AES-128 shall be used to encrypt/decrypt the SecOC key data record.

The Initialization Vector (IV) is 12 byte random number.

Example (testcase):
Device Key:
0x41, 0xac, 0x05, 0x6c, 0x4c, 0x9b, 0x4b, 0x90, 0x4a, 0x29, 0xf6, 0xd0, 0x19, 0x1d, 0x84, 0xf7
IV:
0xb9, 0x1c, 0x92, 0x66, 0x8e, 0x62, 0x02, 0x22, 0xc5, 0x95, 0xce, 0x45
AAD:
0x45, 0x58, 0x31, 0x45, 0x33, 0x41, 0x41, 0x44
SecOC Key Data Record:
0x08, 0xe6, 0xa6, 0xc5, 0x6e, 0x17, 0x28, 0xa7, 0xe1, 0xce, 0xb7, 0x6e, 0x5e, 0x29, 0xa2, 0x4e
TAG:
0x86, 0x57, 0xf1, 0xaa, 0x42, 0x7b, 0xcc, 0x5b, 0xfb, 0xd4, 0x82, 0x3d, 0xf5, 0x62, 0x05, 0xd7
SecOC Key:
0xab, 0x55, 0x10, 0x5a, 0x61, 0xf9, 0x0a, 0xbf, 0x35, 0x96, 0x24, 0x5b, 0x9c, 0xf0, 0x33, 0x0a

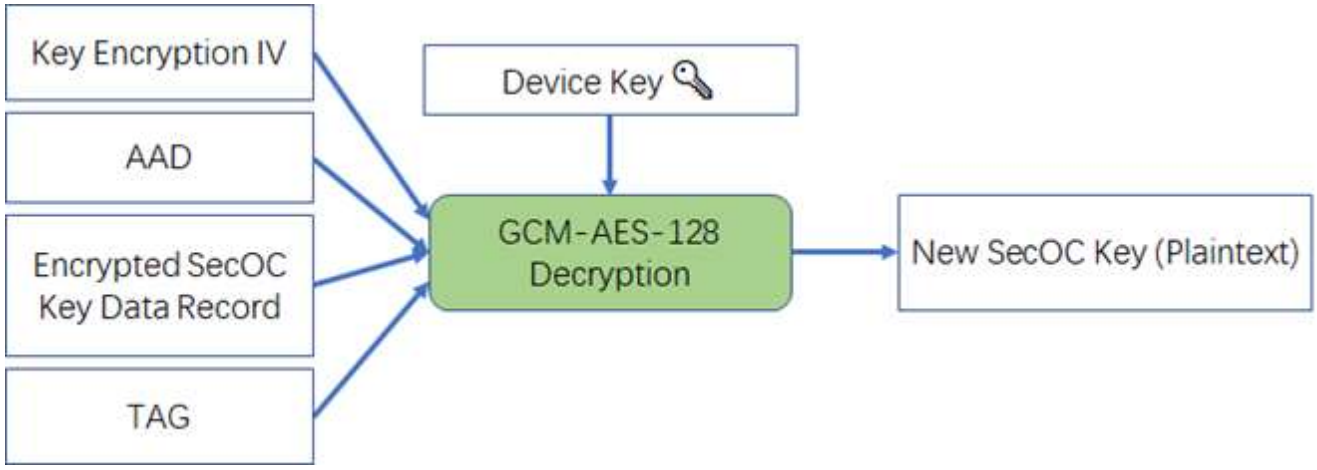
Key Decryption

987091 v2 **Key Decryption**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

Keys shall be decrypted using the plaintext device key (16 bytes) stored in the ECU as a secret, the key encryption IV (12 bytes), AAD (8 bytes), the encrypted SecOC key data record (16 bytes) and the TAG (16 bytes) from the DID request as input to be decrypted.



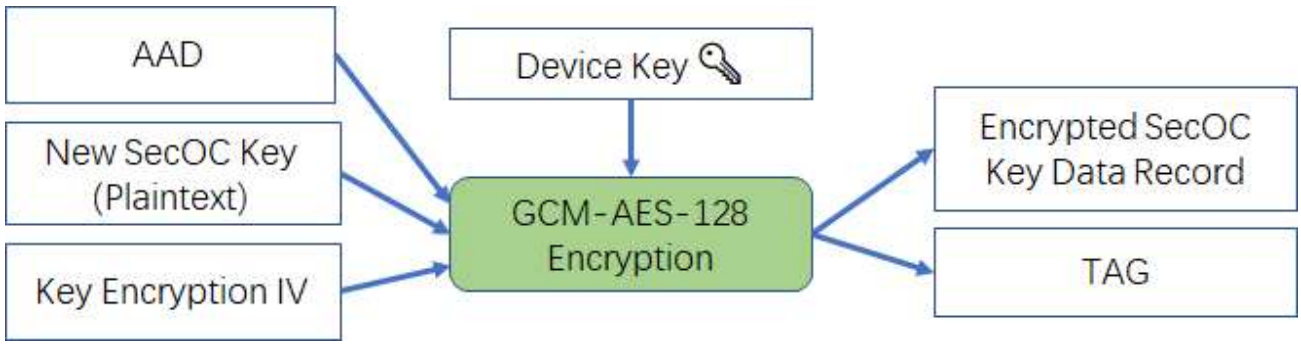
Key Encryption

987092 v2 Key Encryption

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The encrypted SecOC key data record (16 bytes) and the TAG (16 bytes) shall be calculated using the plaintext device key (16 bytes) as secret, the key encryption IV (12 bytes), plaintext AAD (8 bytes) and the new plaintext SecOC key (16 bytes) as input.



Key Programmed Status

987093 v2 Key Programmed Status

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall set base DTC 0xD0C4 with Failure Type Byte (FTB) 0x51, if any of the SecOC keys corresponding to the supported SecOCClusterKeyID in the ECU are initial keys (0xFF).

The ECU shall clear DTC 0xD0C451 upon successful write operation of all supported SecOC keys in the ECU.

If, for any reason, any of the supported SecOC keys are provisioned back to its initial state (0xFF) then the DTC shall be set in the ECU in order to indicate that one or all of the SecOC keys are provisioned with an initial key.

Key Storage

987094 v2 **Key Storage**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

SecOC keys shall be stored in a secure environment.

Key Type Structure

987095 v2 **Key Type Structure**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The SecOC key(s) shall be represented in hexadecimal format when programmed to the ECU using writeDataByIdentifier service 0x2E using DID 0xC05D.

The format of the key(s) when programmed shall be the following concatenation:

Key Format:
SecOC Cluster Key Identifier (1 byte) || Initialization Vector (IV) (12 bytes) || Additional Authenticated Data (AAD) (8 bytes) || Encrypted SecOC Key Data Record (16 bytes) || TAG (16 bytes)

, the encrypted SecOC key data record (16 bytes) and the TAG (16 bytes) from the DID request as input to be decrypted.

The Encrypted SecOC Data Record is the encryption of the new plaintext SecOC key (see Key Encryption).

The Key Encryption Initialization Vector (IV) shall be a 96 bit long cryptographic nonce (randomly generated unique value). The IV is used when encrypting/decrypting the SecOC key data record. The IV shall be discarded after the DID operation and shall not be stored in the ECU.

Key Update Handling

987096 v2 **Key Update Handling**

Version history:
(2):

Purpose:

Verification Method: Test
Legacy ID:

SecOC keys shall be possible to program by writeDataByIdentifier service 0x2E using DID 0xC05D. The DID shall be supported in extendedDiagnosticSession. The DID shall be protected by Authentication service 0x29 using the diagnostics role "Workshop elevated". If the ECU does not support Authentication service 0x29, the DID shall be protected by SecurityAccess service 0x27 with level 0x19 instead. The DID shall be write-only.

SecOC key(s) for production units shall be programmed by the OEM. Non-programmed SecOC keys shall have an initial value of all bytes set to 0xFF.

When the SecOC key is successfully updated, the Trip Counter needs to be reset.(Before restarting, the Trip Counter reset does not take effect)

Message Direction	Client ® Server	
Message Type	Request	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	WriteDataByIdentifier Request SID	$2E_{16}$
#2	dataIdentifier – SecOC Key Update Byte#1 (MSB)	$C0_{16}$
#3	dataIdentifier – SecOC Key Update Byte#2 (LSB)	$5D_{16}$
#4	SecOCClusterKeyID	00-FF_{16}
#5	SecOC Key Encryption IV Byte#1 (MSB)	00-FF_{16}
...	...	...
#16	SecOC Key Encryption IV Byte#12 (LSB)	00-FF_{16}
#17	SecOC Key Encryption AAD Byte #1 (MSB)	00-FF_{16}
...	...	...
#24	SecOC Key Encryption AAD Byte #8 (LSB)	00-FF_{16}
#25	Encrypted SecOC Key Data Record Byte #1 (MSB)	00-FF_{16}
...	...	...
#40	Encrypted SecOC Key Data Record Byte #16 (LSB)	00-FF_{16}
#41	SecOC Key TAG Byte #1 (MSB)	00-FF_{16}
...	...	...
#56	SecOC Key TAG Byte #16 (LSB)	00-FF_{16}

Table: DID request for SecOC Key Update.

Upon DID request, the ECU shall check if the requested SecOCClusterKeyID is supported by the ECU. For a valid SecOCClusterKeyID, the ECU shall decrypt the encrypted SecOC key data record and verify the SecOC Key TAG in the request with the AES GCM algorithm. The ECU shall store the new SecOC key in the Secure Environment (e.g., HSM) if the verification is successful. The ECU shall then clear the DID memory with 0x00..00 immediately upon finalizing the activities (decryption and storing the new SecOC key in the Secure Environment).

There shall be different negative response codes to separate errors:

1. Length or format check failed (NRC 0x13: incorrectMessageLengthOrInvalidFormat).
2. None of the supported SecOCClusterKeyID stored in the ECU match the SecOCClusterKeyID in the DID request (NRC 0x31: requestOutOfRange).
3. The client is not authenticated with Authentication service 0x29 using the diagnostics role "Workshop elevated" before the DID request (NRC 0x34: authenticationRequired).
4. ECU is not unlocked with SecurityAccess service 0x27 before the DID request (NRC 0x33: securityAccessDenied).
5. Failed to decrypt the encrypted SecOC key data record in the DID request (NRC 0x22: conditionsNotCorrect).
6. Error in writing the new SecOC key to the Secure Environment (NRC 0x72: generalProgrammingFailure).

4.1.6.4.1 Symmetric Device Key

Device Key

987097 v2 **Device Key**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall use a Device Key, different for each ECU and written in the EOL phase. The device key shall be used to encrypt keys during key update. The device key shall be 16 bytes long. The encryption algorithm to encrypt the device key shall be CBC-AES-128 (see Encryption Method for Key Format).

Encryption Method for Key Format

987100 v2 **Encryption Method for Key Format**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The encryption algorithm for the key format shall be the Cipher Block Chaining (CBC) Mode of Operation with AES-128 symmetric block cipher (AES-128-CBC) according to NIST SP 800-38A. The AES-128-CBC shall be used to

encrypt/decrypt the device key data record.

The Initialization Vector (IV) is 16 byte random number.

The key used to encrypt the device key shall be programmed as 16 bytes 0xFF (0xFF FF FF FF FF FF FF FF FF FF FF FF FF FF FF FF).

Example (testcase):
IV:
0x88, 0x90, 0xf3, 0xdb, 0xc0, 0x7c, 0xa4, 0xc5, 0xf9, 0x96, 0xaa, 0x13, 0xbb, 0x4b, 0x37, 0xfd
Source Data (Device Key and 0 padding):
0x41, 0xac, 0x05, 0x6c, 0x4c, 0x9b, 0x4b, 0x90, 0x4a, 0x29, 0xf6, 0xd0, 0x19, 0x1d, 0x84, 0xf7,
0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00
Key (Encrypt Key):
0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF, 0xFF
Result (Diagnostic input):
Device Key record data:
0x75, 0x58, 0xf9, 0x56, 0x02, 0x37, 0x9b, 0x20, 0x60, 0xff, 0xbe, 0x1e, 0x9d, 0xec, 0x68, 0xd7, 0x22, 0x80, 0x52,
0xd0, 0x2f, 0x4e, 0x10, 0xa0, 0x17, 0x03, 0xe6, 0xa9, 0x16, 0x8a, 0x54, 0x1d

Key Decryption

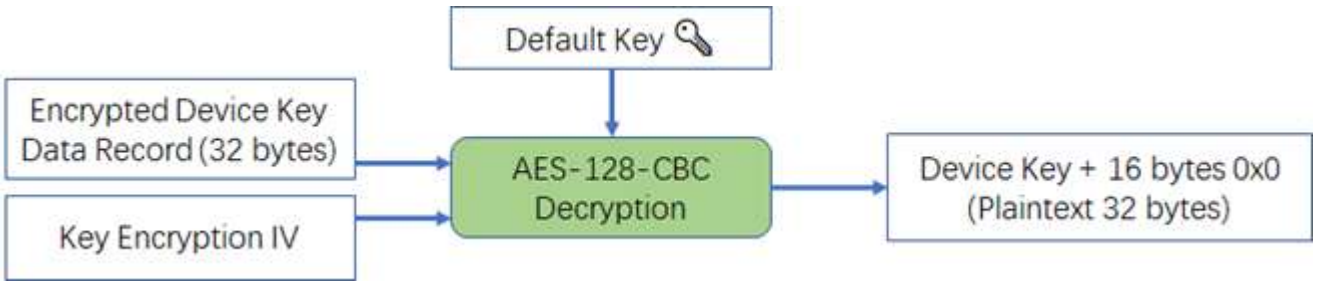
987101 v2 **Key Decryption**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

Keys shall be decrypted using the default development key (16 bytes 0xFF) as secret, the key encryption IV (16 bytes), and the encrypted Device key data record (32 bytes) from the DID request as input to be decrypted.

The decrypted plaintext is the 16 byte long Device Key (first 16 bytes (MSB)) and the 16 bytes plaintext padding (0x00, last 16 bytes (LSB)).



Key Encryption

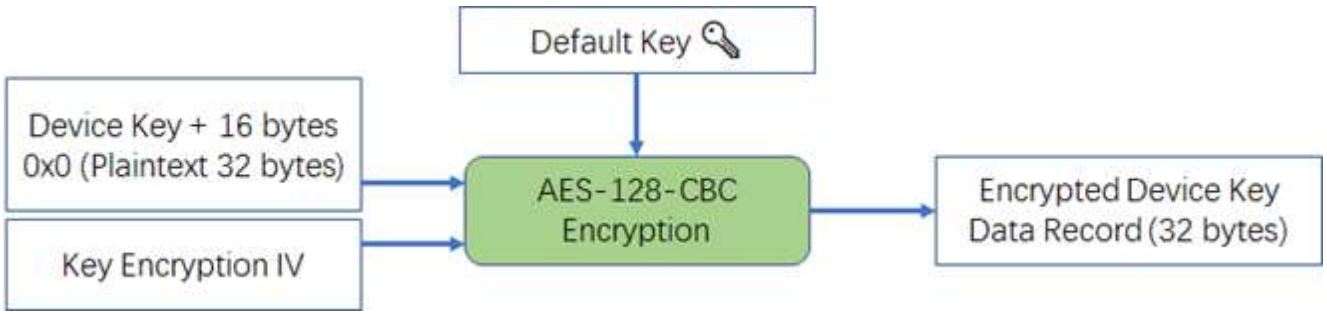
987102 v2 **Key Encryption**

Version history:
(2):

Purpose:
Verification Method: Test

Legacy ID:

The encrypted Device key data record shall be calculated using the default key (16 bytes 0xFF) as secret, the key encryption IV (16 bytes), plaintext Device Key (16 bytes) and the plaintext padding (16 bytes 0x00) as input.



Example:
Default key: 0xFF FF FF FF FF FF FF FF FF FF FF FF FF FF FF FF.
Plaintext padding: 0x00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00.

Key Storage

987104 v2 **Key Storage**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Device keys shall be stored in a secure environment.

Key Type Structure

987106 v2 **Key Type Structure**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The Device key shall be represented in hexadecimal format when programmed to the ECU using writeDataByIdentifier service 0x2E using DID 0xD0E9.

The format of the key(s) when programmed shall be the following concatenation:

Key Format:
Key Encryption Initialization Vector (IV) (16 bytes) || Encrypted Device Key Data Record (32 bytes).

Note:
'||' refers to concatenating the two parts of the diagnostic content. The first 16 bytes (MSB) of the encrypted device key data record shall be used for the device key. The last 16 bytes (LSB) of the encrypted device key data record

shall be used for padding (0x00).
Example:
0x41, 0xac, 0x05, 0x6c, 0x4c, 0x9b, 0x4b, 0x90, 0x4a, 0x29, 0xf6, 0xd0, 0x19, 0x1d, 0x84, 0xf7,
0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00

The Encrypted Device Data Record is the encryption of the concatenated plaintext Device key (see Key Encryption).

The Key Encryption Initialization Vector (IV) shall be a 128 bit long cryptographic nonce (randomly generated unique value). The IV is used when encrypting/decrypting the Device Key data record. The IV shall be discarded after the DID operation and shall not be stored in the ECU.
Example:
0x88, 0x90, 0xf3, 0xdb, 0xc0, 0x7c, 0xa4, 0xc5, 0xf9, 0x96, 0xaa, 0x13, 0xbb, 0x4b, 0x37, 0xfd

Key Update Handing

987108 v2 **Key Update Handing**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The device key shall be possible to program by writeDataByIdentifier service 0x2E using DID 0xD0E9. The DID shall be supported in extendedDiagnosticSession. The DID shall be protected by Authentication service 0x29 using the diagnostics role "Workshop elevated". If the ECU does not support Authentication service 0x29, the DID shall be protected by SecurityAccess service 0x27 with level 0x19 instead. The DID shall be write-only.

The device key for production units shall be programmed by the OEM. Non-programmed Device keys shall have an initial value of all bytes set to 0xFF.

Message Direction	Client → Server	
Message Type	Request	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	WriteDataByIdentifier Request SID	$2E_{16}$
#2	dataIdentifier – Configure Device Key Byte#1 (MSB)	$D0_{16}$
#3	dataIdentifier – Configure Device Key Byte#2 (LSB)	$E9_{16}$
#4	Device Key Encryption IV Byte#1 (MSB)	00-FF_{16}
...	...	...
#19	Device Key Encryption IV Byte#16 (LSB)	00-FF_{16}
#20	Encrypted Device Key Data Record Byte #1 (MSB)	00-FF_{16}
...	...	...
#51	Encrypted Device Key Data Record Byte #32 (LSB)	00-FF_{16}

Table: DID request for Device Key Update.

Upon DID request, the ECU shall decrypt the encrypted device key data record. The ECU shall store the device key in the Secure Environment (e.g., HSM) if the verification is successful. The ECU shall then clear the DID memory with 0x00..00 immediately upon finalizing the activities (decryption and storing the device key in the Secure Environment).

There shall be different negative response codes to separate errors:

1. Length or format check failed (NRC 0x13: incorrectMessageLengthOrInvalidFormat).
2. The client is not authenticated with Authentication service 0x29 using the diagnostics role "Workshop elevated" before the DID request (NRC 0x34: authenticationRequired).
3. ECU is not unlocked with SecurityAccess service 0x27 before the DID request (NRC 0x33: securityAccessDenied).
4. Failed to decrypt the encrypted device key data record in the DID request (NRC 0x22: conditionsNotCorrect). ECU decrypt Devcice Key data record should get 16 bytes Device Key and 16 bytes 0x0 that padding before encryption. If the last 16 bytes not all 0x0, the DID should also request (NRC 0x22: conditionsNotCorrect).
5. Error in writing the device key to the Secure Environment (NRC 0x72: generalProgrammingFailure).

4.1.6.5 SecOC Verification and Failure Handling

Action on Message Failures

987109 v2 **Action on Message Failures**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

When the ECU encounters a SecOC verification failure, the application software shall define and handle failure actions. A few possible actions can be:

Use fail safe data values/actions
Disable functions
Temporarily accept failed signal data under specified range and conditions
Report failures to the Security Log or Intrusion Detection System
Take no action
Discard the signal without using it

DID for SecOC Verification Failure Counters

987110 v3 **DID for SecOC Verification Failure Counters**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall report failure counters of SecOC verification failures for all supported PDUs protected by SecOC in the ECU. The information shall be accessible by readDataByIdentifier service 0x22 using DID 0xC0A4. The DID shall be supported in extendedDiagnosticSession and shall be protected by Authentication service 0x29 using the diagnostics role "Workshop elevated". If the ECU does not support Authentication service 0x29, the DID shall be

protected by SecurityAccess service 0x27 with level 0x19 instead. The DID shall be read-only.
The definition and format of DID shall be based on the format defined in SSDS.

The information in the DID shall contain failure counters of length 8 bit each for all SecOC PDUs configured in the ECU. The 8 bit fail counter value indicates the number of times a PDU has failed final verification with SecOC.

Each failure count value shall be reset to zero on every ECU startup. Upon reaching the maximum value (0xFF), the failure count value shall be frozen to the maximum value (0xFF) and shall not overflow.Each failure count value shall be reset to zero on every ECU startup.

Note:
Parameters for DID 0xC0A4 is only for reference and parameters for actual PDUs in an ECU shall be implemented in ECU specific diagnostic deployment.
Each failure count value shall be incremented in these cases：verification failure, freshness or authentication code failure.

Message Direction	Server → Client	
Message Type	Response	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	ReadDataByIdentifier Response SID	62_{16}
#2 #3	dataIdentifier – SecOC Verification Failure Counters Byte#1 (MSB) dataIdentifier – SecOC Verification Failure Counters Byte#2 (LSB)	$C0_{16}$ $A4_{16}$
#4	PDU 1 SecOC failure count value	$00\text{-}FF_{16}$
#5	PDU 2 SecOC failure count value	$00\text{-}FF_{16}$
#6	PDU 3 SecOC failure count value	$00\text{-}FF_{16}$
...	...	...
#n	PDU n SecOC failure count value	$00\text{-}FF_{16}$

Table: DID 0xC0A4 to read SecOC verification failure counters.

DID for SecOC Verification Failures

987116 v3 **DID for SecOC Verification Failures**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall report information related to SecOC verification failures for all supported PDUs protected by SecOC in the ECU. The information shall be accessible by readDataByIdentifier service 0x22 using DID 0xC0A3. The DID shall be supported in all diagnostic sessions except ProgrammingSession and shall be read-only. The DID shall not be protected by Authentication service 0x29 or by SecurityAccess service 0x27 and the same DID shall be used to configure snapshot data for global SecOC failure DTC defined in the ECU.
The definition and format of DID shall be based on the format defined in SSDS.

The response for reading DID 0xC0A3 shall be bit encoded and the bit value shall be set to one (1) if a PDU has exceeded the SecOC failure count limit and zero (0) otherwise. Each failure count limit value shall be reset to zero on every ECU startup.

Example:
DID C0A3 is 4 bytes long and both PDU 1 and PDU 3 have exceeded their limits respectively.
The response shall be: 0b00000000000000000000000000000101

Note:
Parameters for DID 0xC0A3 is only for reference and parameters for actual PDUs in an ECU shall be implemented in ECU specific diagnostic deployment.

Message Direction	Server → Client	
Message Type	Response	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	ReadDataByIdentifier Response SID	62_{16}
#2	dataIdentifier – SecOC Verification Failures Byte#1 (MSB)	$C0_{16}$
#3	dataIdentifier – SecOC Verification Failures Byte#2 (LSB)	$A3_{16}$
#4 bit 0	PDU 1 SecOC failure count limit exceeded	0b0 – No 0b1 – Yes
#4 bit 1	PDU 2 SecOC failure count limit exceeded	0b0 – No 0b1 – Yes
#4 bit 2	PDU 3 SecOC failure count limit exceeded	0b0 – No 0b1 – Yes
...	...	...
#n bit m	PDU n SecOC failure count limit exceeded	0b0 – No 0b1 – Yes

Table: DID 0xC0A3 to read SecOC verification failures.

Detection of Corrupt Data Received

987117 v3 **Detection of Corrupt Data Received**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

If the ECU at application layer detects, by the verification result provided by SecOC, that a data value received from another ECU is corrupted, this shall be identified with a corresponding DTC. A data value is corrupt if the final SecOC verification is not successful. The same DTC is to be set for a PDU independent of type of SecOC verification failure reported to the application layer (verification failure, freshness or authentication code failure).
The definition and format of DID shall be based on the format defined in SSDS.

- The DTC shall be set when the number of SecOC verification failures for any PDU exceeds its configurable limit for setting the DTC.
- The ECU shall have a common base DTC 0xD0C5 for all PDUs protected by SecOC in an ECU.
- The DTC shall use Failure Type Byte (FTB) 0x68.
- The ECU supporting SecOC shall implement a mandatory global DTC snapshot data record that shall include DID 0xC0A3 (from DID for SecOC Verification Failures).

Note:
statusOfDTC testFailed = 1 (Test sample failed criteria on ZDDC) condition is "SecOC verification failures for any PDU exceeds its configurable limit".

statusOfDTC testFailed = 0 (Test sample passed criteria on ZDDC) condition is "Successfully conducted SecOC verification for all PDUs", when the statusOfDTC testFailed = 0, the data of DID 0xC0A3 and 0xC0A4 need be cleared.

Example:
An ECU has two SecOC protected PDUs. The failure limit for both PDUs is 255. At ECU reset/start, the current failure counters are reset for both PDUs.

If 255 (0xFF) final SecOC verification failures are detected for PDU 2 and 100 (0x64) for PDU 1, the DTC shall be set with the following snapshot data record:

Parameter Name	Length (Bits)	Values
PDU 1 SecOC failure count limit exceeded	1	0b0 – No
PDU 2 SecOC failure count limit exceeded	1	0b1 – Yes

Verification Modes

987118 v3 **Verification Modes**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The verification of SecOC messages shall be controlled via DID 0xC0A5. The mode of verification shall be selected by writeDataByIdentifier service 0x2E and the information shall be accessible by readDataByIdentifier service 0x22.The writeDataByIdentifier of this DID shall be supported in extendedDiagnosticSession and shall be protected by Authentication service 0x29 using the diagnostics role "Workshop elevated". If the ECU does not support Authentication service 0x29, this shall be protected by SecurityAccess service 0x27 with level 0x19 instead and the readDataByIdentifier of this DID shall be supported in all diagnostic sessions except ProgrammingSession and shall not be protected by Authentication service 0x29 or by SecurityAccess service 0x27.
The definition and format of DID shall be based on the format defined in SSDS.

SecOC Ignored: writing 0x00 to DID 0xC0A5 shall cause the ECU to ignore the verification result of all SecOC messages by setting the parameter SecOCIgnoreVerificationResult = true. All PDUs shall be forwarded regardless if the MAC verification succeeds or fails.

SecOC Active: writing 0x01 to DID 0xC0A5 shall enable verification of all SecOC messages by setting the parameter SecOCIgnoreVerificationResult = false. All PDUs shall be verified according to SecOC in this mode.

DID for SecOC TripCounter

1029012 v1 **DID for SecOC TripCounter**

Version history:
(1):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall be capable of reading the SecOC TripCounter. The information shall be accessible by readDataByIdentifier service 0x22 using DID **0xD0CD**. The DID shall be supported in extendedDiagnosticSession and shall be protected by SecurityAccess service 0x27 with level 0x19 instead. The DID shall be read-only.

Message Direction	Server → Client	
Message Type	Response	
Data Byte	**Description (all values are in hexadecimal)**	**Byte Value**
#1	ReadDataByIdentifier Response SID	62_{16}
#2	dataIdentifier –SecOC TripCounter Byte#1 (MSB)	$D0_{16}$
#3	dataIdentifier – SecOC TripCounter Byte#2 (LSB)	CD_{16}
#4	SecOC TripCounter Byte#1(MSB)	00-FF_{16}
#5	SecOC TripCounter Byte#2	00-FF_{16}
#6	SecOC TripCounter Byte#3(LSB)	00-FF_{16}

Trip Counter (TripCnt)：This counter is incremented in units of trips by the FV management master ECU. With the single FV management master method, the FV management master ECU sends a new TripCnt as the sync message (TripResetSyncMsg) to the sender ECU and receiver ECU. All the sender and receiver ECUs maintain this value. With the multi FV management master method, the sender ECU sends a new TripCnt as the sync message to the receiver ECU. The receiver ECU maintains this value.

counter change requirement

Counter	Increment condition	Initialization condition	Initial value	Counter length
Trip counter (TripCnt)	- When the FV management master ECU starts - On wakeup - On reset - When the power status changes: "IG-OFF⇒IG-ON", incremented by 1	The increment conditions occur at the maximum value of the trip counter.	FVmanagement master ECU: 1 Slave ECU: 0	24 bit

4.1.7 18_Security Audit Log

Log recording of vehicle remote control（GB)

851903 v3 **Log recording of vehicle remote control（GB)**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

控制器执行远程控制指令，需向云端反馈执行结果，若无法反馈，则控制器应具备记录远程控制指令的安全日志功能；
a)安全日志数据格式应至少包括：远程控制指令的时间、发送主体、远程控制对象、操作结果；
b)安全日志保存时间不少于6个月。

When the controller executes a remote control command, it is required to feedback the execution result to the cloud（backend）. If it is unable to provide feedback, the controller should have the capability to record security logs for remote control commands.
a) The security log data format should include at least: the time of the remote control command, the sender, the target of the remote control, and the outcome of the operation.
b) Security logs must be retained for no less than six months.

远程控制指令要点解释：
Explanation of Key Points for Remote Control Instructions:

序号 Serial number	要点 Key points	要点解释 Key points explanation
1	远程控制指令的安全日志 Security log of remote control instructions	指的是车辆执行远控指令（ 如开启空调、 启动车辆、 车门解闭锁等） 记录的安全日志 Refers to the execution of remote control commands by the vehicle, such as turning on the air conditioning, starting the vehicle, and lock/unlock the doors

Key Communication Information Security Event Logging Requirements(GB)

851907 v2 **Key Communication Information Security Event Logging Requirements(GB)**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

关键的通信信息安全事件日志要求：
1、关键的通信信息安全事件：
1.1 建立通讯连接的身份校验失败事件与非法访问事件
1）车端与外界建立通讯连接发生的身份验证失败：身份认证失败事件和非授权的访问事件（包括非白名单及密码错误访问事件）；
2）通信信息校验失败事件（包括通信信息的完整性、有效性或唯一性的校验）；
1.2 建立通讯连接后，相关功能执行控制器反馈的失败事件
执行控制器接收到相关指令后无法正常执行，则需记录事件日志，反馈云端或进行本地存储；
2、日志存储要求：
a)日志数据格式应至少包括：事件时间、事件原因；
b)日志保存时间不少于6个月。

Key Communication Information Security Event Logging Requirements:

1、Key Communication Information Security Events:
1.1 Identity verification failure events and illegal access events during the establishment of communication connections:

1）Identity verification failure events and unauthorized access events (including access events from non-whitelisted sources and password incorrect access events) when the vehicle establishes a communication connection with the outside world;
2）Communication information verification failure events (including verification of the integrity, validity or

uniqueness of the communication information);

1.2 Failure events of the execution controller after the establishment of communication connections:
If the execution controller is unable to perform normally after receiving related instructions, an event log must be recorded, which should be fed back to the cloud（backeend） or stored locally;

2、Log Storage Requirements:
a) The log data format should include at least: event time, event reason;
b) Logs must be retained for no less than six months.

Secure communication information log should cover follow requirement at least:
1.Cloud TLS Authentication faild.
2.Security Channel Establishment Verification faild(WIF\BLE\Classic Bluetooth).
3.Data operation instruction access control (WIF\BLE\classic Bluetooth, including NFC and RFID)
4.Key instruction effectiveness and uniqueness validate(WIF\BLE\Classic Bluetooth, including NFC and RFID);
5.Sensitive personal information transmission outside the vehicle
6.Physical replacement inspection (ECU with Bluetooth, WIFI, and cellular function)
7.The login or access of privileged users (root user)
8.Internal network isolation (for each domain controller)rules of change
9.DOS attack (WIFI and OBD)
10.Malicious diagnostic request.

4.1.7.1 Security Audit Log Introduction

For details about the definition of Audit log DID, please refer to the Audit log EXCEL table in the cybersecurity template provided by Geely ECU CS owner. 安全审计日志的DID具体定义最终版请参照吉利CS Owner提供的信息安全模板中的Audit log EXCEL表。

==========

This logical component specifies the requirement for security audit logs in the vehicle. Audit logs are used to record specific events in order to:

- Provide information required to detect possible attacks at early stage. By that, making detection of policy violation attempts or incidents is easier.
- Provide evidence in terms of a sequence of events and non-repudiation of actions to an investigation when an incident occurred.

An event is defined as an occurrence in a system that requires notification. Typically, this is information from an application or service that is not being executed as expected, some malicious activity is detected or a configuration change. The security log will be transferred to a host where it is being analyzed.

This logical component will specify

- The structure of the security event record in order to simplify the off-board auditing and analyzing process.
- The strategy of how to protect the log data, i.e. a security log.

- Recommendation of a basic set of auditable events.

This logical component will not specify the procedure of how to react upon a specific event. How and when to react is dependent of the actual event(s) reported.

4.1.7.2 Terminology

Authenticity	**Authenticity** is defined as the property that an entity is what it claims to be. Authenticity is the property of being genuine and being able to be verified and trusted. **Authentication** is the process of verifying the identity or other attributes claimed by or assumed of an entity (user, process, or device), or to verify the source and integrity of data.
Freshness	**Freshness** attribute applies to a quantum of information, a receiving entity and a given time. The property is satisfied if the quantum of information received by the entity at the given time is not a copy of the same information received by the same or another entity in the past. Ensuring freshness can be used to prevent replay attacks, for example.

4.1.7.3 Security Event Record

Every detected and reported security event shall use a common structure, referred to as SerurityEvent structure. This is required to simplify the review and analyze of the different recorded security events from the ECUs in the vehicle. The content of the SecurityEvent is defined in the following pseudo code;

```
struct SecurityEvent {
  Time (Global Real Time, if ECU cannot get timestamp please log with "Power-on times 0xFFFFFFFF"， eg: 0x00000003 Power-on times 3times)
  Source (optional)
  EventCode
  AddtionalEventData
}
```

Hence, an application is responsible of reporting the detected security event to a logger component in the ECU, which stores each event using the SecurityEvent structure. The event logger is the ECU component responsible for the security logging process for a single ECU, as defined in this document.

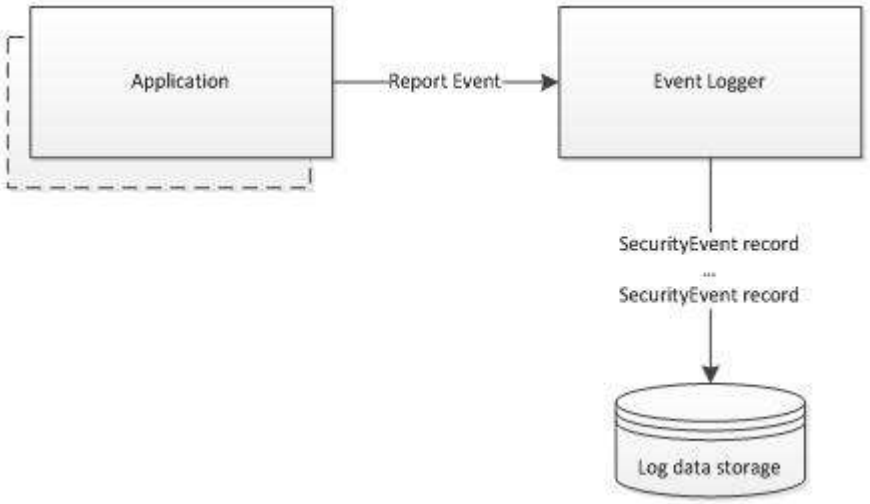


Figure Report Event and Security Event storage

The event types that are to be reported are dependent of the ECU itself, e.g. its physical/logical allocation, functions and responsibilities:

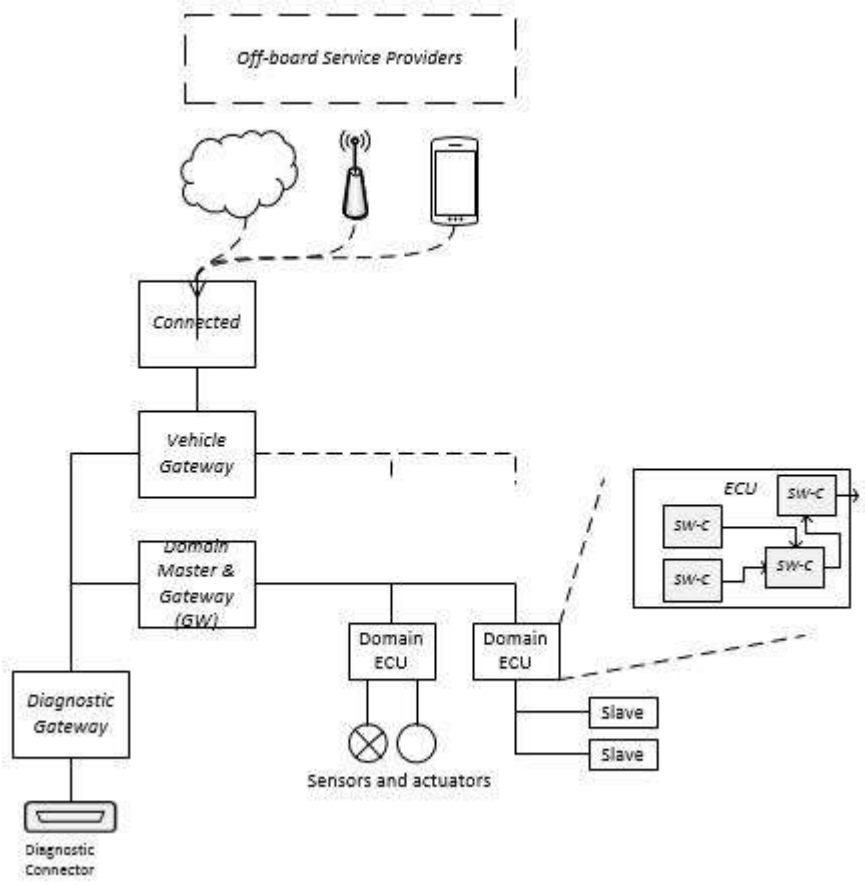


Figure General Vehicle Architecture

Section *Security Audit Log Events* will define some basic event types that shall be supported by the ECUs.

Security Event Types

524511 v4 **Security Event Types**

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

The security events shall be categorized into different event types.

Analyze and agree on the security events

524512 v4 Analyze and agree on the security events

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

The OEM and supplier shall together review and agree on the security events to be part of the security audit log.

SecurityEvent structure

524513 v4 SecurityEvent structure

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

Every security event shall use the SecurityEvent structure, including

- Time: The time when the event was detected.
- Source: The entity in the ECU that is reporting the event, e.g. a verification component used for Signature Verification of a file. Source is (optional) and shall be omitted by default (see note).
- EventCode: Code (number) used to describe the Event, e.g. 1 = SignatureVerification failed, Invalid Signature Data. Each event type uses its own set of EventCodes. EventCode=0 shall be used to indicate 'No History', i.e. no record reported. Values 0x01-0x7F shall be applied for "failed/rejected" attempts and 0x80-0xFE for successful respectively.
- AdditionalEventData: Additional data, e.g. a file name, Certificate details, IP Addresses, etc. This information is related to e.g. event type and its EventCode.
- The value 0xFF shall be applied as default value for event entries that are empty, e.g. Time and AdditionalEventData when required information is not available.

The supplier must provide a list of the defined EventCodes.
Note.
When defining the actual diagnostic identifier (DID) according to the SecurityEvent structure, the source might be obsolete if there is only one component reporting the specific event type.

Read out Security Event records

524514 v4 Read out Security Event records

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

It shall be possible to read all Security Event types via the diagnostic protocol, using the service ReadDataByIdentifier. Event types reported in programmingSession shall also be available to read in non-programmingSession.

A unique DID shall be applied for each type.

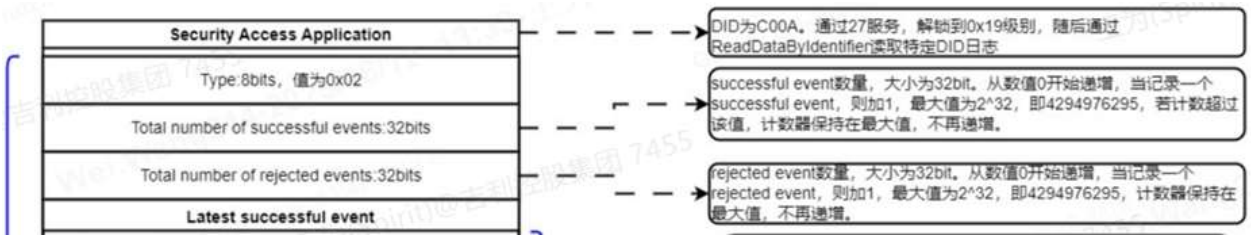
Counter overflow strategy

987208 v2 Counter overflow strategy

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The counters defined in the SecurityEvent Header shall have a length of at least 4 bytes， maximum required to be filled with 4 bytes. Counter overflow is accepted but there shall be no possibility to reset the counters.



Note.

Refer to the chapter of Event Log Flooding of how to mitigate the risk of counter overflow.

Minimum number of events to be stored

987209 v2 Minimum number of events to be stored

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The ECU must be able to store at least 20 events (for each type defined), but 100 events are recommended.

If both successful- and rejected attempts are reported, half of the event records for successful- and rejected attempts respectively must be stored. Otherwise, the history of e.g. the rejected attempts could be lost (the log is filled with only successful attempts). The first half (e.g. 10 when 20 events in total are stored) are reserved for successful attempts and the last part is for the rejected attempts.

Example 1.
Pre-condition: 19 event records are stored out of total 20 (9 successful, 10 rejected),

Event record 1: Successful attempt, e.g. a file is verified OK.
Event record 2: Successful attempt
Event record 3: Successful attempt
Event record 4: Successful attempt
Event record 5: Successful attempt
Event record 6: Successful attempt
Event record 7: Successful attempt
Event record 8: Successful attempt
Event record 9: Successful attempt
Event record 10: No history
Event record 11: Rejected attempt, e.g. the file verification failed.
Event record 12: Rejected attempt
Event record 13: Rejected attempt
Event record 14: Rejected attempt
Event record 15: Rejected attempt
Event record 16: Rejected attempt
Event record 17: Rejected attempt
Event record 18: Rejected attempt
Event record 19: Rejected attempt
Event record 20: Rejected attempt
If the next reported event is a rejected attempt, a record for a successful attempt must not be overwritten but a record (oldest) for a rejected attempt shall be overwritten according to the overwrite strategy.

Note.
The number of events that is stored must be balanced with respect to the available memory.

Security Event Header

987210 v2 **Security Event Header**

Version history:
(2):

Purpose:

Verification Method: Analysis
Legacy ID:

When storing each event, it's required to know the total number of reported events. This is needed in order to keep track of the amount of events that have been reported, but overwritten due to limited memory. Hence, a simple header is introduced. The counter for total reported events (for each event type) is also used as an indication of an possible mis-use, e.g. if the actual counter value for an event is high but the event is not likely to happen that often.

Every security event shall contain a Security Event Header, including

- TotalNumberOfReportedEvents: The total number of reported events, for each individual event type.

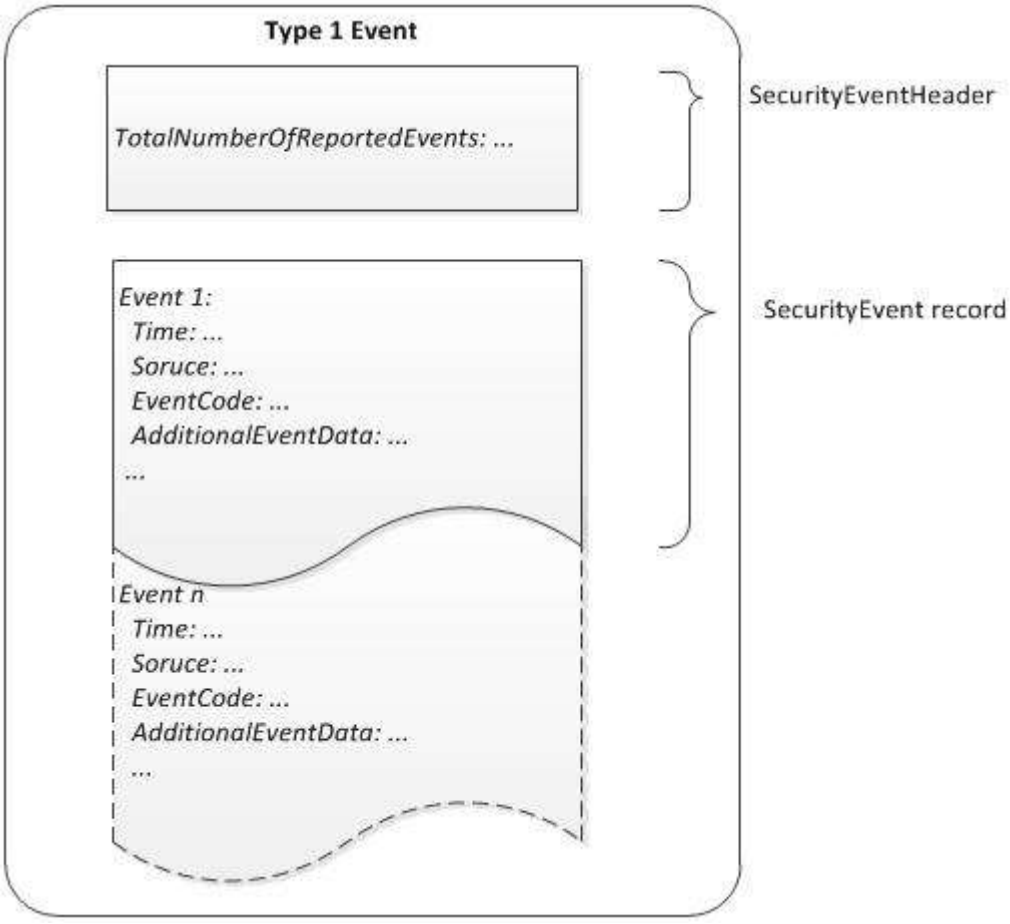


Figure SecurityEvent and SecurityEventHeader

A typical read out will contain a simple header followed by all records (events).
Notes.
(i) If the reserved log data is not full, the TotalNumberOfReportedEvents will be identical to the number of stored records for a specific event type.
(ii) A strategy for counter (TotalNumberOfReportedEvents) overflow is defined elsewhere in this document.
(iii) See other requirements, defining two types of security event header.

Total number of events

987211 v2 Total number of events

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The ECU must record the total number of events reported for each event type (TotalNumberOfReportedEvents). For some event types, it's important to be able to distinguish between successful- and rejected attempts. Hence, the Security Event Header could optionally include a second counter.

For each event type, one of the two following Security Event Header counter structures shall be used:

- Security Event Header type 1, including one single counter of all reported events (TotalNumberOfReportedEvents).
- Security Event Header type 2, including two counters; the first counter keep track of the successful attempts (TotalNumberOfSuccessfulEvents) and the second attempt counts the number of rejected attempts (TotalNumberOfRejectedEvents). This is to be applied when successful and rejected attempts are reported and could be separated.

Security Event Header type 2 shall be applied when the event type contains both successful and rejected events, otherwise type 1 header shall be applied.

Example.
Event Type is for Software Update. Security Event Header Type 2 is used, as it is relevant to store history about both successful and failed events.

- Counter 1: Counts the number of successful software updates.
- Counter 2: Counts the number of rejected (but started) software updates.

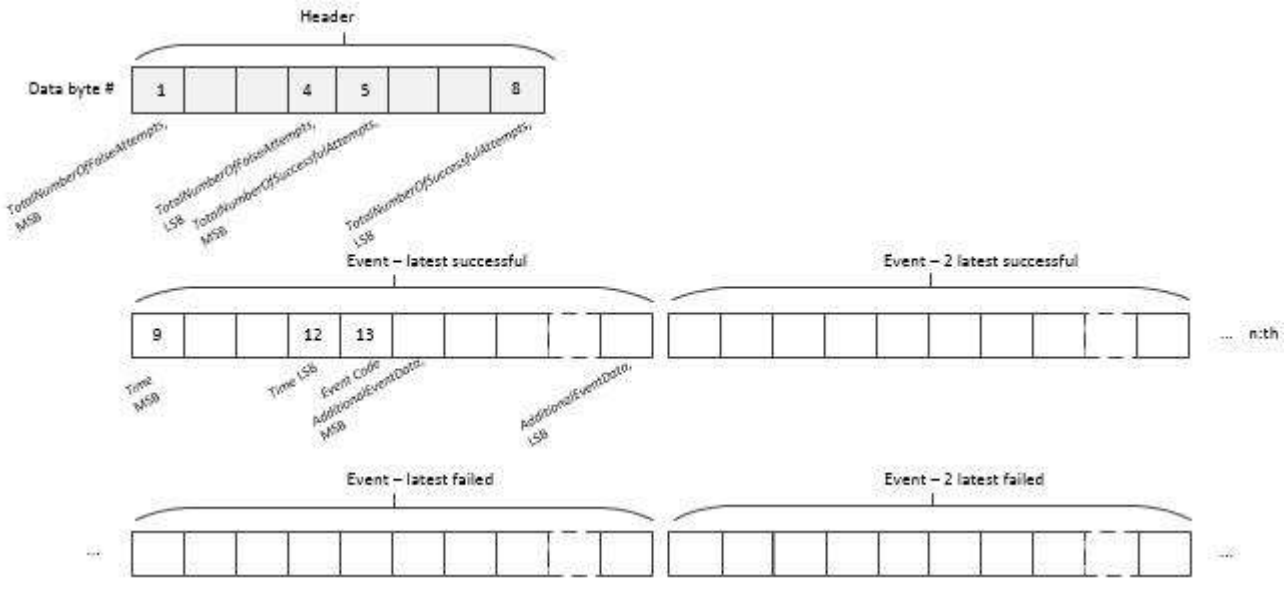


Figure Security Event Header Type 2
Big-endian is to be applied.

4.1.7.4 Protection Of Log Data

To reduce the risk that log data is being erased or manipulated, the log shall be protected. There are different levels of how to protect the log dependent of the actual log data that is stored, how it shall be used (fault tracing, evidence of an attack etc.), and threats considered. Generally, an attack on an audit log can be performed in two ways. First, the attacker might undermine the applied logical structures, e.g. protocols and algorithms to access the log file. Strong, standardized cryptographic algorithms, a correct implementation, deployment and carefully designed and reliably enforced access policies are required to prevent this attack. Second, the hardware might be targeted, e.g. the internal non-volatile memory containing the stored log data, or the memory where the access policies are stored. Tamper-resistant storage is required to protect against physical attacks.

Additionally, the system shall be resistant to e.g. Denial-of-Service (DoS) or to fault injection. Plausibility checks for all input parameters might be used to prevent that kind of attacks.
To summarize, unauthorized deletion/manipulation of system events log shall be prevented. How to realize that is highly dependent of the support provided by the ECU platform, e.g. hardware support for secure storage and operations.

Example.
An authorized user is requesting the log content using a diagnostic tester.
Scenario 1. A manipulated application respond with a modified log content, indicating that no events at all have been reported. This is not OK.

Scenario 2. The valid application respond, but the security log content has now been accessed and manipulated. This is not OK.

Overwrite strategy

524521 v4 Overwrite strategy

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

The log data must be protected from being erased. The default overwrite strategy to be applied is First-In-First-Out (FIFO), i.e. time-based. If there is some critical event that shall be excluded from this policy, this must be explicitly specified elsewhere. FIFO shall apply for every type, meaning that an event categorized as one type shall not overwrite an older event for a second type. For an event type where half of the events are dedicated for successful- and the other half for rejected attempts, there will be two separate FIFO lists.

Authenticity Verification Of Components

524522 v4 Authenticity Verification Of Components

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

The authenticity of both the applications reporting the events and the event logger component itself must be verified, otherwise the logging process might be circumvented or malicious data could be written to the log file

The authenticity of the reporting application and the event logger shall be verified.

Security Audit Log - Access Control

524629 v5 Security Audit Log - Access Control

Version history:
(5):

Purpose:
Verification Method: Analysis
Legacy ID:

Only authorized parties shall be able to view the log data and it must be accessible to authorized users when needed, to not reveal e.g. information about the system design that might be misused. One of following options shall be applied based on information stored:

(1) The log data is encrypted according to method agreed with OEM (specifed elsewhere).
(2) The log data is read (readDataByIdentifier service) protected by using diagnostic service securityAccess. Security Access level 0x19 shall be used.
(3) If the log data is not protected with access control. This alternative must be used with a motivation/assessment (e.g. the log data shall not reveal any sensitive information).

Secure storage of log data

524628 v5 **Secure storage of log data**

Version history:
(5):

Purpose:
Verification Method: Analysis
Legacy ID:

The security audit log shall be stored in a protected memory, e.g. it must as minimum not be possible to alter nor erase using unified diagnostic services or any other supplier specific methods (software attacks).

Note.
-If the security audit log is stored encrypted, the key used to encrypt the log data must be kept in a secure storage (e.g. not possible to read/alter/access).

Note:
-If Authentication Data is generated over log data and is stored in protected storage (e.g. hardware security module), that can be used to detect deletion of log data.

4.1.7.5 Optional Requirements - Protection of log data

Authentication Data - Algorithm

987167 v2 **Authentication Data - Algorithm**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The "NIST Special Publication 800-38B Recommendation for Block Cipher Modes of Operation: The CMAC Mode for Authentication" shall by default be used to calculate the Authentication Data. The underlying block

cipher shall be AES-128 (Advanced Encryption Standard FIPS PUB 197), where 128 bits is the minimum key length.
Notes.
(i) To reduce the required memory space, the CMAC might need to be truncated but is shall always be at least be 4 bytes (most significant bytes).
(ii) Other methods like hash-based HMAC construction according to [FIPS Publ 198-1] as well as "Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC, NIST Special Publication 800-38D" can be used upon agreement with the OEM or when explicitly required for a specific event type (based on data structure and key format defined by the OEM). GCM provides authenticated encryption.

Authentication Data - Inputs

987168 v2 **Authentication Data - Inputs**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The Authentication Data shall be calculated using all stored SecurityEvents and the SecurityEventHeader (Authentication Data itself excluded) as input data. A single Authentication Data is calculated per event type.

Note.
This is optional, i.e. shall be agreed with OEM prior to implementation.

Key storage

987169 v2 **Key storage**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The secret key used to calculate the Authentication Data shall be stored in a protected ECU area and programmed at OEM end-of-line. It must not be possible to read or alter, e.g. using ReadDataByIdentifier service. Only trusted entities (secure operations) must be able to request operations using the secret key. See *Figure Authentication Data generation.* For the default method defined in *"REQid 145711 : Authentication Data - Algorithm"*, the ECU delivered shall be equipped with an initial key where all values are set to 1. The key for the default method is replaced at OEM using writeDataByIdentifier service, DID **0xD03B**. Writing of DID 0xD03B shall be protected by securityAccess level 0x19, write once.

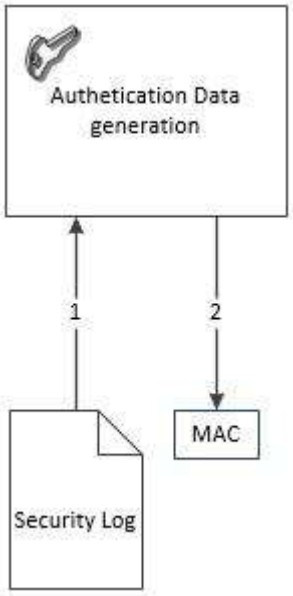


Figure Authentication Data generation

The Authentication Data shall always be appended next to the last event record for an event type, big endian.a

Authentication Data calculation

987170 v2 Authentication Data calculation

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The Authentication Data shall be calculated when an event is reported and stored to non-volatile memory.

Event log flooding

524616 v4 Event log flooding

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

An attacker might be able to trigger that an event is being reported frequently, i.e. previously event will be overwritten. This is referred to as flooding. To mitigate the risk of log flooding, the

event logger must know how often an event is likely to happen. If an event is reported too frequently, it shall not be recorded but reported as separate Event Log flooding event type, where the data identifier of the event (type) is indicated together with the number of times if was reported. How to configure the time interval is to be reviewed for each event separately. Unless no interval is defined, the interval shall by default be infinite (i.e. flooding is not detected).

Event log flooding is, to some extent, also detected by the counters for accepted/rejected attempts. This could be seen as an evidence of a possible attack.

4.1.7.6 Security Audit Log Events

For details about the definition of Audit log DID, please refer to the Audit log EXCEL table in the cybersecurity template provided by Geely ECU CS owner. 安全审计日志的DID具体定义最终版请参照吉利CS Owner提供的信息安全模板中的Audit log EXCEL表。

==========

This section will define a base set of generic auditable events. The principle of the structure is shown in *"Figure - Example of Security Event Type structure",* where two counters are part of the header (type 2).

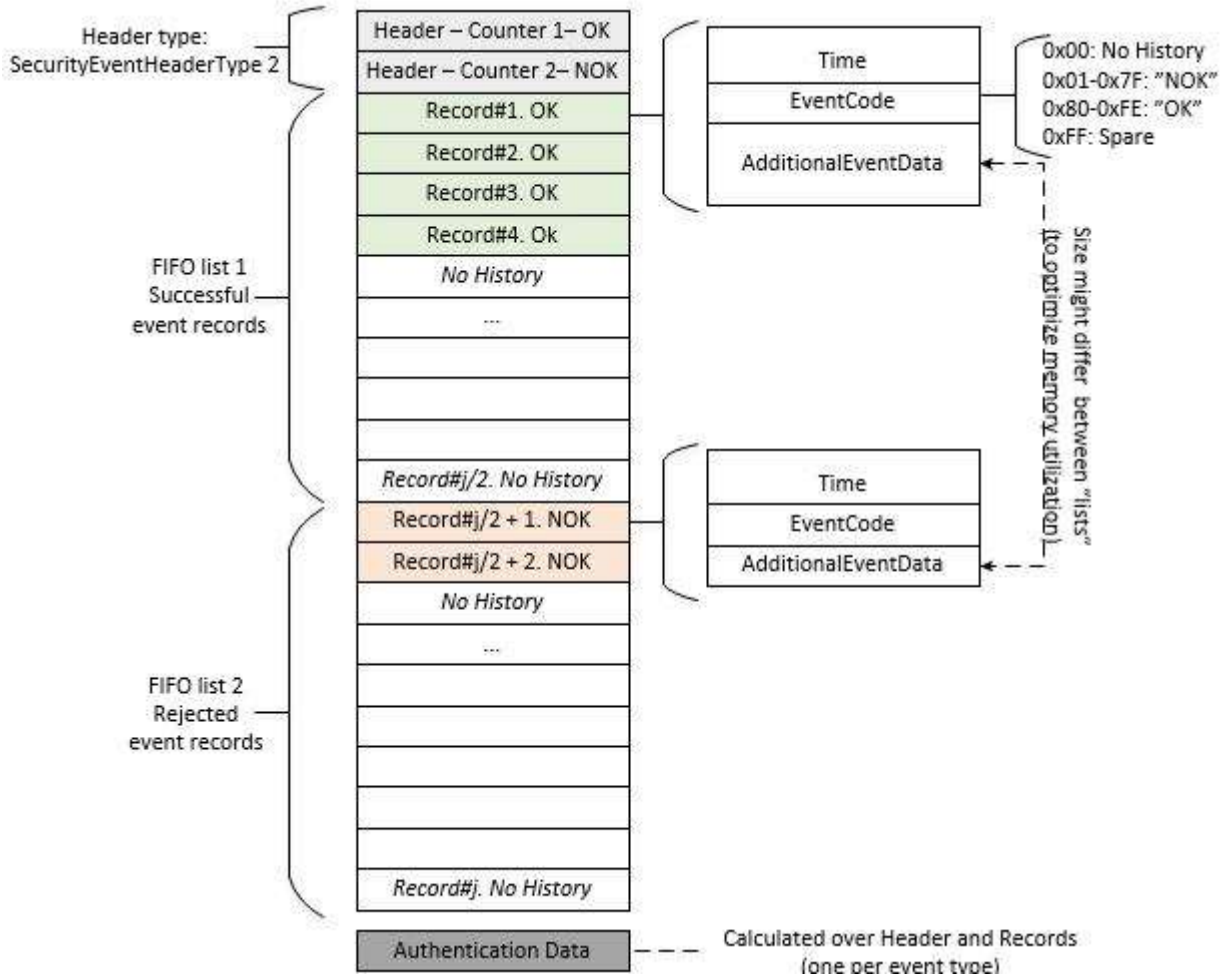


Figure - Example of Security Event Type structure

Event Type - C00A_Security Access

987200 v3 **Event Type - C00A_Security Access**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "Security Access" data record with identifier 0xC00A. The event type is for diagnostic service SecurityAccess when the ECU is running.

Event Header: SecurityEventHeaderType 2 shall be applied, i.e. using two counters. Size 8+32+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - Security Access Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - Security Access Event Definition". Size 32 bits.

Event Code	Event	Additional Event Data

0xFF	No History reported	NA
0x01	Security access validation failure	- Byte 1: The security access level(01,05,19…) - Byte 2: NRC (35/36/37/...)，0xFF should be used if NRC is unavailable - Byte 3-4: 0xFFFF (reserved)
0x02	Request for ethernet switch to programing mode to download the firmware/configuration	- Byte1-2: CAN ID of eth Switch - Byte 3-4: received UDS request. (Truncate the request if its length is longer than the buffer)
0x03	Security access level mismatch at command execution	- Byte 1:Current unlocked security level . (01,05,19...) - Byte 2:Service ID after 27 service，e.g.2E,2F,31… - Byte 3-4:Sub Function ID (RID , DID)，default value should be used for these bytes if ID is unavailable
0x81	Security access validation successful	- Byte 1: Unlocked security level(01,05,19...) - Byte 2-4: 0xFFFFFF

Table - Security Access Event Definition

Access Control: Option (3) as defined in "REQ ID 369985 : Security Audit Log - Access Control" shall be applied

Event Type	Security Access
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**
	dataRecord [Byte#1] =**TotalNumberOfSuccessfulEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfSuccessfulEvents dataRecord [Byte#3] = TotalNumberOfSuccessfulEvents dataRecord [Byte#4] = TotalNumberOfSuccessfulEvents (LSB)
	dataRecord [Byte#1] = **TotalNumberOfRejectedEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfRejectedEvents dataRecord [Byte#3] = TotalNumberOfRejectedEvents dataRecord [Byte#4] = TotalNumberOfRejectedEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest **successful** event (MSB) … … dataRecord[Byte#4] = **Time** – latest **successful** event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest successful event
	dataRecord[Byte#1] = **AdditionalEventData** – latest successful event (MSB) … … dataRecord[Byte#4] = **AdditionalEventData** – latest successful event (LSB)
Event Record#2 .. Event Record#n-1	…
Event Record#n	dataRecord[Byte#1] = **Time** – n:th latest successful event (MSB) …

	… dataRecord[Byte#4] = **Time** – n:th latest successful event (LSB)
	dataRecord[Byte#1] = **EventCode** – n:th latest successful event
	dataRecord[Byte#1] = **AdditionalEventData** – n:th latest successful event (MSB) … … dataRecord[Byte#4] = **AdditionalEventData** – n:th latest successful event (LSB)
Event Record#n+1	dataRecord[Byte#1] = **Time** – latest **failed** event (MSB) … … dataRecord[Byte#4] = **Time** – latest **failed** event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest **failed** event
	dataRecord[Byte#1] = **AdditionalEventData** – latest **failed** event (MSB) … … dataRecord[Byte#4] = **AdditionalEventData** – latest **failed** event (LSB)
Event Record#n+2 .. Event Record#n+m-1	…
Event Record#n+m	dataRecord[Byte#1] = **Time** – m:th **failed** event (MSB) … … dataRecord[Byte#4] = **Time** – m:th **failed** event (LSB)
	dataRecord[Byte#1] = **EventCode**– m:th latest **failed** event
	dataRecord[Byte#1] = **AdditionalEventData** –m:th latest **failed** event (MSB) … … dataRecord[Byte#4] = **AdditionalEventData** –m:th latest **failed** event (LSB)

Table - Security Access Event Type

Note:Gererally speaking,both value of 'n' and 'm' are 10.About the exact value,please discuss the with OEM.

Event Type - C00B_Diagnostic Events

987185 v3 **Event Type - C00B_Diagnostic Events**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "Diagnostic Events" data record with identifier 0xC00B. The event type is

for important diagnostic events.

Event Header: SecurityEventHeaderType 1 shall be applied, i.e. using one counter. Size 8+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - Diagnostic Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - Diagnostic Event Definition". Size 24 bits.

Event Code	Event	Additional Event Data
0xFF	No History stored	NA
0x01	Diagnostic request failed (diagnostic commands: 1002/1003/1082/1082/1101/1181)	- Byte 1-2: The diagnostic request (1002/1003/1082/1082/1101/1181) - Byte 3: 0xFF(reserved)
0x02	Flexray bus anomaly (message missing)	0xFFFFFF
0x03	Any device connected to ethernet OBD-II port	- Byte1-3: MAC address of the connected device Truncate the request if its length is longer than the buffe

Access Control: Option (3) as defined in "REQPROD 369985 : Security Audit Log - Access Control" shall be applied

Event Type	Diagnostic Events
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =Type
	dataRecord [Byte#1] = **TotalNumberOfEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfSuccessfulEvents dataRecord [Byte#3] = TotalNumberOfSuccessfulEvents dataRecord [Byte#4] = TotalNumberOfSuccessfulEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest event (MSB) … … dataRecord[Byte#4] = **Time** – latest event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest event
	dataRecord[Byte#1] = AdditionalEventData – latest event (MSB) …… dataRecord[Byte#3] = Time – latest event (LSB)
Event Record#2 .. Event Record#n-1	…
Event Record#n	dataRecord[Byte#1] = **Time** – n:th latest event (MSB) … … dataRecord[Byte#4] = **Time** – n:th latest event (LSB)
	dataRecord[Byte#1] = **EventCode** – n:th latest successful event
	dataRecord[Byte#1] = AdditionalEventData – n:th latest event

	(MSB) …… dataRecord[Byte#3] = Time – n:th latest event (LSB)

Table - Diagnostic Event Type

Note:Generally speaking,both value of 'n' is 20.About the exact value,please discuss the with OEM.

Event Type - C00C_Secure Boot

987199 v3 **Event Type - C00C_Secure Boot**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "Secure Boot" data record with identifier 0xC00C. The event type is for Secure boot events.

Event Header: SecurityEventHeaderType 2 shall be applied, i.e. using two counters. Size 8+32+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - Secure Boot Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - Secure Boot Event Definition". Size 64 bits.

Event Code	Event	Additional Event Data
0xFF	No History reported	NA
0x01	Switch boot process fail	- Byte 1-6: ECU Version(Software PN Number) - Byte 7: Failure reason - Byte 8: 0xFF (reserved) Failure reason can be as follow: -0x00: Unspecified/unknown -0x01: Secure Environment API non-functional or data in Secure Environment was non-existent -0x02: Application SW failure
0x81	Boot process completion success	0xFFFFFFFFFFFFFFFF

Table - Secure Boot Event Definition

Access Control: Option (3) as defined in "REQPROD 369985 : Security Audit Log - Access Control" shall be applied

Event Type	Secure Boot Events
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**
	dataRecord [Byte#1] =**TotalNumberOfSuccessfulEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfSuccessfulEvents dataRecord [Byte#3] = TotalNumberOfSuccessfulEvents dataRecord [Byte#4] = TotalNumberOfSuccessfulEvents (LSB)
	dataRecord [Byte#1] = **TotalNumberOfRejectedEvents** (MSB)

	dataRecord [Byte#2] = TotalNumberOfRejectedEvents dataRecord [Byte#3] = TotalNumberOfRejectedEvents dataRecord [Byte#4] = TotalNumberOfRejectedEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest **successful** event (MSB) … … dataRecord[Byte#4] = **Time** – latest **successful** event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest successful event
	dataRecord[Byte#1] = **AdditionalEventData** – latest successful event (MSB) … … dataRecord[Byte#8] = **AdditionalEventData** – latest successful event (LSB)
Event Record#2 .. Event Record#n-1	…
Event Record#n	dataRecord[Byte#1] = **Time** – n:th latest successful event (MSB) … … dataRecord[Byte#4] = **Time** – n:th latest successful event (LSB)
	dataRecord[Byte#1] = **EventCode** – n:th latest successful event
	dataRecord[Byte#1] = **AdditionalEventData** – n:th latest successful event (MSB) … … dataRecord[Byte#8] = **AdditionalEventData** – n:th latest successful event (LSB)
Event Record#n+1	dataRecord[Byte#1] = **Time** – latest **failed** event (MSB) … … dataRecord[Byte#4] = **Time** – latest **failed** event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest **failed** event
	dataRecord[Byte#1] = **AdditionalEventData** – latest **failed** event (MSB) … … dataRecord[Byte#8] = **AdditionalEventData** –latest **failed** event (LSB)
Event Record#n+2 .. Event Record#n+m-1	…
Event Record#n+m	dataRecord[Byte#1] = **Time** – m:th **failed** event (MSB) … … dataRecord[Byte#4] = **Time** – m:th **failed** event (LSB)
	dataRecord[Byte#1] = **EventCode**– m:th latest **failed** event
	dataRecord[Byte#1] = **AdditionalEventData** – m:th latest **failed** event

	(MSB) … … dataRecord[Byte#8] = **AdditionalEventData** – m:th latest event (LSB) **failed**

Table - Secure Boot Event Type

Note:Gererally speaking,both value of 'n' and 'm' are 10.About the exact value,please discuss the with OEM.

Event Type - C00D_Firewall Events

987196 v3 **Event Type - C00D_Firewall Events**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "Firewall Events" data record with identifier 0xC00D. The event type is for some events which can be detected about Ethernet connection by firewall.

Event Header: SecurityEventHeaderType 1 shall be applied, i.e. using one counter. Size 8+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - Firewall Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - Firewall Event Definition". Size 48 bits.

Event Code	Event	Additional Event Data
0xFF	No History reported	NA
0x01	Receiving message (TR) buffer overrun of a specified threshold	- Byte 1: Event type - Byte 2-6: 0xFF FF FF ...(Reserved)
0x02	Firewall config update	- Byte 1-5: the version of firewall config (SW PN) - Byte 6:0xFF (Reserved)
0x03	TCP SYN Flooding	- Byte 1-4:IP Address - Byte 5-6:0xFF (Reserved)
0x04	Message flooding Note: UDP Flooding	- Byte 1-4:IP Address - Byte 5-6:0xFF (Reserved)
0x05	Out of white list	- Byte 1-4:source IP Address - Byte 5-6: Port number

Table - Firewall Event Definition

Access Control: Option (3) as defined in "REQ ID 369985 : Security Audit Log - Access Control" shall be applied

Event Type	Firewall
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**
	dataRecord [Byte#1] = **TotalNumberOfEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfEvents dataRecord [Byte#3] = TotalNumberOfEvents

	dataRecord [Byte#4] = TotalNumberOfEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest event (MSB) … … dataRecord[Byte#4] = **Time** – latest event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest event
	dataRecord[Byte#1] = **AdditionalEventData** – latest event (MSB) … … dataRecord[Byte#6] = **Time** – latest event (LSB)
Event Record#2 .. Event Record#n-1	… …
Event Record#n	dataRecord[Byte#1] = **Time** – n: th latest event (MSB) … … dataRecord[Byte#4] = **Time** – n: th latest event (LSB)
	dataRecord[Byte#1] = **EventCode** – n: th latest event
	dataRecord[Byte#1] = **AdditionalEventData** – n: th latest event (MSB) … … dataRecord[Byte#6] = **Time** – n: th latest event (LSB)

Table - Firewall Event Type

Note:Gererally speaking,both value of 'n' is 20.About the exact value,please discuss the with OEM.

Event Type - C00E_Key Management

987197 v3 **Event Type - C00E_Key Management**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "Key Management" data record with identifier 0xC00E. The event type is for events of Key management in ECU, including read out of key, read out of trust anchor, read out of messages or parameters in trust store, and key update, etc.

Event Header: SecurityEventHeaderType 1 shall be applied, i.e. using one counter. Size 8+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - Key Management Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - Key Management Event Definition". Size 16 bits.

Event Code	Event	Additional Event Data
0xFF	No History reported	NA
0x01	Read out of key	- Byte 1-2: 0xFFFF

0x02	Read out of trust anchor	- Byte 1-2: 0xFFFF
0x03	Read out trust store	- Byte 1-2: 0xFFFF
0x04	Key update	-Byte 1-2: DID or key type 0x01： private key 0x02： certificate
0x05	Key Read out	-Byte 1-2: DID
0x06	RPA key verification failure	-Byte 1: timestamp value verification failure -Byte 2: CMAC value verification failure

Table - Key Management Event Definition

Access Control: Option (3) as defined in "REQ ID 369985 : Security Audit Log - Access Control" shall be applied

Event Type	Key Management
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**
	dataRecord [Byte#1] = **TotalNumberOfEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfEvents dataRecord [Byte#3] = TotalNumberOfEvents dataRecord [Byte#4] = TotalNumberOfEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest event (MSB) … … dataRecord[Byte#4] = **Time** – latest event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest event
	dataRecord[Byte#1] = **AdditionalEventData** – latest event (MSB) … … dataRecord[Byte#2] = **AdditionalEventData** – latest event (LSB)
Event Record#2 .. Event Record#n-1	… …
Event Record#n	dataRecord[Byte#1] = **Time** – n: th latest event (MSB) … … dataRecord[Byte#4] = **Time** – n: th latest event (LSB)
	dataRecord[Byte#1] = **EventCode** – n: th latest event
	dataRecord[Byte#1] = **AdditionalEventData** – n: th latest event(MSB) … … dataRecord[Byte#2] = **AdditionalEventData** – n: th latest event (LSB)

Table - Key Management Event Type

Note:Gererally speaking,both value of 'n' is 20.About the exact value,please discuss the with OEM.

Event Type - C00F_System Access

987201 v3 **Event Type - C00F_System Access**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "System Access" data record with identifier 0xC00F. The event type is for important system events.

Event Header: SecurityEventHeaderType 1 shall be applied, i.e. using one counter. Size 8+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - System Access Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - System Access Event Definition". Size 32 bits.

Event Code	Event	Additional Event Data
0xFF	No History reported	NA
0x01	23 service (read memory by address)	- Byte 1-2: memoryAddress - Byte 3-4: memorySize - Byte 3: NRC (13/22/31/33...); - Byte 4: 0xFF(reserved)
0x02	system event	-Byte1:System password error more than 5 times -Byte2: local time（system time）deviation over 10 min -Byte3: Stack canary -Byte4: Watchdog times out Note: System events should be defined by supplier and agree with OEM. System events include but not limited to events as follows: Some general system events for reference: - Log in fail for more than five consecutive times - TRNG failed, demoted to PRNG. - Stack overflow detected - Watch dog timeout - System time adjust last more than 10 minutes - etc. Some Linux system events for reference: - root monitoring (Periodically check whether the root software exists in the file system. And whether system options such as ro.secure, ro.debuggable are tampered) - Kernel module loading and unloading

		(insmod and rmmod commands executed) - System file monitoring (Read/write operation monitoring of security-related files, such as /etc/passwd directory viewed by command like cat; Check whether abnormal files are added to the system service and automatically started in the /etc/init.d system service directory. - Process monitoring (systemctl start/stop/restart; Whether an application such as debugger is started) - Console input monitoring (save and upload console command input history to cloud, for example, use bash as a shell, save and upload.bash_history log file)

Table - System Access Event Definition

Access Control: Option (3) as defined in "REQ ID 369985 : Security Audit Log - Access Control" shall be applied

Event Type	System Access
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**
	dataRecord [Byte#1] = **TotalNumberOfEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfEvents dataRecord [Byte#3] = TotalNumberOfEvents dataRecord [Byte#4] = TotalNumberOfEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest event (MSB) … … dataRecord[Byte#4] = **Time** – latest event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest event
	dataRecord[Byte#1] = **AdditionalEventData** – latest event (MSB) … … dataRecord[Byte#4] = **AdditionalEventData** – latest event (LSB)
Event Record#2 .. Event Record#n-1	… …
Event Record#n	dataRecord[Byte#1] = **Time** – n: th latest event (MSB) … … dataRecord[Byte#4] = **Time** – n: th latest event (LSB)
	dataRecord[Byte#1] = **EventCode** – n: th latest event
	dataRecord[Byte#1] = **AdditionalEventData** – n: th latest event (MSB) … …

	dataRecord[Byte#4] = **AdditionalEventData** – n: th latest event (LSB)

Table - System Access Event Type

Note:Gererally speaking,both value of 'n' is 20.About the exact value,please discuss the with OEM.

Event Type - C012_OTA Events

987198 v3 **Event Type - C012_OTA Events**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "OTA Events" data record with identifier 0xC012. The event type is for events of OTA process.

Event Header: SecurityEventHeaderType 2 shall be applied, i.e. using two counters. Size 8+32+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - OTA Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - OTA Event Definition". Size 80 bits.

Event Code	Event	Additional Event Data
0xFF	No History reported	NA
0x01	SW Part Authentication failure	- Byte1-5:SW PN number - Byte6-7:Target ECU ID - Byte8-10: 0xFFFFFF
0x02	Package signature verification failure	- Byte1-8:Signature of current package (truncate first 8 bytes if length is longer than buffer) - Byte9-10:Target ECU ID
0x03	Certificate verification failed	-0x01 verify CA Trust Chain failure -0x02 OCSP CertStatus failure (not good)
0x81	OTA SW updated successfully	- Byte1-4:SW version; - Byte5-6:Target ECU ID; - Byte7-10:0xFFFFFFFF

Table - OTA Event Definition

Access Control: Option (3) as defined in "REQ ID 369985 : Security Audit Log - Access Control" shall be applied

Event Type	OTA
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**
	dataRecord [Byte#1] =**TotalNumberOfSuccessfulEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfSuccessfulEvents dataRecord [Byte#3] = TotalNumberOfSuccessfulEvents dataRecord [Byte#4] = TotalNumberOfSuccessfulEvents (LSB)
	dataRecord [Byte#1] = **TotalNumberOfRejectedEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfRejectedEvents dataRecord [Byte#3] = TotalNumberOfRejectedEvents

	dataRecord [Byte#4] = TotalNumberOfRejectedEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest **successful** event (MSB) … … dataRecord[Byte#4] = **Time** – latest **successful** event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest successful event
	dataRecord[Byte#1] = **AdditionalEventData** – latest successful event (MSB) … … dataRecord[Byte#10] = **AdditionalEventData** – latest successful event (LSB)
Event Record#2 .. Event Record#n-1	…
Event Record#n	dataRecord[Byte#1] = **Time** – n:th latest successful event (MSB) … … dataRecord[Byte#4] = **Time** – n:th latest successful event (LSB)
	dataRecord[Byte#1] = **EventCode** – n:th latest successful event
	dataRecord[Byte#1] = **AdditionalEventData** – n:th latest successful event (MSB) … … dataRecord[Byte#10] = **AdditionalEventData** – n:th latest successful event (LSB)
Event Record#n+1	dataRecord[Byte#1] = **Time** – latest **failed** event (MSB) … … dataRecord[Byte#4] = **Time** – latest **failed** event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest **failed** event
	dataRecord[Byte#1] = **AdditionalEventData** – latest **failed** event (MSB) … … dataRecord[Byte#10] = **AdditionalEventData** – latest **failed** event (LSB)
Event Record#n+2 .. Event Record#n+m-1	…
Event Record#n+m	dataRecord[Byte#1] = **Time** – m:th **failed** event (MSB) … … dataRecord[Byte#4] = **Time** – m:th **failed** event (LSB)
	dataRecord[Byte#1] = **EventCode**– m:th latest **failed** event
	dataRecord[Byte#1] = **AdditionalEventData** –m:th latest **failed** event (MSB)

	… … dataRecord[Byte#10] = **AdditionalEventData** –m:th latest **failed** event (LSB)

Table - OTA Event Type

Note:Gererally speaking,both value of 'n' and 'm' are 10.About the exact value,please discuss the with OEM.

Event Type - [Euro7]C09F_ SecOC Authenticated Freshness Value Verification Failure

1073238 v2 **Event Type - [Euro7]C09F_ SecOC Authenticated Freshness Value Verification Failure**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "SecOC Authenticated Freshness Value Verification Failure" data record with identifier 0xC09F. The event type is for events of SecOC FVM process.
The definition and format of DID shall be based on the format defined in SSDS.

Event Header: SecurityEventHeaderType 1 shall be applied, i.e. using one counter. Size 8+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - SecOC Authenticated Freshness Value Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - SecOC Authenticated Freshness Value Event Definition". Size 0 bits.

Event Code	Event	Additional Event Data
0xFF	No History reported	NA
0x01	Trigger Condition(s): SecOC Authenticated Freshness Value Verification Failure **Comments**:Start to record this SecOC events 2 seconds after ECU startup	NA

Table - SecOC Authenticated Freshness Value Verification Failure Event Definition

Access Control: Option (3) as defined in "REQ ID 369985 : Security Audit Log - Access Control" shall be applied

Event Type	Key Management
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**
	dataRecord [Byte#1] = **TotalNumberOfEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfEvents dataRecord [Byte#3] = TotalNumberOfEvents dataRecord [Byte#4] = TotalNumberOfEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest event (MSB) … … dataRecord[Byte#4] = **Time** – latest event (LSB)

	dataRecord[Byte#1] = **EventCode**– latest event
Event Record#2 .. Event Record#n-1	… …
Event Record#n	dataRecord[Byte#1] = **Time** – n: th latest event (MSB) … … dataRecord[Byte#4] = **Time** – n: th latest event (LSB)
	dataRecord[Byte#1] = **EventCode** – n: th latest event

Table - SecOC Authenticated Freshness Value Verification Failure Event Type

Note: Gererally speaking, both value of 'n' is 20.About the exact value,please discuss the with OEM.

Event Type - [Euro7]C0A0_SecOC PDU MAC Verification Failure Counter Exceeds Threshold Limit - Small

1073243 v2

Event Type - [Euro7]C0A0_SecOC PDU MAC Verification Failure Counter Exceeds Threshold Limit - Small

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "SecOC PDU MAC Verification Failure Exceeds Threshold Limit - Small " data record with identifier 0xC0A0. The event type is for events of SecOC PDU Verification process.
The definition and format of DID shall be based on the format defined in SSDS.

Event Header: SecurityEventHeaderType 1 shall be applied, i.e. using one counter. Size 8+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - SecOC Authenticated Freshness Value Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - SecOC Authenticated Freshness Value Event Definition". Size 0 bits.

Event Code	Event	Additional Event Data
0xFF	No History reported	NA
0x01	SecOC PDU MAC Verification Failure - Medium Trigger Condition(s): Log the event if counter value greater than 128; Only trigger once within one ignition cycle	NA

Table - SecOC PDU MAC Verification Failure Exceeds Threshold Limit - Small Event Definition

Access Control: Option (3) as defined in "REQ ID 369985 : Security Audit Log - Access Control" shall be applied

Event Type	Key Management
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**

	dataRecord [Byte#1] = **TotalNumberOfEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfEvents dataRecord [Byte#3] = TotalNumberOfEvents dataRecord [Byte#4] = TotalNumberOfEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest event (MSB) … … dataRecord[Byte#4] = **Time** – latest event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest event
Event Record#2 .. Event Record#n-1	… …
Event Record#n	dataRecord[Byte#1] = **Time** – n: th latest event (MSB) … … dataRecord[Byte#4] = **Time** – n: th latest event (LSB)
	dataRecord[Byte#1] = **EventCode** – n: th latest event

Table - SecOC PDU MAC Verification Failure Exceeds Threshold Limit - Small Event Type

Note: Gererally speaking, both value of 'n' is 20.About the exact value,please discuss the with OEM.

Event Type - [Euro7]C0A1_SecOC PDU MAC Verification Failure Counter Exceeds Threshold Limit - Medium

1073259 v2 **Event Type - [Euro7]C0A1_SecOC PDU MAC Verification Failure Counter Exceeds Threshold Limit - Medium**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "SecOC PDU MAC Verification Failure Exceeds Threshold Limit - Medium " data record with identifier 0xC0A1. The event type is for events of SecOC PDU Verification process.
The definition and format of DID shall be based on the format defined in SSDS.

Event Header: SecurityEventHeaderType 1 shall be applied, i.e. using one counter. Size 8+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - SecOC Authenticated Freshness Value Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - SecOC Authenticated Freshness Value Event Definition". Size 0 bits.

Event Code	Event	Additional Event Data
0xFF	No History reported	NA
0x01	SecOC PDU MAC Verification Failure - Medium Trigger Condition(s): Log the event if counter value greater than 1024; Only trigger once within one ignition cycle	NA

Table - SecOC PDU MAC Verification Failure Exceeds Threshold Limit - Medium Event Definition

Access Control: Option (3) as defined in "REQ ID 369985 : Security Audit Log - Access Control" shall be applied

Event Type	Key Management
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**
	dataRecord [Byte#1] = **TotalNumberOfEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfEvents dataRecord [Byte#3] = TotalNumberOfEvents dataRecord [Byte#4] = TotalNumberOfEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest event (MSB) … … dataRecord[Byte#4] = **Time** – latest event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest event
Event Record#2 .. Event Record#n-1	… …
Event Record#n	dataRecord[Byte#1] = **Time** – n: th latest event (MSB) … … dataRecord[Byte#4] = **Time** – n: th latest event (LSB)
	dataRecord[Byte#1] = **EventCode** – n: th latest event

Table - SecOC PDU MAC Verification Failure Exceeds Threshold Limit - Medium Event Type

Note: Gererally speaking, both value of 'n' is 20.About the exact value,please discuss the with OEM.

Event Type - [Euro7]C0A2_SecOC PDU MAC Verification Failure Counter Exceeds Threshold Limit - Large

1073389 v2 **Event Type - [Euro7]C0A2_SecOC PDU MAC Verification Failure Counter Exceeds Threshold Limit - Large**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

The ECU shall implement event type "SecOC PDU MAC Verification Failure Exceeds Threshold Limit - Large " data record with identifier 0xC0A2. The event type is for events of SecOC PDU Verification process.
The definition and format of DID shall be based on the format defined in SSDS.

Event Header: SecurityEventHeaderType 1 shall be applied, i.e. using one counter. Size 8+32 bits.
Event Records:
Time: Size 32 bits
EventCode: As defined in "Table - SecOC Authenticated Freshness Value Event Definition". Size 8 bits.
AdditionalEventData: As defined in "Table - SecOC Authenticated Freshness Value Event Definition". Size 0 bits.

Event Code	Event	Additional Event Data

0xFF	No History reported	NA
0x01	SecOC PDU MAC Verification Failure - Medium Trigger Condition(s): Log the event if counter value greater than 8192; Only trigger once within one ignition cycle	NA

Table - SecOC PDU MAC Verification Failure Exceeds Threshold Limit - Large Event Definition

Access Control: Option (3) as defined in "REQ ID 369985 : Security Audit Log - Access Control" shall be applied

Event Type	Key Management
Data Byte	**Description**
Event Header	dataRecord [Byte#1] =**Type**
	dataRecord [Byte#1] = **TotalNumberOfEvents** (MSB) dataRecord [Byte#2] = TotalNumberOfEvents dataRecord [Byte#3] = TotalNumberOfEvents dataRecord [Byte#4] = TotalNumberOfEvents (LSB)
Event Record#1	dataRecord[Byte#1] = **Time** – latest event (MSB) … … dataRecord[Byte#4] = **Time** – latest event (LSB)
	dataRecord[Byte#1] = **EventCode**– latest event
Event Record#2 .. Event Record#n-1	… …
Event Record#n	dataRecord[Byte#1] = **Time** – n: th latest event (MSB) … … dataRecord[Byte#4] = **Time** – n: th latest event (LSB)
	dataRecord[Byte#1] = **EventCode** – n: th latest event

Table - SecOC PDU MAC Verification Failure Exceeds Threshold Limit - Large Event Type

Note: Gererally speaking, both value of 'n' is 20.About the exact value,please discuss the with OEM.

4.1.8 20_Process Separation

Classical embedded and small systems are based on a single micro controller. The software is built solely to execute a specific task. There is no file system, because there is often no need to store anything. Some systems may have to keep track of a state. Sometimes it is necessary to continue a task from a specific point, where the execution for some reason was interrupted. This can be realized simply by writing a few bits to a non-volatile state memory.

The hardware is equally often kept simple, to reduce cost and complexity. Time, communication to external devices or interfaces to a source can all be designed for the specific system needs. The few bytes or kilobytes of memory are shared for everything the system shall do. If data are shared or shall be kept isolated is likely controlled on an agree bases among the software developers.
Immediately when a system have certain requirements to fulfil, a trusted time source, a secured

communication channel to an external device or tasks that needs to execute in parallel, the complexity for hardware and software often grows quite fast. There may be two or more tasks executed by the same system and they may have different requirements for real time properties, different needs for hardware resources or even different security or safety levels to fulfil.

Todays embedded systems spans all the way from a simple micro controller with just a few hundred bytes of memory up to large file system based computers with graphical user interfaces, network communication and even more. There are many different techniques to address all kind of problems that can occur in such different systems; here, only a few examples are rendered.
If a system is processing privacy data or high confidentiality data, one or many different techniques have to be used to make up a proper isolation in memory and or between processes as well. Process separation is mandatory for a system executing in different ASIL levels. In such a system it may also be necessary to restrict IO and other hardware resources, making them available only where they shall be used.
Trusted Execution Environment (TEE) is a technology where hardware and software can be used to put barriers and a strict separation between normal and sensitive, security related processes.

Memory protection
Memory protection is a way to control memory access rights, and is a part of most modern instruction set architectures and operating systems.
The main purpose of memory protection is to prevent a process from accessing memory that belongs to others. An attempt to access unowned memory results in a hardware
fault, (segmentation fault or storage violation exception).
Unallocated pages, and pages allocated to any other application, do not have any addresses from the application point of view.
The protection level of a particular implementation may be measured by how closely it adheres to the principle of minimum privilege.
For processors which need to run high-end operating systems (such as Android and Linux)， Memory management needs to be supported from the hardware, by a Memory Management Unit MMU or a PMMU Paged Memory Management Unit. For processors which need to run RTOS (such as RTA-OS and OSEK/VDX OS), Memory Protection system needs to be supported from the hardware, by a Memory Protection Unit.

An MMU effectively performs virtual memory management, handling at the same time memory protection, cache control, bus arbitration and, in simpler computer architectures bank switching.
But MPU is used for memory protection only.

Cryptographic Operations in Secure Environment

524497 v4 **Cryptographic Operations in Secure Environment**

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

Processes for cryptographical operations shall always be separated from normal execution by support from a Secure Environment.

General process separation

524501 v4 General process separation

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

For processors which need to run high-end operating systems (such as Android, Linux and QNX), Memory Management Unit (MMU) and/or Paged Memory Management Unit (PMMU) hardware shall be used in combination with software to manage general memory protection, cache control, bus arbitration and, in simpler computer architectures bank switching.

For processors which need to run RTOS (such as RTA-OS and OSEK/VDX OS), Memory Protection Unit (MPU) shall be used in memory protection.

Protected Memory Space

524502 v5 Protected Memory Space

Version history:
(5):

Purpose:
Verification Method: Analysis
Legacy ID:

1. Process isolation requirements for OS, such as SOC

Operating system(s) shall provide protected memory space(s) to applications that cannot be accessed by other applications. One application shall not be able to access another applications memory spaces.
An attempt to access unowned or unallocated memory shall always cause a segmentation fault or storage violation exception. The exception shall in turn be properly fetched, logged, and managed by the operating system or underlying software components.

Notes:
This requirement applies to both high-end operating systems (such as Android, Linux and QNX) and RTOS (such as RTA-OS and OSEK/VDX OS).

2. Process isolation requirements for AUTOSAR, such as MCU

It shall not be possible to execute from certain memory sectors intended for data and not instructions.

In order to mitigate code-injection attacks in executable memory segments, writing to executable memory

segments shall not be allowed, i.e. executable regions shall be read-only.

This to avoid arbitrary code being inserted elsewhere in the system memory.

4.1.9 21_Random Number Generator

In a security system, random number are often used to generate:
• Strong unpredictable cryptographic key data
• Initialization Vector, Salt, Padding in Cryptographic algorithms
• Nonces and Challenges in security protocols

The sequence of random numbers used for cryptographic purposes must not allow an adversary to learn or predict former or subsequent values, as security protocols depends on the strong entropy of the random numbers to ensure freshness and aliveness of messages, and in challenge-response protocols where both parties use the random numbers to demonstrate the knowledge of a pre-shared secret. This provides protection against replay attacks where an adversary saves old messages and replay them back to the system. Examples of cryptographic applications in the automotive context are:

Security Access
• Used to ensure freshness and liveness of the “Send Key” command to unlock diagnostic services.

TLS (Transport Layer Security)
• Setup secure communication to VCC Cloud services. Used to setup session keys and ensure freshness of messages.

SecOC
• Secure Communication between ECUs. Used to ensure freshness and liveness of each message.

Recommendations on Random Number Generation can be found in the NIST SP 800-90A - C documents or BSI documents “Application Notes and Interpretation of the Scheme” AIS 20 & AIS 31”.
In order to test the entropy of the random numbers, the ENT tool can be used.

Links:
NIST - SP 800-90A-C:
https://csrc.nist.gov/projects/random-bit-generation

BSI - AIS 20/31:
https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Zertifizierung/Interpretationen/AIS_31_Functionality_classes_for_random_number_generators_e.pdf?__blob=publicationFile

ENT tool:
https://www.fourmilab.ch/random

Superseding Previous Requirements

987359 v3 **Superseding Previous Requirements**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

The requirements in 21 Random Number Generation (this control) supersedes any other requirements related to the implementation of RNG specified in e.g., the BaseTech documentation.

In case of unclarities, the supplier shall contact the OEM for guidance.

4.1.9.1 DRBG - Deterministic Random Bit Generator

DRBG - Deterministic Random Bit Generator

520525 v5 **DRBG - Deterministic Random Bit Generator**

Version history:
(5):

Purpose:
Verification Method: Test
Legacy ID:

Random numbers shall be generated by a deterministic random bit generator (DRBG), also known as a cryptographically safe pseudo random number generator (CSPRNG) ~~or generated directly by a Hardware Random Number Generator (TRNG).~~

If a TRNG is not used, the random number generator used shall be one of the hash based or block cipher based generators approved by NIST, see SP 800-90A. That is Hash_DRBG, HMAC_DRBG or CTR_DRBG. The generator Dual_EC_DRBG must not be used.

Note:
If a TRNG is used directly, the solution must ensure that the hardware can generate random numbers in a fast-enough rate and with enough entropy for the applied use case. If it can't be ensured, a DRBG must be used.

DRBG-Seed Entropy for Deterministic Random Bit Generator

520527 v5 **DRBG-Seed Entropy for Deterministic Random Bit Generator**

Version history:
(5):

Purpose:
Verification Method: Test
Legacy ID:

The output from the entropy source used as a seed to the DRBG must be tested using the tool ENT. The entropy generated when tested with ENT MUST be:
- - Entropy: At least 7.5 bits per character or higher.
- - Compression: 0%
- - Chi-Square: Between 200 and 400 and randomly exceed more than 10% and less than 90% of the time.
- - Mean value: Between 126 and 128
- - Monte Carlo: Max 0.5% error
- - Serial correlation: 0.1 or lower

DRBG-Seed for Deterministic Random Bit Generator

520528 v5 **DRBG-Seed for Deterministic Random Bit Generator**

Version history:
(5):

Purpose:
Verification Method: Test
Legacy ID:

The Deterministic Random Bit Generator (DRBG) must be initially seeded and periodically reseeded with entropy provided by the entropy source.

The reseeding of the DRBG shall be performed in accordance with the most appropriate and recent revision of NIST, SP 800-90A for the used DRBG mechanism.

CTR-DRBG NIST, SP 800-90A for the used DRBG mechanism

The initial seed to the DRBG must not be static and shall be different after every reset.

DRBG-System Performance

987360 v3 **DRBG-System Performance**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

Since DRBG is cryptographically signed, the performance requirements for handling such function shall be provisioned in basetech related requirements.

4.1.9.2 TRNG - True Random Number Generator

TRNG - True Random Number Generator

987361 v3 **TRNG - True Random Number Generator**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

True Random Number Generator (TRNG), also called Non-Deterministic Random Bit Generator (NRBG), shall be used.

The Random Number Generator shall meet the standards as defined by NIST SP 800-90A documents.
NIST - SP 800-90A/B/C:https://csrc.nist.gov/projects/random-bit-generation.

Note:
NRBGs shall be constructed to include a DRBG (Deterministic Random Bit Generator) algorithm from SP 800-90A to provide a fallback capability if an entropy source is faulty.

The Random Number Generator shall meet the standards as defined by NIST SP 800-90A documents.
NIST - SP 800-90A/B/C:https://csrc.nist.gov/projects/random-bit-generation.

TRNG-Random number generator validation

520526 v7 **TRNG-Random number generator validation**

Version history:
(7):

Purpose:
Verification Method: Test
Legacy ID:

The output from the random number generator shall be tested with the tool Dieharder or NIST. When tested, no test shall fail independent of ECU mode (like after a reboot).

Repeatability: A 3-byte random number needs to be repeated at least 2,000 times, and a 16-byte random number needs to be repeated at least 10,000 times.
Randomness: At least 100,000 seed requests.

Test standard refer to NIST SP 800-22;

Links to Dieharder:
https://www.phy.duke.edu/~rgb/General/dieharder.php

Links to NIST:
https://csrc.nist.gov/projects/random-bit-generation/documentation-and-software
https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-22r1a.pdf

Links to GMSSL:
https://www.gmssl.cn/gmssl/index.jsp

4.1.10 22_Secure Debug

Hardware debug interfaces, such as serial ports and JTAG (Joint Test Action Group) interfaces are widely used during development and testing of embedded devices and is considered vital because of its powerful ability to access, modify and analyze the internal resources of the system such as the CPU, memory and peripherals during runtime.

This however also opens up an attack vector if it's not securely restricted and controlled after production. If an attacker manages to connect to an open JTAG port, it's fairly easy to circumvent all security mechanisms put on the device, such as secure boot, injecting malicious code, leaking of cryptographic keys and extracting OEM and supplier software intellectual property for reverse engineering potentially hurting the OEM’s competitive edge and opens up for third party actors, undercutting the OEMs market.

The most secure solution is to permanently disable the hardware debug interface, for instance by configuring an OTP (One-Time Programmable) memory before leaving production. This is however sometimes not feasible, because of the need of return field analysis of faulty devices. In certain ECU’s, there is also a need to be able to fetch real-time high resolution measurements in production devices for certification purposes. In these cases, UDS (Unified Diagnostic Services) or other propriety calibration and measurement protocols does not provide high enough bandwidth, so the debug interface will instead have to be used.

Another point of attack that also is important to protect against is debug functionality added by a supplier through normal communication channels, i.e. available at vehicle networks. This does not need physical access to the ECU and is a very convenient way for the supplier to add propriety protocols and services, used for diagnostics, debugging and flashing software. This is fine during development, but after production, it adds a big attack surface to the system and may be used as a springboard to utilize a scaled cybersecurity attack against the vehicle.

It is thus extremely important that both software debug functionality from regular communication channels and hardware debug interfaces are either disabled or protected by one of the Secure Debug concepts below after production.

Secure Debug Unlock Concepts

The following sections describes the different Secure Debug Unlock concepts that can be used to have a controlled and authenticated access to the hardware debug interface.

Password Unlock

Password Unlock is a solution which requires password authentication in order to enable the debug interface. Preferable, the authentication password is device unique in order to avoid scalable attacks and the password should be based on at least a 256 bit number if the platform supports it to counter brute force attacks.

If the correct password is written to a specific place in memory, often only available for the debug tool, the full functionality of the debug interface is unlocked. It’s important that the database holding the

passwords are protected with proper authenticated encryption.

Signed Unlock

Another solution to control access to the hardware debug interface is through a special commercially signed debug certificate. The debug certificate in question have been commercially signed and preferable locked to the target ECU's hardware device unique ID. This solution requires that Secure Boot supports the authentication of the debug certificate.

Security Access Unlock

A third option is to use generation 2 or higher of Security Access and UDS, to authenticate to the system in order to unlock the hardware debug interface. A specific DID (Diagnostic Identifier), can be implemented and offer the service for a client to unlock the hardware debug interface. The implementation must however make sure that the unlocking of the debug interface is not persistent through more than one reset or shutdown.

As Security Access functionality is available quite late in the boot process, in order to use a hardware debugger to analyze the boot stage prior to the Security Access functionality, one would need to implement a secure unlock of the hardware debug interface that is persistent through a single reset.

Challenge Unlock

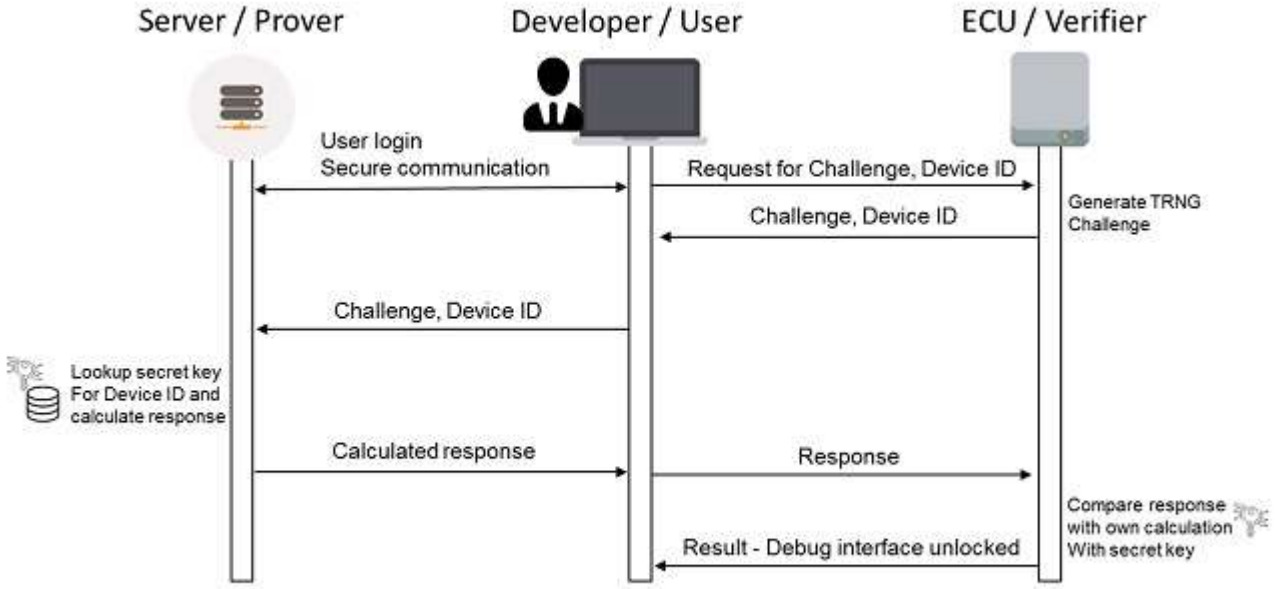
Another way to control access to the hardware debug interface is through a protection server mechanism with a challenge response protocol. With the help of a cryptographic secret key that is only known between the prover (client trying to unlock the debug interface) and the verifier (the target ECU), it is possible to make sure that only authorized users are able to unlock the hardware debug interface.

For the challenge seed value, the ECU uses a True Random Number Generator (TRNG) based number. Based on the challenge seed from the ECU, the debugging user can through a secure server use a cryptographic primitive and calculate a response value based on the secret key that has been pre-shared between the target ECU and a secure server during production. If the results of both parties' calculations are the same, it means that the user is trusted and the hardware debug connection can be unlocked.

This solution requires a key management infrastructure in place and that the user can authenticate itself to a server and create a secure session to it. The user client can then get hold of the computation response of the challenge from the server, which is passed to the target ECU. The cryptographic keys are stored in a secure server environment database which is encrypted and protected with a HSM (Hardware Security Module)

Based on the wanted level of protection, if symmetric keys are used, a KDF (Key Derivation Function) can be used instead in order to derive out the cryptographic keys which is used for the challenge response calculation. The input to the KDF would then be an ECU unique secret credential and propriety metadata information. This puts another level of protection in case the database with cryptographic keys have been sniffed or extracted during production provisioning. The attacker still need to know how to derive out the end keys used for the response calculation, as the cryptographic keys are never stored in the server or the target ECU.

It is also possible to use asymmetric cryptography to compute the challenge response instead of using symmetric cryptography. In the case of asymmetric cryptography, the server would sign the challenge value with its private key, in which the target ECU can verify with the servers public key. For this solution, it is important that the public key is protected with a HTA (Hardware Trust Anchor) in the ECU, and that the private key is handled in a highly secure offline environment in the server.



Disable Hardware Debug Interfaces

986037 v2 Disable Hardware Debug Interfaces

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

Hardware debug interfaces shall by default be permanently disabled after end-of-line (EOL) at supplier.

1) The connector needs to be removed. （Mandantary）
接插件需要被移除；（强制）
2) Solder joint protection: such as: scattering, applying adhesive, conformal coating, etc. (Recommended)
焊点保护：例如：打散、涂胶，三防漆等等（推荐）

Disable Software Interfaces for Non-Specified Software Services

986330 v4 Disable Software Interfaces for Non-Specified Software Services

Version history:
(4):

Purpose:
Verification Method: Test
Legacy ID:

1. All non-specified software functions shall be permanently disabled by the supplier by default after End-of-Life (EOL). Those retained upon approval must be kept in a locked state by default after End-of-Life (EOL).
2. For approved non-specified functions to be retained, the locking methods shall include, but are not limited to: password unlock, signature unlock, secure access unlock (e.g., UDS 27 service), or challenge-response unlock.
3. If a password or cryptographic key unlock mechanism is adopted, a strict "one device, one secret" scheme must be implemented, and the password strength must comply with OEM requirements.
4. Access to any diagnostic session, security access sub-function, Data Identifier (DID), or Routine Identifier (RID) not explicitly defined by the OEM in the SSDS is prohibited and shall be considered an unauthorized interface until unlocked.When accessed without being unlocked, the ECU shall return the appropriate NRC value in accordance with the ISO 14229 standard.
5.The access permission for any unlocked non-specified function shall be limited to the current ignition cycle; it must automatically revert to the locked state upon vehicle power-off or restart.
6.Suppliers must obtain prior approval from the OEM if retention of any non-specified software function is necessary, regardless of whether a locking mechanism is used.

1. 所有非指定软件功能在EOL后，默认应由供应商永久禁用；若经批准保留的，则必须处于锁定状态。
2. 经批准保留的非指定功能，其锁定方式应包括但不限于：密码解锁、签名解锁、安全访问解锁（如UDS 27服务）或挑战值-响应解锁。
3. 若采用密码或密钥解锁机制，必须严格执行“一设备一密”方案，并确保密码强度符合主机厂要求。
4. 任何非OEM在SSDS中明确定义的诊断会话、安全访问子功能、数据标识符（DID）及例程标识符（RID）均属未授权接口，在解锁前一律禁止访问。当未解锁就访问时，ECU需按照ISO14229规范返回合适的NRC值。
5. 任何已解锁的非指定功能，其访问权限的有效期须限制在当前点火周期内；车辆下电或重启后，必须自动恢复至锁定状态。
6. 供应商如确有必要保留任何非指定软件功能，无论是否采用锁定机制，都必须事先获得主机厂（OEM）的批准。

Note:
1. For details about password and password strength, please see requirements: Password Conformity
2. Non-specified software services include, but is not limited to, JTAG, XCP (etc), and all supplier specific debugging protocols and services not used or approved by the OEM, which could be used for diagnostics, debugging, flashing and executing software etc.

Network ports management（GB)

693230 v5 Network ports management（GB)

Version history:
(5):

Purpose:

Verification Method: Test
Legacy ID:

关闭非业务必要的网络端口，包括不限于：车载以太网、蜂窝网络、WLAN等通讯通道。根据实现的网络端口清单，明确业务场景使用的通道类型、工作/非工作条件、数据类型等，对于非业务必要的网络端口，进行关闭确认。供应商需提供开放端口白名单（白名单内容包括但不限于：功能场景、应用服务及协议、MAC、IP地址、访问端口），与OEM相关业务owner握手确认。确认后的文档提交ECU owner进行归档。

Close all non-essential network ports, including but not limited to: in-vehicle Ethernet, cellular networks, WLAN, and other communication channels. Based on the inventory of implemented network ports, specify the types of channels used in business scenarios, working/non-working conditions, data types, etc., and confirm the closure of non-essential network ports.

The supplier must provide a whitelist of open ports (the whitelist content includes but is not limited to: function scenarios, application services and protocols, MAC addresses, IP addresses, access ports), and confirm it with the relevant ECU owner of the OEM through a handshake agreement. The confirmed documentation should be submitted to the ECU owner for archiving.

PCB-BGA or LQFP Packaging

986039 v3 PCB-BGA or LQFP Packaging

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The integrated circuit packaging type shall be either BGA or LQFP.

Note: This is in order to make the component harder to physically tamper with.

PCB-Serial Interfaces

986040 v3 PCB-Serial Interfaces

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

If the component uses serial interfaces (e.g., xMI, XFI, SerDes) then the PCB shall be multi-layered and the serial interfaces shall be routed only in internal layers which are not exposed.

PCB-Test Points

986041 v3 PCB-Test Points

Version history:
(3):

Purpose:

Verification Method: Test
Legacy ID:

All test points on the ECU shall have been removed on production units upon leaving the suppliers EoL.

4.1.11 25_Secure Boot

4.1.11.1 Root of Trust

Secure Boot relies on the System-on-Chip (SoC) hardware support to provide the initial Root-of-Trust code and key. The Root-of-Trust key is used by the Root-of-Trust code to verify the first boot stage of signed software or signed key data, which in turn are used to verify the subsequent stages of software components. The key shall be provisioned to the hardware at production and stored in a protected memory.

Secure Boot Coverage

525168 v3 **Secure Boot Coverage**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The Secure Boot verification process must be executed as the very first step, forced by Read Only Memory (ROM) code, before any other software components are loaded and executed.

The Secure Boot shall cover the SW as specified below:

- A constraint and small embedded system, (sometimes referred to as address based), shall cover 100% of the software components within Secure Boot.
- A complex embedded system with separate file- and operating system images shall cover at least booting of primary boot loader and up till operating system image. Protection of large images and other assets may be handled by security mechanisms outside Secure Boot.

4.1.11.2 On-Chip Root-of-Trust Code

On-Chip Root-of-Trust code is the first piece of software bound to the microcontroller unit (MCU) hardware and executed when the MCU is powered on. It shall be contained in an internal, immutable memory (e.g. ROM or trusted internal flash which is locked) to ensure its trustworthiness. This immutable Root-of-Trust code shall be responsible for initiating the Chain-of-Trust by loading and verifying the next stage, first reprogrammable boot stage software. The verification is done by checking the integrity and authenticity of the software using the Root-of-Trust key.

On-Chip Root-of-Trust code

525169 v3 **On-Chip Root-of-Trust code**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

On-Chip Root-of-Trust code shall be executed when powering the component on.

Root-of-Trust Code

525170 v2 **Root-of-Trust Code**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Root-of-Trust Code shall be contained in an internal, immutable memory

Root-of-Trust code integrity protection

525171 v2 **Root-of-Trust code integrity protection**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The On-Chip Root-of-Trust code shall be locked to Read Only Memory (ROM) or similar immutable memory area.

4.1.11.3 Chain-of-Trust

This is established by the Root-of-Trust code. After a successful verification of the first boot stage by the Root-of-Trust code, the verified boot stage software can be executed and continue the verification and execution chain of the subsequent boot stages. Each boot stage shall verify the integrity and authenticity of the next stage before executing it.

Enforce Chain-of-Trust

525172 v3 **Enforce Chain-of-Trust**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

The chain-of-trust must be kept by enforcing and monitoring the booting sequence, it shall not be possible to jump over a boot stage.

Chain-of-Trust sequence (sequential)

525173 v4 Chain-of-Trust sequence (sequential)

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

- Secure Boot and the Chain-of-Trust is starting by a Root-of-Trust code, also referred to as Hardware Trust Anchor (HTA).
- The Root-of-Trust relies only on support from the hardware.
- The Root-of-Trust code is locked to Read Only Memory (ROM) or similar immutable memory area.
- The Root-of-Trust code will load and verify the first reprogrammable boot stage.
- After a successful verification by the Root-of-Trust code, the verified boot stage software can be executed and continue the loading and verification chain of the subsequent boot stages.
- Each boot stage shall verify the integrity and authenticity of the next stage before executing it.
- If the verification fails, actions on failure must be executed.

Action on failure

525174 v3 Action on failure

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

If the Secure Boot verification process for any reason fails the following actions shall be taken, as applicable and in order of prefered solutions (depending on functionality criticality and necessary functionality guarantees):

a. Execution shall be stopped and the system shall be halted.

b. Execution shall not be started, and if applicable the system shall avoid starting.

c. The system shall be reset and started in a "recovery mode" (see d and e).

d. Non-mandatory functionality shall be be disabled, if a minimum set of functions are to be guaranteed.

e. Secrets shall be disabled or deleted (e.g. keys, passwords etc).

Logging of Failures

987213 v2 Logging of Failures

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

In case the secure boot event fails it shall be logged. Access to logs shall only be granted to authorized entities (e.g. OEM approved developers via Security Audit Concept).

4.1.11.4 Secure Boot process

In a Secure Boot process, the trustworthiness of any verification key used to verify each boot stage software must be verified before it is used for the verification. The trust can be achieved either by having the key directly protected in OTP for asymmetric keys or protected in secure key storage for symmetric keys , or by verifying the key associated with a signature or MAC against a pre-trusted key (e.g. the Root-of-Trust key).

There are two different types of cryptographic methods used in Secure Boot: symmetric key and asymmetric key cryptography-based solution. Asymmetric key solution is typically used in high performance systems, while symmetric key is preferred in resource-constrained systems.

Minimum cryptographic support

525184 v4 **Minimum cryptographic support**

Version history:
(4):

Purpose:
Verification Method: Test
Legacy ID:

The minimum required cryptographic support shall be SHA-256 / RSA-3072 for asymmetric keys and AES-128 with crypto modes for Message Authentication Code (MAC) calculations for symmetric keys. Cipher-based Message Authentication Code (CMAC), shall be according to National Institute of Standards and Technology (NIST) special publication 800-38B.

4.1.11.5 Asymmetric key based solution

Asymmetric-Key Sign server

525185 v2 **Asymmetric-Key Sign server**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

A secure sign server and signing tool connected to a secure PKI environment shall be part of the Secure Boot solution to generate correctly signed software.

PKI Secure cryptographic operations

525186 v2 **PKI Secure cryptographic operations**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

PKI Secure cryptographic operations: Private and public key pairs shall be generated securely, i.e. within HSMs.

The private keys used for signing SW

525187 v2 **The private keys used for signing SW**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The private keys used for signing SW must be securely stored, protected from manipulation and unauthorized disclosure, i.e., within HSMs.

PKI Secure cryptographic operations

527401 v3 **PKI Secure cryptographic operations**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

PKI Secure cryptographic operations: The private keys used for signing SW must be used securely i.e. within HSMs.

Secure cryptographic operations

525188 v2 **Secure cryptographic operations**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Secure cryptographic operations: The signing services shall be protected from unauthorized access.

Root-of-Trust key provisioning

525190 v3 **Root-of-Trust key provisioning**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

The provisioning of the Root-of-Trust key shall be performed at EOL (End-of-Line) production in a trusted environment.

Note: The service, method or process to do the Root-of-Trust key provisioning shall be explicitly agreed with the OEM.

Asymmetric key

525191 v3 **Asymmetric key**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

The public key of asymmetric key shall be protected from unauthorized modification (integrity).

Hash of the asymmetric key

525192 v3 **Hash of the asymmetric key**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

Hash of the public key shall be protected from unauthorized modification (integrity).

Secure Boot [Asymmetric] key protection

525193 v3 **Secure Boot [Asymmetric] key protection**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

The Root-of-Trust key shall be protected and used according to“ Mandatory Root-of-Trust Public Key Protection. The other public keys not acting as Root-of-Trust must be verified against the Root-of-Trust key or be part of a verified boot chain prior to each usage for software verification.”

Secure Boot key revocation

525194 v3 **Secure Boot key revocation**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

In case of private key leakage key revocation shall be performed. Any root key revocation must be coordinated and agreed with OEM.

Note: In case of root private key leakage, root key revocation, if supported by hardware (HW), must be done and root key shall be changed to a new key.

But in case there is no HW support for root key revocation, new root key must be used for new-produced devices.

In case of SW signing private key leakage, it shall be revoked without HW root key revocation and shall be rolled-out with regular SW updates.

4.1.11.6 Symmetric-key-based solution

Symmetric key

525195 v2 **Symmetric key**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Symmetric key shall be kept secret and protected from unauthorized disclosure and modification (confidentiality and integrity).

Access to symmetric key

525196 v3 **Access to symmetric key**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

Access to symmetric key shall be limited within the secure environment.

[Symmetric] Root-of-Trust key provisioning

525197 v3 **[Symmetric] Root-of-Trust key provisioning**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

Secret keys used to generate or verify the SW MACs must be initialized and used only within the secure environment.

Symmetric keys

525198 v2 **Symmetric keys**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Symmetric keys shall be device-unique to minimize the risk of scalable attacks.

Secure Boot [Symmetric] key protection

525199 v2 **Secure Boot [Symmetric] key protection**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

All the keys used to generate and verify Message Authentication Codes (MACs) of the software shall be protected and used according to Req " Mandatory Confidential Key HW Protection".

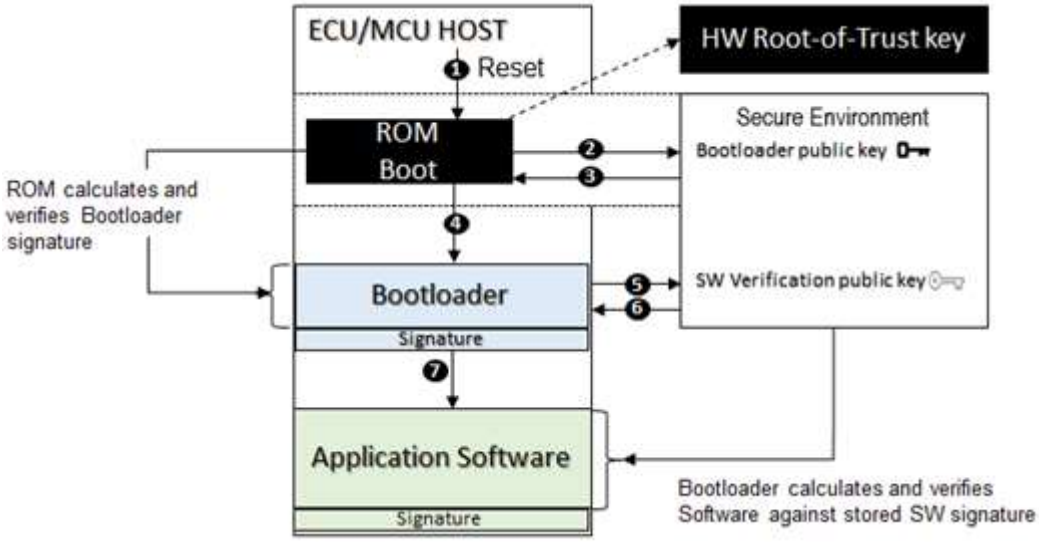
4.1.11.7 Secure Boot Flow – Asymmetric keys

Secure Boot Flow – Asymmetric keys

525200 v3 **Secure Boot Flow – Asymmetric keys**

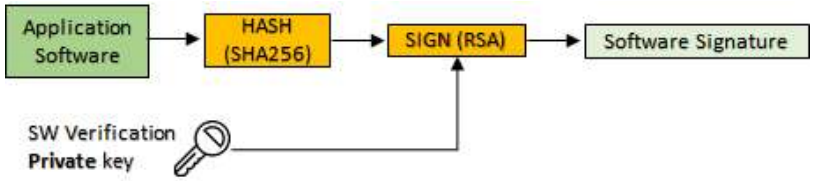
Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

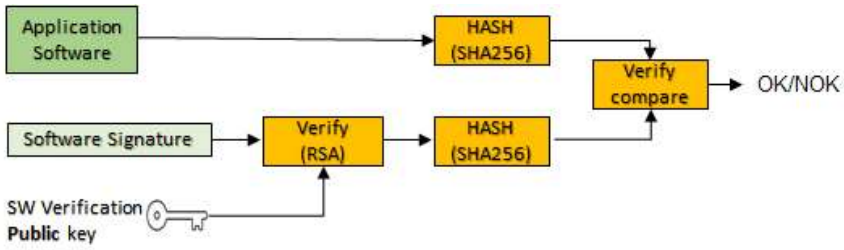


1. Execution starts from platform reset in a hardware trust anchor part that can be in the secure environment or in ROM code.
2. ROM code first verifies the bootloader public key against the HW Root-Of-Trust key and then use it to verify signature appended to the bootloader image.
3. Execution is either halted or continued depending on verification result.
4. Bootloader executes after successful verification.
5. Bootloader first verifies the SW verification public key and then uses it to verify signature appended to the Application software image.
6. Actions on failure such as stop execution or continued execution depending on verification result (see Chain-of-Trust requirements for details).
7. Execution passes on to application software.

Generation of signature



Verification of signature



Verification of a signature could be done inside the secure environment, but also in the REE (Rich Execution Environment), as the key used is public. The requirement is that the public key should be verified by either storing a hash over the public key in immutable storage such as OTP or that it's protected by a certificate chain that also anchors in an immutable storage.

The public key is used to verify the signature, which outputs a hash value. This hash value is then compared to the calculated hash over the application software. If these matches, the verification is successful.

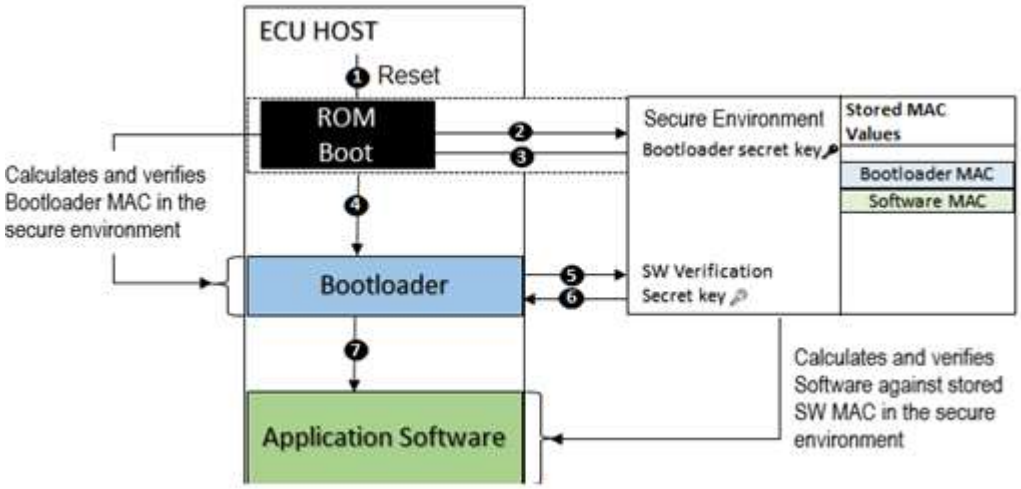
4.1.11.8 Secure Boot Flow – Symmetric keys using HSM

Secure Boot Flow – Symmetric keys in Secure Environment

525201 v4	Secure Boot Flow – Symmetric keys in Secure Environment

Version history:
(4):

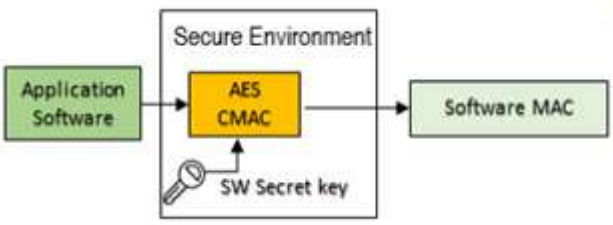
Purpose:
Verification Method: Analysis
Legacy ID:



1. Execution starts after a platform reset from a Root-of-Trust code that can be in the secure environment or in ROM code.
2. API call to the secure environment to use internal bootloader secret key to calculate MAC over bootloader image. Calculated MAC is then compared to the stored bootloader MAC value.
3. Execution is either halted or continued depending on verification result.
4. Bootloader executes after successful verification.
5. Bootloader calls the secure environment in order to use internal SW verification secret key to calculate MAC over Application software image. Calculated MAC is compared to the stored SW MAC value.
6. Execution is either halted (actions on failure) or continued depending on verification result (see Chain-of-Trust requirements for details).
7. Execution passes on to application software after successful verification.

Note: MAC can also be appended to the SW images, as long as the calculation and verification of the software image is done inside the secure environment.

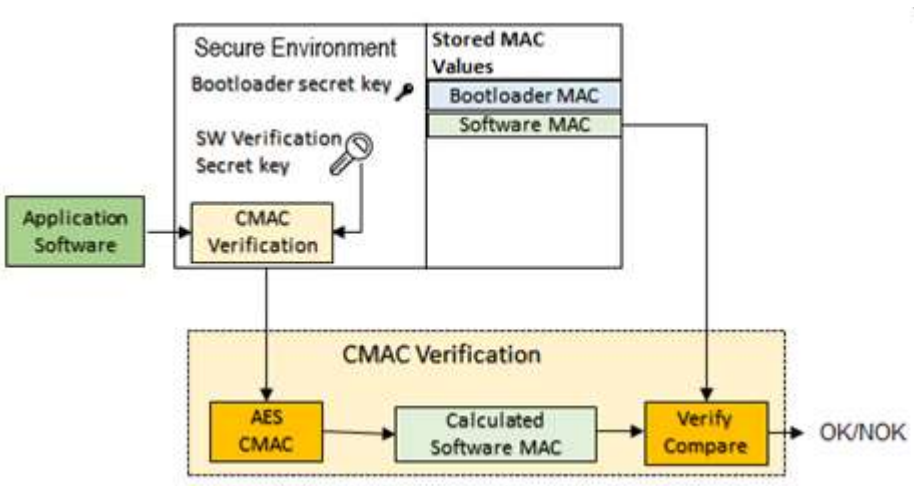
Generation of MAC



Generation of MAC is done in a secure environment with the SW verification secret key. In this example AES CMAC* is used. The secure environment could be in a TEE inside a HSM or in a secure production factory line. Often, security related metadata is also appended to the software which the CMAC is calculated over. In this case,

the verification process will also implicitly include this metadata in the calculation. **Note:** * AES CMAC – Advanced Encryption Standard Cipher-based Message Authentication Code

Verification of MAC



Verification of software MAC is done in the secure environment where the SW verification secret key is used together with the application software as input to AES CMAC, which generates a software MAC. This is then compared to the software MAC stored in the secure environment.

4.1.11.9 Initialization and activation requirements

Secure Boot activation

525202 v2 **Secure Boot activation**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Secure Boot mechanism shall be supported and activated through the entire System-on-Chip (SoC) lifecycle.

Secure Boot design validation

525203 v2 **Secure Boot design validation**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The specific Secure Boot implementation shall be documented, reviewed, and approved by OEM.

Secure Boot initialization

525204 v3 **Secure Boot initialization**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

The initial state of Secure Boot, where the commercial key for Secure Boot verification is not yet provisioned to the ECU, software shall be verified towards a development key, stored in Read Only Memory (ROM) or a similar immutable memory area. Any development keys shall be removed from production units before the release.

Secure Boot from optional media

525205 v2 **Secure Boot from optional media**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

A system which can be booted from optional media must perform the same Secure Boot actions and signature verifications and act accordingly as described in other Secure Boot related requirements.

4.1.12 26_HSM

The purpose of Hardware Security is to provide an ECU with a higher level of security which can't be realized with software alone.

An ECU in itself is not considered secure enough to protect security critical assets such as cryptographic keys and sensitive code execution.

And in some cases, the ECU have been built to solely execute a specific task, and don't have the extra capability to execute computationally intensive software, such as cryptographic operations.

In such cases, it is suitable to utilize a separate dedicated cryptographic block that has been designed and optimized to perform a specific cryptographic operation in an accelerated way.

With the help of a dedicated cryptographic accelerator, it will also be possible to offload the main ECU

CPU for its main task, and significantly increases cryptographic throughput for encryption, decryption, signing and authentication.

Key areas that can be realized and performed significantly faster and more secure are:
• Secure Boot (accelerated authentication of signature/message authentication code (MAC))
• Secure Download (accelerated authentication of signature/message authentication code (MAC))
• Secure communication (accelerated encryption and decryption of data)
• Security Access (accelerated authentication of MAC and use of hardware random number generator*)

At the same time, hardware security also provides tamper-resistant microprocessors to store and process sensitive information, and makes the hardware less vulnerable to key leakage, timing attacks and side channel attacks.

To prevent an attacker from retrieving or modifying data, the chips are designed so that the information is not accessible through external means and can only be accessed through a well-defined API by the embedded software.

Mandatory Confidential Key HW Protection

525137 v2 **Mandatory Confidential Key HW Protection**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

A hardware enforced Trusted Execution Environment (TEE) must be supported.

TEE must be used to protect confidential keys and operations.

Hardware protection for vehicle terminal(GB/T 32960)

987521 v2 **Hardware protection for vehicle terminal(GB/T 32960)**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

车载终端应配备具备硬件安全保护机制的汽车芯片。汽车芯片应满足以下要求：

——具备一个唯一的芯片标识ID（简称：芯片ID）。芯片ID由四位芯片型号标识符和车辆生产企业自定义的最多十二位字符组成；
——应存储芯片ID和密钥。芯片ID和公钥可以读取，私钥不可读不可改；
——安全等级应满足GM/T0008安全等级2级要求或产品安全保证级别不低于EAL4+级要求或者满足汽车芯片信息安全国家标准或行业标准要求；

Vehicle terminals should be equipped with automotive chips that have hardware security protection mechanisms. Automotive chips should meet the following requirements:
——Having a unique chip identification ID (referred to as chip ID). The chip ID consists of a four digit chip model identifier and the vehicle manufacturing enterprise Customized up to twelve characters;
——The chip ID and key should be stored. The chip ID and public key can be read, while the private key cannot be read or modified;
——The security level should meet the requirements of GM/T0008 security level 2 or the product security assurance level should not be lower than EAL4+ or meet the requirements of national or industry standards for automotive chip information security;

Physical Tampering Attacks Recognition

1029206 v2 Physical Tampering Attacks Recognition

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

External ECUs with direct wireless communication should be equipped with security mechanisms to protect against physical tampering attacks.
Detection and identification mechanisms, including function limitation and alerts, must take effect immediately upon occurrence of a physical tampering attack.

Clause 7.2.7 in GB44495 is covered by the S-679-01 Physical Component Replacement Identification function.

外部直接无线通信的ECU应配备安全机制来防范物理篡改攻击。
检测识别机制包括限制功能、报警等，但需要在物理篡改攻击发生后立即生效。

GB44495中的7.2.7条款通过 **S-679-01** 物理换件识别功能覆盖；

Light EVITA Compliance

986382 v2 Light EVITA Compliance

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The component HSM should be EVITA Light compliant if possible.

However, all necessary algorithm accelerators, as needed to fulfill functional requirements (e.g., UDS) without unacceptable time delays (as specified in e.g., signal databases or other requirements), shall be present.

TRNG is not necessary, and cryptographic keys may be handled in read/write protected RAM by the application processor.

SW Based Solution

986383 v3 SW Based Solution

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

If ECU does NOT support HSM hardware security module, software based security solution should be implemented for the Secure Environment.

Software based security solution does not have to fulfill e.g., EVITA Medium or Full.

Disable Hardware Debug Interfaces to HSM

986362 v2 Disable Hardware Debug Interfaces to HSM

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

Only applicable for ECUs with Hardware Security Modules (HSM).
Hardware debug interface to a Hardware Security Module shall by default be permanently disabled.

Full EVITA Compliant

986364 v2 Full EVITA Compliant

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The HSM shall be Full EVITA compliant.

HSM Support

986366 v2 HSM Support

Version history:
(2):

Purpose:

Verification Method: Analysis
Legacy ID:

A Hardware Security Module (HSM) shall be supported.

Resistant to Side Channel Analysis

986367 v2 **Resistant to Side Channel Analysis**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The Hardware Security Module (HSM) shall be resistant to side channel analysis.

Interface to Secure Environment cryptographic operations

986377 v2 **Interface to Secure Environment cryptographic operations**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The hardware enforced Secure Environment must provide an application program interface (API) to cryptographic operations that can be used by software outside of it.

Notes:
Cryptographic algorithms that must be supported in the hardware enforced Secure Environment are based on the use case for the ECU.

Mandatory Root-of-Trust Public Key Protection

986378 v2 **Mandatory Root-of-Trust Public Key Protection**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Immutable storage or similar technology must be supported.

Public keys acting as a Root of Trust must be protected (see Key Management for details).

Note:
Immutable storage could be OTP (One Time Programmable) memory, sections of flash storage that can be locked during normal use or Secure Environment.

Secure Environment

986379 v2 **Secure Environment**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Asymmetric and Symmetric key-based solutions must be supported by the Secure Environment.

The Secure Environment must be physically or logically isolated from all applications outside of the Secure Environment. Specifically, cryptographic operations along with confidential keys must not be exposed outside of the Secure Environment. All code and data loaded inside the Secure Environment must be integrity protected.

Notes:
A hardware enforced Secure Environment is a general term used to realize hardware security and is usually a dedicated hardware or a logically isolated secure environment, providing crypto functions and handling cryptographic keys along with sensitive security operations. Commonly implemented and referred as

• Trusted Execution Environment (TEE)
• Hardware Security Module (HSM)
• Secure Hardware Extension (SHE)
• Secure Element (SE)
• Trusted Platform Module (TPM)

or any other vendor specific secure environments.

4.1.13 29_Enhanced System Hardening for MCU

Ensure code quality - compiler warnings handling

525158 v3 **Ensure code quality - compiler warnings handling**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

All software shall be built/compiled with warnings treated as errors.

The supplier guarantees no Waring in their own code, the third party code can deviate.
If not accepted, there may be deviations, provide compilation report to OEM review.

Note:
For example, this can be enabled in Clang/Gcc compiler with the flag -Werror.

Ensure code quality - static code analysis

525159 v3 Ensure code quality - static code analysis

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

All source code shall be scanned by a static code analyzer capable of finding common coding errors and in-memory vulnerabilities.
This is to minimize the risk of exposing an in-memory vulnerability that can violate the runtime integrity.
Refer to MISRA C or CERT C coding standards;

No execute memory

525161 v2 No execute memory

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

If supported by hardware, the system shall mark non code segment as non-executable.
This to avoid arbitrary code being inserted elsewhere in the system memory.

Read-only executable memory

525163 v2 Read-only executable memory

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

In order to mitigate code-injection attacks in executable memory segments, writing to executable memory segments shall not be allowed, i.e. executable regions shall be read-only.

Stack protection

525165 v2 **Stack protection**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

The program stack shall be protected against overflow attacks that may alter its data. As for example providing a mechanism such as canary insertion or local data bounds checks.

It is mandatory that the stack protection feature is turned on. It shall terminate the process and log the event when a memory overwrite is detected.

Note:
For example, GNU Compiler Collection (GCC) supports the stack protection with compiler flags: -fstack-protector, -fstack-protectorall, -fstack-protector, -fstack-protectorstrong, -fstack-protectorexplicit.

4.1.14 29_System Hardening for MCU

Follow industry accepted processes

524499 v2 **Follow industry accepted processes**

Version history:
(2):

Purpose:
Verification Method: Analysis
Legacy ID:

Industry-accepted system hardening activities shall be executed according to the Cybersecurity Processes defined in the Cybersecurity - Statement of Work (CS-SOW) and its references.

A security review of all used open source and commercial software shall be performed in conjunction with a release. If vulnerabilities are found in common vulnerability databases, the software shall be upgraded or patched to obstruct vulnerabilities by the supplier and documented for the OEM. As a bare minimum, the Common Vulnerabilities and Exposures (CVE) database shall be scanned/checked against.

Supplier shall provide architecture design and documentation, which provides a summary of applied system hardening methods, techniques and standards to present the case that the system is hardened against possible threats.

Note:
CS-SOW is included in the Engineering Statement of Work (ESOW). Notable reference in the CS-SOW is the ISO/SAE 21434 - Road Vehicles Cybersecurity Engineering and Draft Recommendation on Cyber Security of the Task Force on Cyber Security and Over-the-air issues of UNECE WP.29 IWG ITS/AD. Please see section Supplier responsibilities in the CS-SOW for the full list.

It is the responsibility of the supplier to ensure that the latest versions of the documents listed in this section are used.

CVE database - https://cve.mitre.org/cve/

Log recording of vehicle remote control（GB)

851903 v3 Log recording of vehicle remote control（GB)

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

控制器执行远程控制指令，需向云端反馈执行结果，若无法反馈，则控制器应具备记录远程控制指令的安全日志功能；
a)安全日志数据格式应至少包括：远程控制指令的时间、发送主体、远程控制对象、操作结果；
b)安全日志保存时间不少于6个月。

When the controller executes a remote control command, it is required to feedback the execution result to the cloud（backend）. If it is unable to provide feedback, the controller should have the capability to record security logs for remote control commands.
a) The security log data format should include at least: the time of the remote control command, the sender, the target of the remote control, and the outcome of the operation.
b) Security logs must be retained for no less than six months.

远程控制指令要点解释：
Explanation of Key Points for Remote Control Instructions:

序号 Serial number	要点 Key points	要点解释 Key points explanation
1	远程控制指令的安全日志 Security log of remote control instructions	指的是车辆执行远控指令（ 如开启空调、 启动车辆、 车门解闭锁等） 记录的安全日志 Refers to the execution of remote control commands by the vehicle, such as turning on the air conditioning, starting the vehicle, and lock/unlock the doors

Key Communication Information Security Event Logging Requirements(GB)

851907 v2 Key Communication Information Security Event Logging Requirements(GB)

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

关键的通信信息安全事件日志要求：

1、关键的通信信息安全事件：
1.1 建立通讯连接的身份校验失败事件与非法访问事件
1）车端与外界建立通讯连接发生的身份验证失败：身份认证失败事件和非授权的访问事件（包括非白名单及密码错误访问事件）；
2）通信信息校验失败事件（包括通信信息的完整性、有效性或唯一性的校验）；
1.2 建立通讯连接后，相关功能执行控制器反馈的失败事件
执行控制器接收到相关指令后无法正常执行，则需记录事件日志，反馈云端或进行本地存储；
2、日志存储要求：
a)日志数据格式应至少包括：事件时间、事件原因；
b)日志保存时间不少于6个月。

Key Communication Information Security Event Logging Requirements:

1、Key Communication Information Security Events:
1.1 Identity verification failure events and illegal access events during the establishment of communication connections:

1）Identity verification failure events and unauthorized access events (including access events from non-whitelisted sources and password incorrect access events) when the vehicle establishes a communication connection with the outside world;
2）Communication information verification failure events (including verification of the integrity, validity or uniqueness of the communication information);

1.2 Failure events of the execution controller after the establishment of communication connections:
If the execution controller is unable to perform normally after receiving related instructions, an event log must be recorded, which should be fed back to the cloud（backeend） or stored locally;

2、Log Storage Requirements:
a) The log data format should include at least: event time, event reason;
b) Logs must be retained for no less than six months.

Secure communication information log should cover follow requirement at least:
1.Cloud TLS Authentication faild.
2.Security Channel Establishment Verification faild(WIF\BLE\Classic Bluetooth).
3.Data operation instruction access control (WIF\BLE\classic Bluetooth, including NFC and RFID)
4.Key instruction effectiveness and uniqueness validate(WIF\BLE\Classic Bluetooth, including NFC and RFID);
5.Sensitive personal information transmission outside the vehicle
6.Physical replacement inspection (ECU with Bluetooth, WIFI, and cellular function)
7.The login or access of privileged users (root user)
8.Internal network isolation (for each domain controller)rules of change
9.DOS attack (WIFI and OBD)
10.Malicious diagnostic request.

Product vulnerability handling policy(GB)

693227 v3 **Product vulnerability handling policy(GB)**

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

车端具备远程控制功能或软件更新的系统、授权的第三方应用等外部连接系统交付时不应存在由权威漏洞平台6个

月前公布且未经处置的高危及以上的安全漏洞。
注：1.处置包括消除漏洞、制定减缓措施等方式;2.权威漏洞平台如CVE/CAVD/CNNVD/CNVD等
Systems with remote control functions or software updates at the end of the vehicle, authorized third-party applications and other external connected systems should not have security vulnerabilities above high risk that were announced by the authoritative vulnerability platform six months ago and have not been dealt with.
Note: 1.Disposal includes eliminating vulnerabilities and making mitigation measures. 2. Authoritative vulnerability platforms such as CVE/CAVD/CNNVD/CNVD etc..
Vehicle software upgrade system

4.1.15 39_Rate Limitation

	Throttling

985897 v2	**Throttling**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

All (expected) received input to the component shall be rate limited, or throttled, to the lowest potential cadence of the input that the source of it could legitimately generate.

Example: A periodic message with a periodicity of 5ms should be rate limited at ~4ms (some leeway).
Example: A given event based message may only naturally be possible to be sent from the source every 5ms (due to e.g. sensor hardware limitations or similar), in such cases the message should be rate limited at ~4ms (allowing for some leeway).

4.1.16 40_Input Validation

	Input Sanitization

985898 v2	**Input Sanitization**

Version history:
(2):

Purpose:
Verification Method: Test
Legacy ID:

All external input or communication from other components or sub-components shall be sanitized before any further use. If any deviations are found and the message is not strictly following the specification of the expected protocol it shall be discarded before further processing can be performed.

Note: This implies that input sanitization shall be applied on communication between different OSes, processes or otherwise different software modules, and also when receiving input from e.g. a CAN bus.

4.1.17 46_[DP]Personal Data Handling in ECUs

Personal user data shall be protected by design by the following aspects:

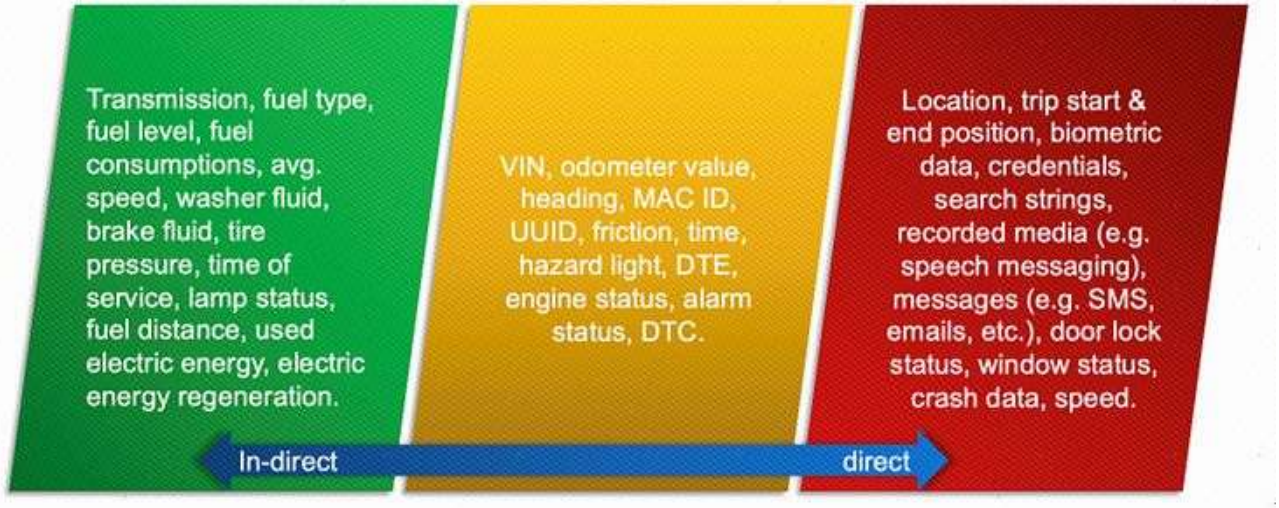
a. Secure access control and storage of Personal Data in the vehicle, i.e. it shall be protected from vehicle external access.
b. Secure transmission between on-board to authorized off-board systems.
c. Secure storage in authorized off-board systems.
d. Off-board usage of Personal Data only according to a defined legal ground (e.g. User consent)
e. Removal of all personal user data upon request of authorized on-board as well as off-board systems.

The following definitions provides information on a general level on how to identify Personal Data and what rules are applicable to it.

1. Definitions

a. Personal Data as stated in GDPR: *"Any information relating to an identified or identifiable natural person ('Data Subject'); an identifiable person is one who can be identified, directly or indirectly, in particular by reference to an identification number or to one or more factors specific to his physical, physiological, mental, economic, cultural or social identity"*
b. Personal Data for OEM: *"Any data that are generated by the vehicle system component (e.g. ECU) with the possibility to identify the user/driver/passengers"*
c. Elaboration: All data in the vehicle that are classified as Personal Data; can be differentiated into a direct and indirect Personal data.

2. Example of direct and indirect Personal Data collected, processed, and stored in OEM vehicles:



a. The green box where most of the data are indirect Personal Data, are safe to be collected, processed, and stored in the ECU.
b. The yellow box is also indirect Personal Data, but it has a potential to provide a direct information of the data subject (driver). There shall be a purpose to collect, process, and store the data in the ECU.

c. The red box is direct Personal Data, to collect, process, and store any of these data, it shall follow the privacy principles.

Classification 1	Classification 2	Grading	
		General Personal Data	Sensitive Personal Data
Personal device information	*Unique device identifiers*	***VIN**, SN, IMEI/MEID, DEVICE_ID, **IMSI/ICCID/MSISDN** in SIM card, (LAN/WLAN/BT/4G/5G/...)**MAC**, **UID/UUID/GUID**, **ANDROID_ID(SSAID)/AAID/GAID/OAID** for Android, UDID/IDFA/IDFV/OpenUDID for iOS, IP Address, etc*	
	Device critical data		*Account and password in JDBC, **OSS Server's account and password**, **Other Server's account and password**, **Device password(System login password, Unlock pattern, UART/JTAG/SSH/FTP login password, etc.),** **Symmetric key**, **Private key of asymmetric key(e.g. PEM)**, **PKCS #12 certificates,** /etc/shadow file*
	Device operating data		***ramdump, coredump***
Biometric data	*Biometric data*		***facial recognition patterns**, **voice recognition patterns**, iris or retina patterns, fingerprints, hand geometry, DNA, signature(the distinctive way a person writes their name), gait(the way a person walks), earlobe geometry, eye patterns*
Audio and Video Recordings	*Cockpit data*		***data collected from the dashcam(video/images and audio), data collected in sentinel mode(video/images and audio), data collected by various cameras(video/images), data collected by MIC(audio), data imported from other devices(video/images and audio).***
Location	*Rough location*		*country, region, province, city,altitude*
	Precise location		***longitude and latitude**(from GPS, Wifi, BT, Cellular, 3rd SDK), Location data obtained through Android's ACCESS_FINE_LOCATION and ACCESS_COARSE_LOCATION permissions. **Driving trajectory**, Travel Itineraries, Travel Records, Route planning, Location history*
Interactive data through HMI(APP)	*Basic Information*	*Names, Date of Birth, Ages, Gender, Ethnic, Nationality, Native place, Marital Status, Family Information, Hobbies and Interests, Nickname, Personal signature, Physical Characteristics (Height and Weight, Eye Colour, etc), etc*	
	Contact Information	*Home Address, Email Address, Work Address, Phone Number, Personal Website URL, etc*	*Emergency Contacts, Friends Contacts(include Bluetooth), etc*
	Communication Records		*Text Messages, Email Correspondence, Call Logs(include Bluetooth), Voice Mails, Social Media Messages, etc*
	Education History	*Academic Transcripts, Diplomas and Certificates, Standardised Test Scores, etc*	
	Employment Records	*Job Title, Employment History, Performance Reviews, Professional Licences, etc*	*Salary Information, etc*
	Identification Numbers		*National Identification Number, Passport Number, Social Security Number, Employee ID, Driver License, Residence permit, etc*
	Financial Information		*Bank Account Number, **Authentication information (password)**, etc*

	Device information		***License Plate**, Engine Number, **Device Name**, **BT Device Name**, **SSID** of Wifi, etc*
	Health Information		*Medical History, Prescription Information, Blood Type, Immunisation Records, Allergy Information, etc*
	Online Behaviour	*APP usage records, Recreational Interests, Likes and Reactions, Tweets and Retweets, Comments, Consumer Preferences, etc*	*Cookies, Token, Online Purchase Records, Browser History, Download History, etc*
	Audio and Video Recordings		*Voicemails, Video Messages, Surveillance Footage, Podcast Appearances, Personal Videos/Images/Audios which were imported from personal devices(such as phone, PC),etc*
	Other		*Religious Beliefs, Political Affiliations, Sexual Orientation, Legal Records, Membership and Affiliations, Psychological Traits, Behavioral Patterns,Social Connections,Personal Beliefs,Minor's information, etc*
data revealing criminal offenses or other infractions			*e.g., data indicating that the vehicle crossed a white line, the instantaneous speed of a vehicle combined with precise location data*

3. If the data collection, processing, and storing are based on legal regulations:

a. OEM shall be able to proof that the data collection is based on a legal regulation(s) (e.g. EU directive/regulations & local regulations).
b. OEM should be able to present the proof in its support webpage.

4. If the ECU with stored Personal Data are to be sent to the supplier due to hardware or software issues:

a. Ensure to inform the supplier that there are Personal Data stored in its memory.
b. Review the purchasing contract with the supplier, do they have an awareness and follow EU GDPR regulations.
c. Make sure the supplier has sign a Data Protection Agreement (DPA) with VCC.

5. If the ECU performs a "machine learning" tasks where the purpose is to produce a subject profiling, and uses direct Personal data (data in the red box) and the following sensitive Personal Data:

a. Racial or ethnic origin
b. Political opinions
c. Religious or philosophical beliefs
d. Membership of a trade union
e. Health
f. A person's sex life or sexual orientation
g. Genetic data
h. Biometric data that uniquely identifies a person (ex. fingerprint, facial recognition, iris scan, heartbeat…)
i. Criminal records

These machine learning data shall:

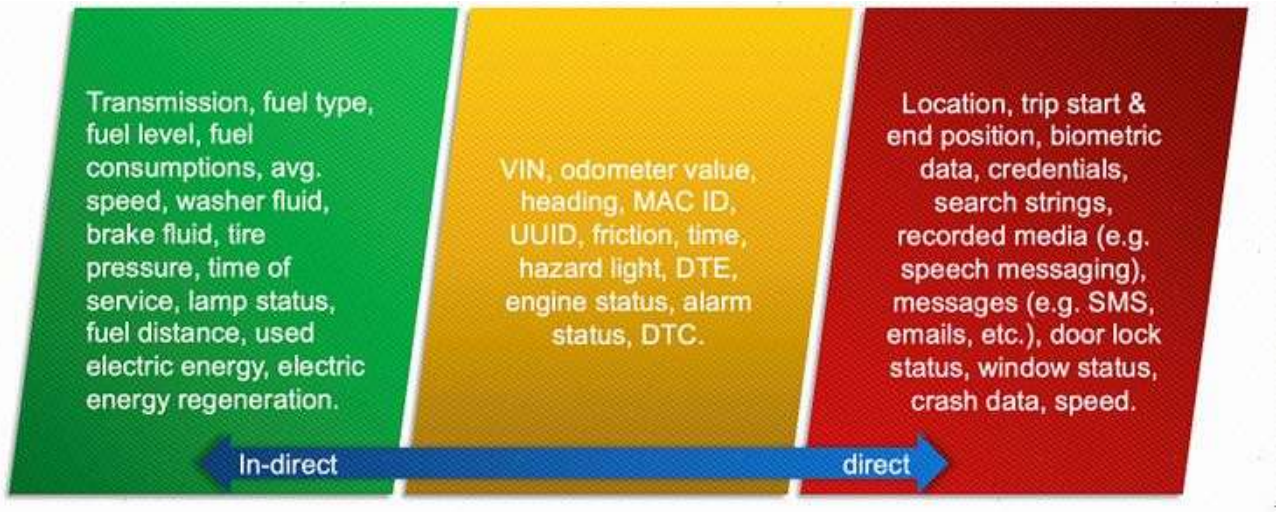
j. Not be transferable in its raw format
k.Encrypted when it's in raw format
l. Erasable by ensuring re-constructible of data is minimum

The Vehicle Data is a Customer's Personal Data. Data processing includes collection, access, store, alteration, transmit, disclosure, encryption, anonymization, Pseudonymization, and destruction during the data lifecycle. Data processing is lawful when it is performed according to valid purpose and legal basis.

The customer's Personal Data is defined as any information relating to (directly or indirectly) an identified or identifiable natural person. This includes any information that can be connected to the customer's vehicle for example VIN or any other identification of the vehicle described in the above picture.

ECU中个人数据处理要求
用户个人数据应从以下几个方面进行设计保护：
a.应采取安全访问、安全加密等方式保障系统中存储的个人信息安全；
b.车载系统应与云端进行安全传输。
c.在已授权的车外系统中安全存储。
d.仅在具备明确法律依据（例如用户同意）的情况下，方可进行车外使用个人数据。
e.在收到经授权的车内系统及车外系统的删除数据的请求后，删除所有个人用户数据。

以下定义从一般层面说明了如何识别个人数据以及适用于个人数据的规则
1. 定义
a. 《通用数据保护条例》（GDPR）中所述的个人数据："与已识别或可识别的自然人（'数据主体'）相关的任何信息；可识别的人是指能够直接或间接被识别的人，特别是通过参考识别号码或与其身体、生理、心理、经济、文化或社会身份相关的一个或多个特定因素"。
b. 原始设备制造商（OEM）定义的个人数据："由车辆系统组件（例如电子控制单元，ECU）生成且有可能识别用户/驾驶员/乘客的任何数据"。
c. 详细说明：车辆中所有被归类为个人数据的数据；可细分为直接个人数据和间接个人数据。
2. 在OEM车辆中收集、处理和存储的直接和间接个人数据示例



a. 绿色方框内的大部分数据属于间接个人数据，收集、处理并存储在电子控制单元（ECU）中是安全的。
b. 黄色方框内的数据同样属于间接个人数据，但这些数据有可能提供关于数据主体（驾驶员）的直接信息。在电子控制单元（ECU）中收集、处理和存储这些数据，应当有明确的目的。
c. 红色方框内的数据属于直接个人数据，要收集、处理和存储其中任何一项数据，都必须遵循隐私原则。

Classification 1	Classification 2	Grading	
		General Personal Data	Sensitive Personal Data
Personal device information	*Unique device identifiers*	***VIN**, SN, IMEI/MEID, DEVICE_ID, **IMSI/ICCID/MSISDN** in SIM card, (LAN/WLAN/BT/4G/5G/...)**MAC**, **UID/UUID/GUID**, **ANDROID_ID(SSAID)/AAID/GAID/OAID** for Android, UDID/IDFA/IDFV/OpenUDID for iOS, IP Address, etc*	
	Device critical data		*Account and password in JDBC, **OSS Server's account and password**, **Other Server's account and password**, **Device password(System login password, Unlock pattern, UART/JTAG/SSH/FTP login password, etc.),** **Symmetric key**, **Private key of asymmetric key(e.g. PEM)**, **PKCS #12 certificates,** /etc/shadow file*
	Device operating data		***ramdump, coredump***
Biometric data	*Biometric data*		***facial recognition patterns**, **voice recognition patterns**, iris or retina patterns, fingerprints, hand geometry, DNA, signature(the distinctive way a person writes their name), gait(the way a person walks), earlobe geometry, eye patterns*
Audio and Video Recordings	*Cockpit data*		***data collected from the dashcam(video/images and audio), data collected in sentinel mode(video/images and audio), data collected by various cameras(video/images), data collected by MIC(audio), data imported from other devices(video/images and audio).***
Location	*Rough location*		*country, region, province, city,altitude*
	Precise location		***longitude and latitude**(from GPS, Wifi, BT, Cellular, 3rd SDK), Location data obtained through Android's ACCESS_FINE_LOCATION and ACCESS_COARSE_LOCATION permissions. **Driving trajectory**, Travel Itineraries, Travel Records, Route planning, Location history*
Interactive data through HMI(APP)	*Basic Information*	*Names, Date of Birth, Ages, Gender, Ethnic, Nationality, Native place, Marital Status, Family Information, Hobbies and Interests, Nickname, Personal signature, Physical Characteristics (Height and Weight, Eye Colour, etc), etc*	
	Contact Information	*Home Address, Email Address, Work Address, Phone Number, Personal Website URL, etc*	*Emergency Contacts, Friends Contacts(include Bluetooth), etc*
	Communication Records		*Text Messages, Email Correspondence, Call Logs(include Bluetooth), Voice Mails, Social Media Messages, etc*
	Education History	*Academic Transcripts, Diplomas and Certificates, Standardised Test Scores, etc*	
	Employment Records	*Job Title, Employment History, Performance Reviews, Professional Licences, etc*	*Salary Information, etc*
	Identification Numbers		*National Identification Number, Passport Number, Social Security Number, Employee ID, Driver License, Residence permit, etc*

	Financial Information		*Bank Account Number, **Authentication information (password)**, etc*
	Device information		***License Plate**, Engine Number, **Device Name**, **BT Device Name**, **SSID** of Wifi, etc*
	Health Information		*Medical History, Prescription Information, Blood Type, Immunisation Records, Allergy Information, etc*
	Online Behaviour	*APP usage records, Recreational Interests, Likes and Reactions, Tweets and Retweets, Comments, Consumer Preferences, etc*	*Cookies, Token, Online Purchase Records, Browser History, Download History, etc*
	Audio and Video Recordings		*Voicemails, Video Messages, Surveillance Footage, Podcast Appearances, Personal Videos/Images/Audios which were imported from personal devices(such as phone, PC),etc*
	Other		*Religious Beliefs, Political Affiliations, Sexual Orientation, Legal Records, Membership and Affiliations, Psychological Traits, Behavioral Patterns,Social Connections,Personal Beliefs,Minor's information, etc*
data revealing criminal offenses or other infractions			*e.g., data indicating that the vehicle crossed a white line, the instantaneous speed of a vehicle combined with precise location data*

3. 若数据收集、处理和存储是基于法律法规：
a. 原始设备制造商（OEM）应能够证明数据收集是基于一项或多项法律法规（例如欧盟指令/法规及当地法规）。
b. OEM 应能够在其支持网页上展示相关证明。

4. 若因硬件或软件问题，需将存储有个人数据的电子控制单元（ECU）发送给供应商：
a. 务必告知供应商其内存中存储有个人数据。
b. 审查与供应商签订的采购合同，确认供应商是否知晓并遵循欧盟《通用数据保护条例》（GDPR）规定。
c. 确保供应商已与沃尔沃汽车公司（VCC，此处 VCC 推测为特定公司名称，可根据实际情况调整）签订数据保护协议（DPA）。

5. 若电子控制单元（ECU）执行"机器学习"任务，目的是生成主体画像，且使用了直接个人数据（红色方框内的数据）以及以下敏感个人数据：
a. 种族或民族出身
b. 政治观点
c. 宗教或哲学信仰
d. 工会会员身份
e. 健康状况
f. 个人的性生活或性取向
g. 基因数据
h. 可唯一识别个人的生物识别数据（例如指纹、面部识别、虹膜扫描、心跳等）
i. 犯罪记录

这些用于机器学习的数据应满足以下要求：
a. 不得以原始格式进行传输；
b. 在原始格式下应进行加密处理
c. 应确保数据可被擦除，且数据重建的可能性降至最低

车辆数据属于客户的个人数据。数据处理涵盖在数据生命周期内的收集、访问、存储、修改、传输、披露、加密、匿名化、假名化以及销毁等操作。只有当数据处理是基于有效目的和合法依据进行时，才是合法的。
客户的个人数据被定义为与已识别或可识别的自然人直接或间接相关的任何信息。这包括任何能够与客户

车辆相关联的信息，例如车辆识别码（VIN）或上述图片中描述的车辆其他任何标识信息。

Authenticated Encryption of Personal Data in Transit

525153 v4 Authenticated Encryption of Personal Data in Transit

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

1）Only applicable for Personal Data in transit through wireless interfaces.

2）There shall be Authenticated Encryption mechanism(s) with replay protection implemented to ensure that only authorized processes and/or authorized individuals can alter and/or disclose data when Personal Data have been transferred to off-board systems.

The Authenticated Encryption mechanism(s) with replay protection solution shall be documented by the supplier and be reviewed and approved by the OEM.

Note:
Example of such a protection mechanism for Personal Data in transit to off-board backend systems is a mutual-authenticated Transport Layer Security (TLS) secure channel.

1）仅适用于通过无线接口传输的个人数据。
2）应实施具备抗重放保护功能的认证加密机制，以确保在个人数据传输至车外系统时，只有经过授权的流程和/或授权人员能够修改和/或披露数据。

供应商应记录具备抗重放保护功能的认证加密机制解决方案，并由原始设备制造商（OEM）进行审查和批准。

注：
对于传输至车外后端系统的个人数据，此类保护机制的一个示例是采用双向认证的传输层安全协议（TLS）安全通道。

Identify and agree on Personal Data protection

525154 v4 Identify and agree on Personal Data protection

Version history:
(4):

Purpose:
Verification Method: Analysis
Legacy ID:

The OEM and supplier shall together identify, review and agree on Personal Data that needs to be protected by the security mechanisms in “Personal Data Handling in ECUs”.
The identification of Personal Data should be driven by the OEM together with the OEM “Data Protection Coordinator”.

Protection of Personal Data is only applicable when it is stored persistently on non-volatile memory or when it is transferred to any off-board system.

Note:

If the Personal Data is only processed internally within on-board systems volatile memory (i.e. not stored persistently and not transferred off-board), and it is necessary for the vehicle function, it does not need to be protected by the security mechanisms in “Personal Data Handling in ECUs”.

Direct Personal Data needs to be protected by security mechanisms in “Personal Data Handling in ECUs”. Example of direct Personal Data includes location, trip start & end position, biometric data, credentials, search strings, recorded media (e.g. speech messaging), messages (e.g. SMS, emails, etc.), door lock status, crash data, speed.

There are also in-direct Personal Data that have the potential to provide direct information of the driver such as VIN, odometer value, heading, MAC ID, UUID, friction, tie, hazard light, DTE, engine status, alarm status, DTC. In-direct Personal Data handled together with other similar data could potentially be pieced together and become a privacy concern. In-direct Personal Data must thus be handled with care, and investigation should be done to see if it needs to be protected. There shall always be a purpose to collect, process, and store the data in the ECU.

Generally, any data that are stored in the ECU with the possibility to identify the user/driver/passengers are considered direct Personal Data and must be protected by the security mechanisms in “Personal Data Handling in ECUs”.

Refer to Introduction section of this document “Personal Data Handling in ECUs” for more details regarding Personal Data definition.

原始设备制造商（OEM）和供应商应共同识别、审查并商定需要通过“电子控制单元（ECU）中的个人数据处理”部分所规定的安全机制来保护的个人数据。
个人数据的识别工作应由原始设备制造商（OEM）及其“数据保护协调员”共同主导开展。
个人数据的保护仅在数据持久存储于非易失性存储器中，或传输至任何车外系统时适用。
注：
若个人数据仅在车载系统易失性存储器内部进行处理（即未持久存储且未传输至车外），且为车辆功能所必需，则无需通过“电子控制单元（ECU）中的个人数据处理”部分所规定的安全机制进行保护。

直接个人数据需要通过“电子控制单元（ECU）中的个人数据处理”部分所规定的安全机制进行保护。直接个人数据的示例包括位置信息、行程起始和结束位置、生物识别数据、凭证信息、搜索字符串、记录的媒体内容（例如语音信息）、消息（例如短信、电子邮件等）、车门锁状态、碰撞数据、车速等。

此外，还有一些间接个人数据有可能提供关于驾驶员的直接信息，例如车辆识别码（VIN）、里程表读数、行驶方向、媒体访问控制地址（MAC ID）、通用唯一标识符（UUID）、摩擦力、轮胎信息、危险警示灯状态、续航里程估算（DTE）、发动机状态、报警状态、故障诊断码（DTC）等。这些间接个人数据与其他类似数据一起处理时，可能会被拼凑起来，从而引发隐私问题。因此，必须谨慎处理间接个人数据，并调查是否需要对其进行保护。在电子控制单元（ECU）中收集、处理和存储数据，始终应具有明确目的。

一般来说，任何存储在电子控制单元（ECU）中且有可能识别用户/驾驶员/乘客的数据，都被视为直接个人数据，必须通过“电子控制单元（ECU）中的个人数据处理”部分所规定的安全机制进行保护。
有关个人数据定义的更多详细信息，请参阅本文档“电子控制单元（ECU）中的个人数据处理”部分的引言部分。

Personal Data Access Control

525155 v4 Personal Data Access Control

Version history:
(4):

Purpose:
Verification Method: Test
Legacy ID:

Any off-board system that can access Personal Data through vehicle-external interfaces shall be protected with Access Control Mechanism(s).
Examples of such interfaces are:
• Wired connections (OBD)
• Wireless connections (Cellular, WiFi, Bluetooth)

By default, all processing of Personal Data by any off-board systems shall not be allowed until the ECU has verified the authenticity of the off-board system or diagnostic client. This is to ensure that only authorized processes and/or authorized individuals can process Personal Data.

For diagnostic commands used to collect, process, erase and store Personal Data, UDS – Security Access must be used as an Access Control Mechanism prior usage. The Security Access level reserved for “Personal Data” must be used according to “REQPROD 481795 : Security Access Levels”.

The Access Control mechanism(s) solution shall be documented by the supplier and be reviewed and approved by the OEM.

Note:
Another mechanism for access control to off-board backend systems is a mutual-authenticated Transport Layer Security (TLS).

任何能够通过车辆外部接口访问个人数据的车外系统，均应采用访问控制机制进行保护。
此类接口的示例包括：
• 有线连接（如车载诊断系统接口，OBD）
• 无线连接（如蜂窝网络、WiFi、蓝牙）
默认情况下，在电子控制单元（ECU）验证车外系统或诊断客户端的真实性之前，不允许任何车外系统对个人数据进行任何处理。这是为了确保只有经过授权的流程和/或授权人员能够处理个人数据。
对于用于收集、处理、擦除和存储个人数据的诊断命令，在使用前必须使用统一诊断服务（UDS）中的安全访问（Security Access）作为访问控制机制。根据“REQPROD 481795：安全访问级别”的要求，必须使用为“个人数据”预留的安全访问级别。
供应商应记录访问控制机制的解决方案，并由原始设备制造商（OEM）进行审查和批准。
注：
访问车外后端系统的另一种访问控制机制是采用双向认证的传输层安全协议（TLS）。

Secure Erase of Personal Data

525156 v5 **Secure Erase of Personal Data**

Version history:
(5):

Purpose:
Verification Method: Test
Legacy ID:

ECU should delete personal data in the following situations:
1.ECU restored to factory settings
2.Users click the delete personal data button
3.The purpose of data processing has been achieved, cannot be achieved, or the personal data used to achieve that purpose is no longer necessary
4.Individuals withdraw their consent to data collection
5.Before production, all data related to personal information in the development log should be deleted
6.Other circumstances stipulated by laws and administrative regulations

There shall be a mechanism to permanently erase Personal Data in the ECU. Authorized users shall ensure erasure of Personal Data to comply with OEM's data retention policies.

The best available solution provided by the ECU shall be used for Secure Erase to make sure the Personal Data is physically erased from the ECU.

Secure Erase mechanism must be protected by an Access Control Mechanism according to "REQPROD 483635 : Personal Data Access Control".

The Secure Erase solution shall be documented by the supplier and be reviewed and approved by the OEM.

Note:
Secure Erase commands ensures that the data has been physically removed, in contrast to the standard way of only logically erasing it. A normal erase often means that the data is still physically present, but the software driver and memory controller keep track that it has been erased and do not return the real physical contents for performance and usability. The data could in such case easily be retrieved by hackers and forensic experts.

Example of such erase commands are usually available as Secure Erase/Trim on eMMC memory or Secure Purge/Erase on UFS memory.

电子控制单元（ECU）应在以下情况下删除个人数据：
ECU 恢复至出厂设置
用户点击删除个人数据按钮
数据处理目的已达成、无法达成，或用于达成该目的的个人数据不再必要
个人撤回数据收集同意
生产前，应删除开发日志中所有与个人信息相关的数据
法律法规和行政法规规定的其他情形
应建立一种机制，用于永久擦除 ECU 中的个人数据。授权用户应确保按照原始设备制造商（OEM）的数据保留政策擦除个人数据。
应使用 ECU 提供的最佳可用解决方案进行安全擦除，以确保个人数据从 ECU 中被物理擦除。

安全擦除机制必须根据“REQPROD 483635：个人数据访问控制”的要求，通过访问控制机制进行保护。
供应商应记录安全擦除解决方案，并由原始设备制造商（OEM）进行审查和批准。
注：
安全擦除命令可确保数据被物理删除，这与仅进行逻辑删除的标准方式不同。普通擦除通常意味着数据在物理上仍然存在，但软件驱动程序和内存控制器会跟踪其已被擦除的状态，为提高性能和可用性，不会返回真实的物理内容。在这种情况下，黑客和取证专家很容易检索到这些数据。此类擦除命令的示例通常包括 eMMC 内存上的安全擦除/Trim 命令，或 UFS 内存上的安全清除/擦除命令。

Basic Principles of Personal Information Processing

838997 v3 Basic Principles of Personal Information Processing

Version history:
(3):

Purpose:
Verification Method: Analysis
Legacy ID:

<<Template Note: To print in A4 format the width of the description field content (pictures and tables) must be limited to 17 cm.>>

If the supplier has a design to collect personal data, they need to inform the OEM and obtain their approval.

Suppliers should provide OEM with data processing documentation (explaining what data was collected, the legality basis of data collection, the purpose of data processing, how the data was processed, and the data flow) for OEM to review.

Suppliers shall comply with the relevant laws and regulations on personal information processing in the country of sale, including but not limited to the personal data processing principles in GDPR and the personal information processing rules in The Personal Information Protection Law of the People's Republic of China。.

If the Personal Data is only processed internally within on-board systems volatile memory (i.e. not stored persistently and not transferred off-board), and it is necessary for the vehicle function, it does not need to be constrained by this requirement.

若供应商有收集个人数据的设计，需告知原始设备制造商（OEM）并获得其批准。
供应商应向 OEM 提供数据处理文档，说明所收集的数据内容、数据收集的合法性依据、数据处理目的、数据处理方式以及数据流向，供 OEM 审查。
供应商应遵守销售所在国家/地区关于个人信息处理的相关法律法规，包括但不限于欧盟《通用数据保护条例》（GDPR）中的个人数据处理原则以及《中华人民共和国个人信息保护法》中的个人信息处理规则。
若个人数据仅在车载系统易失性存储器内部进行处理（即未持久存储且未传输至车外），且为车辆功能所必需，则不受本要求的约束。

ECU Log Printing Principle

848372 v6 ECU Log Printing Principle

Version history:
(6):

Purpose:
Verification Method: Test
Legacy ID:

The following requirements apply to ECUs that support UDS 0x23, as well as mobile phone apps and TSPS.

The ECU, mobile APP and TSP need to follow the following basic principles when printing logs:

1. Minimum necessity for personal information collection: The printed logs should collect the minimum necessary fields based on the actual business situation. Personal information should not be collected unless it is necessary

Before collecting personal information, it must be evaluated in advance by the OEM business and the compliant party before printing.

2. Requirements for printing sensitive personal information:

a) For sensitive personal information that needs to be printed in the log, encryption methods such as data replacement and randomization, or de-identification and anonymization should be adopted for processing to prevent unauthorized access, acquisition and tampering.

b) The processing of users' sensitive personal information requires the user's consent. Without the user's consent, the processing of users' sensitive information, including log printing, cannot be carried out.

3. Requirements for cross-border data transmission: Personal data cannot be transmitted across borders. Before transmission, a full log list must be provided, desensitized, and approved by OEM before cross-border transmission can be carried out. Desensitization methods can adopt data XOR or use "***" instead.

4. The sensitive information in the Log should meet the requirements of GDPR, GB/T 44464 and GB 44495.

Note: If there are changes in the ECU LOG printing, such as the increase in data printed to the log due to new functions, the above four basic principles should be met.

The Log list filling should include the following information:

1. Data Collection Scenario

1) Team

2) Module/ Application Module/app

3) Function

4) Function Description

2. Data description

1) Data description

3. Data source

1) (provided by the User/read from the Vehicle body/obtained by the dealer/shared internally/obtained from external third parties/obtained from public channels/etc.) (User provided/Vehicle/dealer access/internal sharing/external third party access/public channel access /etc.)

4. Data flow

1) Transmission to related parties (Associated system name)

2) Data transmission frequency (Real-time/Regularly)

3) Is the log class command used to Print to the log? (Yes/No) Print to log? (Yes/No)

4) If printed to log, please give a complete sample

5) Explanation: Key words

6) Necessity Explanation: Please clarify whether it is necessary to print each piece of data (such as SSID,BSSID, vehicle speed, diagnostic code, mobile phone number, longitude, latitude, etc.) in plain text in the log to achieve business purposes (such as after-sales debugging). If "Yes", please clearly state the purpose of data collection.

7) Desensitized examples

8) Desensitization issues

5. Mitigation Required by GRI for solutions required by GRI

1) Desensitization method

2) Whether it is sensitive data and the requirements for data desensitization

6. Data storage

1) Storage mode

7.LOG attachment

数据收集场景 Data Collection Scenario	数据描述 Data description	数据来源 Data source	数据流向 Data flow	Mitigation Required by GRI	数据存储 Data storage	

团队 Team	模块/应用 Module/app	功能 Function	功能描述 Function Description	数据描述 Data description	（用户提供/车身读取/经销商内部共享/外部第三方处获取/公开渠道处获取/）(User provided/Vehicle/dealer access/internal sharing/external third party access/public channel access/)	向关联方传输（关联系统名称）Transmission to related parties (Associated system name)	数据传输频率（实时/定期）Data transmission frequency (Real-time/Regularly)	是否使用log类命令打印到日志中（是/否）Print to log? (Yes/No)	如果打印到日志中，请提供完整示例 If printed to log, please give a complete sample	解释：关键字	必要性请明确各个数据（如SSID,BSSID,车速,诊断码，手机号，经度，纬度等）明文打印到日志中，是否是实现业务目的（如售后debug）所必须的。如“是”，请明确写出数据采集的目的。	脱敏后示例	脱敏问题	脱敏方式	是否是敏感数据，数据脱敏要求	存储方式 Storage mode	附件、LOG
APP	蓝牙模块	蓝牙	智能互联，连接蓝牙设备	蓝牙设备名，MAC地址	用户提供	无	无	是	BluetoothEventManager.java(395): onReceive: BluetoothEventManager ACLConnected device [Name=张安然的iPhone 11 Pro Max , MAC= 44:4A:DB:55:BA:5E]	定位：BluetoothEventManager... [Name=张安然的iPhone 11 Pro Max , MAC= 44:4A:DB:55:BA:5E] （name后面的是设备名称，到逗号处结束MAC后面的是MAC地址，到中括号处结束）	否	BluetoothEventManager.java(395): onReceive: BluetoothEventManager ACLConnected device [Name= ******, MAC= ******]	（开发补充一个完整的日志）	匿名化	是，不可回传	存储车端，有需求上传至云端	
				车辆蓝牙信息	用户提供	无	无	是	BluetoothEventManager.java(434): onReceive: BluetoothEventM	定位：BluetoothEventManager LocalNameChangedHandler name =	否	BluetoothEventManager.java(434): onReceive: BluetoothEvent		匿名化	是，不可回传	存储车端，有需求上传至云端	

									anager LocalNameChangedHandler name = Volvo EX30---BluetoothAdapter.isEnabled()--false	Volvo EX30---BluetoothAdapter.isEnabled()--false（name后面的是车机的蓝牙名称，可全部删掉或匿名化）		Manager LocalNameChangedHandler name = ******					
				蓝牙状态	用户提供	无	无	是	0	定位：CachedBluetoothDevice.java...: getState: Name--张安然的iPhone 11 Pro Max------a2dp---true----hfp---true--mProfiles--[HEADSET_CLIENT, A2DPSink, ecarx.settingslib.profile.AvrcpProfile@55e67f1]（Name后面的是对手的蓝牙名称，可全部删掉或匿名化）	否	CachedBluetoothDevice.java(952): getState: Name--******		匿名化	均可能含设备名称或者设备信息，不可回传	存储车端，有需求上传至云端	

Personal data includes but is not limited to the examples in the following list:

Note: The following list is only an example and not a complete list of personal information. Suppliers are required to cooperate in providing a full log list, which will be jointly identified and a personal information list established by the OEM compliance team. The log list needs to be filled in according to the template provided by the OEM.

一类级别	二级类别	三级类别	个人信息示例	是否敏感个

Class One level	Secondary category	Third-level category	Personal information example	人信息 Whether personal information is sensitive
个人信息 Personal information	个人基本资料 Personal basic information	个人基本资料Personal basic information	自然人基本情况信息，如个人姓名、生日、年龄、性别、民族、国籍、籍贯、婚姻状况、家庭关系、住址、个人电话号码、电子邮件地址、兴趣爱好等Basic information of natural persons, such as personal name, birthday, age, gender, ethnicity, nationality, native place, marital status, family relationship, address, personal phone number, email address, hobbies and interests, etc	General personal information
	个人身份信息 Personal identity information	个人身份信息Personal identity information	可直接标识自然人身份的信息，如身份证、军官证、护照、驾驶证、工作证、出入证、社保卡、居住证、港澳台通行证等证件号码、证件有效期、证件照片或影印件等Information that can directly identify the identity of a natural person, such as ID card numbers, military officer certificates, passports, driver's licenses, work permits, access permits, social security cards, residence permits, Hong Kong, Macao and Taiwan permits, etc., along with their validity periods, photos or photocopies of the documents	Sensitive personal information
	个人生物识别信息Personal biometric information	个人生物识别信息Personal biometric information	生物识别原始信息（如样本、图像等）和比对信息（如特征值、模板等），如人脸、指纹、步态、声纹、基因、虹膜、笔迹、掌纹、耳廓、眼纹等Biometric raw information (such as samples, images, etc.) and comparison information (such as eigenvalues, templates, etc.), such as face, fingerprint, gait, voiceprint, gene, iris, handwriting, palm print, auricle, eye print, etc	Sensitive personal information
	网络身份标识信息Network identity identification information	网络身份标识信息Network identity identification information	可直接标识网络或通信用户身份的信息及账户相关资料信息（金融账户除外），如用户账号、用户 ID 、即时通信账号、网络社交用户账号、用户头像 、昵称、个性签名、 IP 地址、账户开立时间等 Information that can directly identify the identity of network or communication users and account-related data (except for financial	General personal information

			accounts), such as user accounts, user ids, instant messaging accounts, social networking user accounts, user avatars, nicknames, personal signatures, IP addresses, account opening times, etc	
个人健康生理信息Personal health and physiological information	健康状况信息Health status information	与个人身体健康状况相关的一般信息，如体重、身高、体温、肺活量、血压、血型等General information related to an individual's physical health condition, such as weight, height, body temperature, lung capacity, blood pressure, blood type, etc	General personal information
	个人医疗信息Personal medical information	个人因生病医治等产生的相关记录，如病症、住院志、医嘱单、检验报告、体检报告、手术及麻醉记录、护理记录、用药记录、药物食物过敏信息、生育信息、以往病史、诊治情况、家族病史、现病史、传染病史、吸烟史等Personal records related to illness treatment, etc., such as symptoms, hospitalization records, medical orders, test reports, physical examination reports, surgical and anesthesia records, nursing records, medication records, drug and food allergy information, fertility information, past medical history, treatment situation, family medical history, current medical history, infectious disease history, smoking history, etc	General personal information
个人教育工作信息Personal education work information	个人教育信息Personal education information	个人受教育和培训情况相关信息，如学历、学位、教育经历（如入学日期、毕业日期、学校、院系、专业等）、成绩单、资质证书、培训记录等Personal information related to education and training, such as academic qualifications, degrees, educational background (such as enrollment date, graduation date, school, department, major, etc.), transcripts, qualification certificates, training records, etc	General personal information

		个人工作信息Personal work information	个人求职和工作情况相关信息，如个人职业、职位、职称、工作单位、工作地点、工作经历、工资、工作表现、简历等 Personal information related to job hunting and work situation, such as personal occupation, position, title, work unit, work location, work experience, salary, job performance, resume, etc	General personal information
	个人财产信息 Personal property information	金融账户信息Financial account information	金融账户及账户相关信息，如银行卡号、支付账号、银行卡磁道数据（或芯片等效信息）、银行卡有效期、证券账户、基金账户、保险账户、公积金账户、公积金联名账号、账户开立时间、开户机构、账户余额、支付标记信息等Financial accounts and related account information, such as bank card numbers, payment account numbers, bank card track data (or chip equivalent information), bank card validity period, securities accounts, fund accounts, insurance accounts, provident fund accounts, provident fund co-branded accounts, account opening time, opening institution, account balance, payment marking information, etc	Sensitive personal information
		个人交易信息Personal transaction information	交易过程中产生的交易信息和消费记录，如交易订单、交易金额、支付记录、透支记录、交易状态、交易日志、交易凭证、账单，证券委托、成交、持仓信息，保单信息、理赔信息等Transaction information and consumption records generated during the transaction process, such as transaction orders, transaction amounts, payment records, overdraft records, transaction status, transaction logs, transaction vouchers, bills, securities entrustment, transaction, position information, policy information, claims information, etc	Sensitive personal information
		个人资产信息Personal asset information	个人实体和虚拟财产信息，如个人收入状况、房产信息、存款信息、车辆信息、纳税额、公积金缴存明细（含余额、基数、缴纳公司、公积金中心、状态等）、银行流水、虚拟财产（虚拟货币、虚拟交易、游戏类兑换码等）、个人社保与医保存缴金额等。	Sensitive personal information

			Personal physical and virtual property information, such as personal income status, real estate information, deposit information, vehicle information, tax payment amount, housing provident fund contribution details (including balance, base, contributing company, housing provident fund center, status, etc.), bank statements, virtual property (virtual currency, virtual transactions, game redemption codes, etc.), personal social security and medical insurance deposit and payment amounts, etc.	
		个人借贷信息Personal loan information	个人在借贷过程中产生的信息，如个人借款信息、还款信息、欠款 信息、信贷记录、征信信息、担保情况等The information generated by an individual during the borrowing process, such as personal loan information, repayment information, outstanding debt information, credit records, credit information, guarantee situations, etc	Sensitive personal information
	身份鉴别信息 Identity verification information	身份鉴别信息Identity verification information	用于身份鉴别的数据，如账户登录密码、银行卡密码、支付密码、账户查询密码、交易密码、银行卡有效期、银行卡片验证码（CVN 和 CVN2）、 USBKEY 、动态口令、 U 盾（网银、手机银行密保工具信息）、短信验证码、密码提示问题答案、手机客服密码、个人数字证书、随机令牌等Data used for identity verification Such as account login password, bank card password, payment password, account inquiry password, transaction password, bank card validity period, bank card verification code (CVN and CVN2), USBKEY, dynamic password, U Shields (information of online banking and mobile banking security tools), SMS verification codes, answers to password prompt questions, mobile customer service passwords, personal digital certificates, random tokens, etc	Sensitive personal information

	个人通信信息 Personal communication information	个人通信信息Personal communication information	通信记录，短信、彩信、话音、电子邮件、即时通信等通信内容（如文字、图片、音频、视频、文件等），及描述个人通信的元数据（如通话时长）等 Communication records, including text messages, multimedia messages, voice messages, emails, instant messaging and other communication contents (such as text, pictures, audio, video, files, etc.), as well as metadata describing personal communications (such as call duration), etc	Sensitive personal information
	联系人信息 Contact person information	联系人信息Contact person information	描述个人与关联方关系的信息，如通讯录、好友列表、群列表、电子邮件地址列表、家庭关系、工作关系、社交关系等 Information describing an individual's relationship with related parties, such as contact lists, friend lists, group lists, email address lists, family relationships, work relationships, social relationships, etc	Sensitive personal information
	个人上网记录 Personal Internet access record	个人操作记录Personal operation record	个人在业务服务过程中的操作记录和行为数据，包括网页浏览记录、软件使用记录、点击记录、 Cookie 、发布的社交信息、点击记录、收藏列表、搜索记录、服务使用时间、下载记录、访问时间（含登录时间、退出时间）等Personal operation records and behavioral data during the business service process, including web browsing records, software usage records, click records, cookies, posted social information, click records, collection lists, search records, service usage time, download records, access time (including login time and logout time), etc	Sensitive personal information
		业务行为数据Business behavior data	用户使用某业务的行为记录（如游戏业务：用户游戏登录时间、最近充值时间、累计充值额度、用户通关记录）等 Records of a user's behavior when using a certain service (such as for game services: the user's game login time, the most recent recharge time, the cumulative recharge amount, the user's clearance record), etc	General personal information
	个人设备信息 Personal device information	可变更的唯一设备识别码A changeable and unique device identification code	Android ID、 IDFA 、 IDFV 、 OAID 等 Android ID, IDFA, IDFV, OAID, etc	General personal information

	不可变更的唯一设备识别码 An unalterable and unique device identification code	IMEI、 IMSI 、 MEID 、设备 MAC 地址、硬件序列号、ICCID 等IMEI, IMSI, MEID, device MAC address, hardware serial number, ICCID, etc	General personal information
	应用软件列表List of application software	终端上安装的应用程序列表，如每款应用软件的名称、版本等A list of applications installed on the terminal, such as the name and version of each application software	General personal information
个人位置信息 Personal location information	粗略位置信息Rough location information	仅能定位到行政区、县级等的位置信息，如地区代码、城市代码等It can only locate the location information of administrative regions, counties, etc., such as area codes, city codes, etc	General personal information
	精确位置信息Precise position information	能具体定位到个人的地理位置数据，包括行踪轨迹、经纬度、住宿信息、小区代码、基站号、基站经纬度坐标等It can precisely locate an individual's geographical location data, including travel trajectories, longitude and latitude, accommodation information, community codes, base station numbers, and the longitude and latitude coordinates of base stations, etc	Sensitive personal information
个人标签信息 Personal tag information	个人标签信息Personal tag information	基于个人上网记录等各类个人信息加工产生的用于对个人用户分类分析的描述信息，如 App 偏好、关系标签、终端偏好、内容偏好等标签信息Descriptive information generated based on various personal information such as personal online records for classifying and analyzing individual users, such as App preferences, relationship tags, terminal preferences, content preferences and other tag information	General personal information
个人运动信息 Personal sports information	个人运动信息Personal sports information	步数、步频、运动时长、运动距离、运动方式、运动心率等Step count, step frequency, exercise duration, exercise distance, exercise style, exercise heart rate, etc	General personal information
其他个人信息 Other personal information	其他个人信息Other personal information	性取向、婚史、宗教信仰、未公开的违法犯罪记录等Sexual orientation, marital history, religious belief, and undisclosed criminal records, etc	General personal information

	个人车辆标识 Personal vehicle identification	个人车辆标识Personal vehicle identification	VIN、车牌号、行驶证等VIN, license plate number, vehicle registration certificate, etc	General personal information
	其他信息Other information	其他信息Other information	个人音频、视频、图像数据Personal audio, video and image data	Sensitive personal information
	特殊类别（来自GDPR）Special Category (from GDPR)	种族或民族起源Racial or ethnic origin	包括基因和生物特征数据，当用于唯一识别个人时。Including genetic and biometric data, when used to uniquely identify an individual.	Sensitive personal information
		政治观点Political viewpoint	任何表明个人政治立场的信息。	Sensitive personal information
			Any information indicating an individual's political stance.	Sensitive personal information
		宗教或哲学信仰Religious or philosophical belief	与个人宗教或哲学信仰相关的信息。Information related to an individual's religious or philosophical beliefs.	Sensitive personal information
		工会会员资格Trade union membership qualification	个人是否属于工会的信息。Information on whether an individual belongs to a trade union.	Sensitive personal information
		健康信息Health information	包括生理和心理健康状况，以及医疗历史。Including physical and mental health conditions, as well as medical history.	Sensitive personal information
		性生活或性取向Sexual life or sexual orientation	涉及个人性生活或性取向的任何信息。Any information related to an individual's human life or sexual orientation.	Sensitive personal information
车辆信息 Vehicle information	车辆鉴别数据 Vehicle identification data	车辆鉴别数据Vehicle identification data	用于验证车辆及零部件身份的信息，私钥证书(包含证书链和 rot CA)对称密,P12文件pasword 、调试口的密码UART/TAG/USB/ADB/SH等)、PNCde安全启动的密码， 会话密钥Information for verifying the identities of vehicles and components, private key certificates (including certificate chains and rot CA), symmetric passwords,P12 file pasword, passwords for debug ports such as UART/TAG/USB/ADB/SH, etc., passwords for secure startup of PNCde, and session keys	General personal information

	业务端口 Business port	关键业务的端口号Port numbers for critical business		General personal information
	数字钥匙Digital key	数字钥匙的信息的关键信息 The key information of the digital key	钥匙的秘钥，钥匙的long D,card key，钥匙状态信息，error code 等The secret key of the key, the long D of the key, the card key, the key status information, the error code, etc	General personal information
	运行状态 Operating status	运行状态Operating status	车速、里程Vehicle speed, mileage	General personal information
			加速、减速模式，紧急制动频率等（反应车主的驾驶习惯）Acceleration and deceleration modes, emergency braking frequency, etc. (reflecting the driving habits of the car owner)	General personal information
	车辆维保数据 Vehicle maintenance and repair data	车辆维保数据Vehicle maintenance and repair data	如仪表灯、发动机健康状态、刹车磨损程度等 （反映车主的驾驶习惯和维护行为）	General personal information
			Such as instrument panel lights, engine health status, brake wear degree, etc. (reflecting the driving habits and maintenance behaviors of the car owner)	General personal information
	车内环境数据In-vehicle environment data	车内环境数据In-vehicle environment data	温度、湿度、空气质量等Temperature, humidity, air quality, etc	General personal information

以下要求适用于支持 UDS 0x23 的电子控制单元（ECU），以及手机应用程序（APP）和远程服务提供商（TSPS）。
ECU、手机 APP 和 TSP 在打印日志时，需遵循以下基本原则：
个人信息收集的最小必要性原则：
打印的日志应根据实际业务情况，收集最少必要的字段。除非必要，否则不应收集个人信息。
在收集个人信息前，必须由原始设备制造商（OEM）业务部门和合规方提前进行评估，评估通过后方可打印。
敏感个人信息打印要求：
a) 对于需要在日志中打印的敏感个人信息，应采用数据替换、随机化等加密方法，或去标识化、匿名化等方式进行处理，以防止未经授权的访问、获取和篡改。
b) 处理用户的敏感个人信息需要获得用户的同意。未经用户同意，不得对用户的敏感信息进行包括日志打印在内的任何处理。
跨境数据传输要求：
个人数据不得跨境传输。在传输前，必须提供完整的日志列表，进行脱敏处理，并经 OEM 批准后方可进行跨境传输。脱敏方法可以采用数据异或或使用“***”替代。
日志中的敏感信息应符合 GDPR、GB/T 44464 和 GB 44495 的要求：
注：如果 ECU 日志打印发生变更，例如因新功能增加打印到日志的数据，应满足上述四项基本原则。
日志列表填写应包括以下信息：

数据收集场景：
团队
模块/应用模块/APP
功能
功能描述
数据描述：
数据详细描述
数据来源：
（由用户提供/从车身读取/由经销商获取/内部共享/从外部第三方获取/从公共渠道获取等）（用户提供/车身/经销商访问/内部共享/外部第三方访问/公共渠道访问等）
数据流：
传输给相关方（关联系统名称）
数据传输频率（实时/定期）
是否使用日志类命令打印到日志？（是/否）
如果打印到日志，请给出完整示例
解释：关键词
必要性解释：请明确说明在日志中以明文形式打印每条数据（如 SSID、BSSID、车速、诊断代码、手机号码、经度、纬度等）以实现业务目的（如售后调试）是否必要。如果“是”，请明确说明数据收集的目的。
脱敏示例
脱敏问题
GRI 要求的解决方案所需的缓解措施：
脱敏方法
是否为敏感数据及数据脱敏要求
数据存储：
存储模式
日志附件（如有）

个人数据包括但不限于以下列表中的示例：
注：以下列表仅为示例，并非个人信息的完整清单。供应商需配合提供完整的日志列表，该列表将由原始设备制造商（OEM）的合规团队共同确认，并据此建立个人信息清单。日志列表需按照 OEM 提供的模板进行填写。

Data secure storage

988308 v3 **Data secure storage**

Version history:
(3):

Purpose:
Verification Method: Test
Legacy ID:

[REQUIRED] Vehicles should adopt isolation technology and secure access techniques to protect Personal Data stored within the car, to prevent unauthorized access and acquisition.

Technical implementation method for reference:

Technology	Implementation method
Isolation	The loosely coupled software functions should be isolated using separate processes, with each process having its own unique UID. Additionally, data collected by a process should only be accessible and manipulable by that process(For example, set the file permission to rw-------). Of course, you can also use virtualization technology or sandbox for isolation, or

	even adopt physical separation.
Secure Access	All processing of Personal Data by any off-board systems shall not be allowed until the ECU has verified the authenticity of the off-board system or diagnostic client.

[REQUIRED] Unless otherwise specified, vehicles should employ additional encryption technologies to protect sensitive Personal Data stored within the vehicle or store it in a secure environment to prevent unauthorized access and acquisition.

Technical implementation method:

Technology	Method
Secure Environment	The Secure Environment could be realized through the use of Trusted Execution Environment (TEE) or Hardware Security Module (HSM).
Encryption	Save sensitive Personal Data after encrypting it using an open, published, and effective password algorithm, and promptly delete the original data. Internationally recognized encryption algorithms include: AES128/192/256 (Must not use ECB mode, as it is considered insecure), RSA2048/3072/4096, and ECC256/384/521. The utilization of a more secure encryption algorithm must be prioritized. It is only appropriate to resort to a encryption algorithm of the next security level when the system does not provide support or if there is a substantial detriment to performance.

For example:

1. Contact lists, communication records, and content transferred from personal devices to the vehicle need to be encrypted before being stored.

2. If location data is collected in the logs (which is often unnecessary), then the location data needs to be encrypted before being stored.

3. Coredump or ramdump often contain sensitive data. These dumps are essentially snapshots of the memory of a system at a certain point in time. This means that they could potentially contain any data that the system was processing at that moment. In some situations, these dumps could contain highly sensitive information. If the system was handling personal data, confidential business information or any other form of sensitive information at the time of the dump, then this data could potentially be included in the coredump or ramdump. Therefore, it's crucial to treat these dumps as sensitive data itself. Appropriate security measures should be put in place, such as encryption and restricted access, to protect the data contained in them.

Notes: Another more reasonable measure is to prevent the system from generating these types of dumps after the software is released.

[REQUIRED] Symmetric keys or private keys in asymmetric pairs used for the encryption of sensitive Personal Data need to be stored in a secure environment(such as HSM or TEE) to prevent unauthorized access and acquisition.

[REQUIRED] The keys used for encrypting sensitive Personal Data must be unique for each vehicle, not for each vehicle model. If conditions permit, must use a unique key for each function.

[REQUIRED] Any off-board system that can access Personal Data through vehicle-external interfaces shall be protected with Access Control Mechanism(s).

[必需] 车辆应采用隔离技术和安全访问技术，以保护车内存储的个人数据，防止未经授权的访问和获取。
技术实现方法参考：

技术	实现方法
隔离	松耦合的软件功能应使用独立进程进行隔离，每个进程应具有唯一的用户标识符（UID）。此外，某一进程收集的数据应仅由该进程访问和操作（例如，将文件权限

	设置为 rw-------）。当然，也可以使用虚拟化技术或沙箱进行隔离，甚至采用物理隔离。
安全访问	在电子控制单元（ECU）验证车外系统或诊断客户端的真实性之前，不得允许任何车外系统对个人数据进行任何处理。

[必需] 除非另有规定，车辆应采用额外的加密技术来保护车内存储的敏感个人数据，或将其存储在安全环境中，以防止未经授权的访问和获取。
技术实现方法：

技术	方法
安全环境	安全环境可通过使用可信执行环境（TEE）或硬件安全模块（HSM）来实现。
加密	使用公开、有效且国际认可的密码算法对敏感个人数据进行加密后保存，并及时删除原始数据。国际认可的加密算法包括：AES128/192/256（不得使用 ECB 模式，因其被认为不安全）、RSA2048/3072/4096 和 ECC256/384/521。应优先采用更安全的加密算法。仅当系统不支持或对性能有重大损害时，才应考虑采用下一安全级别的加密算法。

例如：
1. 从个人设备传输到车辆的联系人列表、通信记录和内容在存储前需进行加密。
2. 如果日志中收集了位置数据（通常不必要），则位置数据在存储前需进行加密。
3. 核心转储（coredump）或内存转储（ramdump）通常包含敏感数据。这些转储本质上是在某一时刻系统内存的快照，意味着它们可能包含系统当时正在处理的任何数据。在某些情况下，这些转储可能包含高度敏感的信息。如果系统在转储时正在处理个人数据、机密商业信息或任何其他形式的敏感信息，则这些数据可能包含在核心转储或内存转储中。因此，必须将这些转储本身视为敏感数据，并采取适当的安全措施，如加密和限制访问，以保护其中包含的数据。
注：另一项更合理的措施是在软件发布后防止系统生成这些类型的转储。

[必需] 用于加密敏感个人数据的对称密钥或非对称密钥对中的私钥需存储在安全环境中（如 HSM 或 TEE），以防止未经授权的访问和获取。

[必需] 用于加密敏感个人数据的密钥必须针对每辆车唯一，而不是针对每款车型。如果条件允许，必须为每个功能使用唯一的密钥。

[必需] 任何能够通过车外接口访问个人数据的车外系统都应采用访问控制机制进行保护。

4.2 CSRS

5 DETAILED CHANGE INFO